

	DIN EN IEC 62443-4-2 (VDE 0802-4-2)	
	Diese Norm ist zugleich eine VDE-Bestimmung im Sinne von VDE 0022. Sie ist nach Durchführung des vom VDE-Präsidium beschlossenen Genehmigungsverfahrens unter der oben angeführten Nummer in das VDE-Vorschriftenwerk aufgenommen und in der „etz Elektrotechnik + Automation“ bekannt gegeben worden.	

Vervielfältigung – auch für innerbetriebliche Zwecke – nicht gestattet.

ICS 25.040.40; 35.030; 35.240.50

**IT-Sicherheit für industrielle Automatisierungssysteme –
Teil 4-2: Technische Sicherheitsanforderungen an Komponenten
industrieller Automatisierungssysteme (IACS)
(IEC 62443-4-2:2019);
Deutsche Fassung EN IEC 62443-4-2:2019**

Security for industrial automation and control systems –
Part 4-2: Technical security requirements for IACS components
(IEC 62443-4-2:2019);
German version EN IEC 62443-4-2:2019

Sécurité des systèmes d'automatisation et de commande industrielles –
Partie 4-2: Exigences de sécurité technique des composants IACS
(IEC 62443-4-2:2019);
Version allemande EN IEC 62443-4-2:2019

Gesamtumfang 106 Seiten

DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE

© VDE Verband der Elektrotechnik Elektronik Informationstechnik e. V. und DIN Deutsches Institut für Normung e. V. sind Inhaber aller einfachen Rechte der Verwertung, gleich in welcher Form und welchem Verfahren.

Einzelverkauf und Abonnements durch VDE VERLAG GMBH, 10625 Berlin
Einzelverkauf auch durch Beuth Verlag GmbH, 10772 Berlin

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12

Anwendungsbeginn

Anwendungsbeginn für die von CENELEC am 2019-04-03 angenommene Europäische Norm als DIN-Norm ist 2019-12-01.

Nationales Vorwort

Vorausgegangener Norm-Entwurf: E DIN EN 62443-4-2 (VDE 0802-4-2):2017-10.

Für dieses Dokument ist das nationale Arbeitsgremium UK 931.1 „IT-Sicherheit in der Automatisierungstechnik“ der DKE Deutsche Kommission Elektrotechnik Elektronik Informationstechnik in DIN und VDE (www.dke.de) zuständig.

Die enthaltene IEC-Publikation wurde vom TC 65 „Industrial-process measurement, control and automation“ erarbeitet.

Das IEC-Komitee hat entschieden, dass der Inhalt dieses Dokuments bis zu dem Datum (stability date) unverändert bleiben soll, das auf der IEC-Website unter „<http://webstore.iec.ch>“ zu diesem Dokument angegeben ist. Zu diesem Zeitpunkt wird entsprechend der Entscheidung des Komitees das Dokument

- bestätigt,
- zurückgezogen,
- durch eine Folgeausgabe ersetzt oder
- geändert.

Das Original-Dokument enthält Bilder in Farbe, die in der Papierversion in einer Graustufen-Darstellung wiedergegeben werden. Elektronische Versionen dieses Dokuments enthalten die Bilder in der originalen Farbdarstellung.

Die Deutsche Fassung wurde im [Abschnitt 3.1](#) an den aktuellen Standardtext angepasst.

Nationaler Anhang NA (informativ)

Zusammenhang mit europäischen und internationalen Dokumenten

Für den Fall einer undatierten Verweisung im normativen Text (Verweisung auf ein Dokument ohne Angabe des Ausgabedatums und ohne Hinweis auf eine Abschnittsnummer, eine Tabelle, ein Bild usw.) bezieht sich die Verweisung auf die jeweils aktuellste Ausgabe des in Bezug genommenen Dokuments.

Für den Fall einer datierten Verweisung im normativen Text bezieht sich die Verweisung immer auf die in Bezug genommene Ausgabe des Dokuments.

Eine Information über den Zusammenhang der zitierten Dokumente mit den entsprechenden deutschen Dokumenten ist nachstehend wiedergegeben.

Tabelle NA.1

Europäisches Dokument	Internationales Dokument	Deutsches Dokument	Klassifikation im VDE-Vorschriftenwerk
–	IEC 60050-351	^a und DIN IEC 60050-351	–
–	IEC 60050-732	^a	–
EN 61131-3	IEC 61131-3	DIN EN 61131-3	–
–	IEC 62443-2-1	–	–
EN IEC 62443-2-4	IEC 62443-2-4	DIN EN IEC 62443-2-4 (VDE 0802-2-4) ^b	VDE 0802-2-4
–	IEC 62443-3-2	–	–
EN IEC 62443-3-3	IEC 62443-3-3:2013	–	–
EN IEC 62443-4-1	IEC 62443-4-1	DIN EN IEC 62443-4-1 (VDE 0802-4-1)	VDE 0802-4-1
–	IEC TR 61850-1:2013	–	–
–	IEC TR 62443-3-1	–	–
–	IEC TR 62443-2-3	–	–
–	IEC TS 62443-1-1	–	–
EN ISO/IEC 7498-1:1995 <i>zurückgezogen</i>	ISO/IEC 7498-1:1994	DIN EN ISO/IEC 7498-1:1995-12 <i>zurückgezogen</i>	–
–	ISO 8601:2004	DIN ISO 8601:2006-09	–
–	ISO/IEC 11889-1:2015	–	–
–	ISO/IEC 15408-1:2009	–	–
–	ISO/IEC 19790	–	–
EN ISO/IEC 27002:2017	ISO/IEC 27002:2013	DIN EN ISO/IEC 27002:2017-06	–
^a „Internationales Elektrotechnisches Wörterbuch – Deutsche Ausgabe“, Online-Zugang: http://www.dke.de/dke-iev .			
^b In Vorbereitung.			

Nationaler Anhang NB (informativ)

Literaturhinweise

DIN IEC 60050-351, *Internationales Elektrotechnisches Wörterbuch – Teil 351: Leittechnik*

DIN EN 61131-3, *Speicherprogrammierbare Steuerungen – Teil 3: Programmiersprachen*

DIN EN IEC 62443-2-4 (VDE 0802-2-4) (in Vorbereitung), *IT-Sicherheit für industrielle Automatisierungssysteme – Teil 2-4: Anforderungen an das IT-Sicherheitsprogramm von Dienstleistern für industrielle Automatisierungssysteme*

DIN EN IEC 62443-4-1 (VDE 0802-4-1), *IT-Sicherheit für industrielle Automatisierungssysteme – Teil 4-1: Anforderungen an den Lebenszyklus für eine sichere Produktentwicklung*

DIN EN ISO/IEC 7498-1:1995-12 (zurückgezogen), *Informationstechnik – Kommunikation Offener Systeme – Teil 1: Basis-Referenzmodell: Basismodell (ISO/IEC 7498-1:1994); Englische Fassung EN ISO/IEC 7498-1:1995*

DIN EN ISO/IEC 27002:2017-06, *Informationstechnik – Sicherheitsverfahren – Leitfaden für Informationssicherheitsmaßnahmen (ISO/IEC 27002:2013 einschließlich Cor 1:2014 und Cor 2:2015); Deutsche Fassung EN ISO/IEC 27002:2017*

DIN ISO 8601:2006-09, *Datenelemente und Austauschformate – Informationsaustausch – Darstellung von Datum und Uhrzeit (ISO 8601:2004)*

IT-Sicherheit für industrielle Automatisierungssysteme –
Teil 4-2: Technische Sicherheitsanforderungen an Komponenten industrieller
Automatisierungssysteme (IACS)
(IEC 62443-4-2:2019)

Security for industrial automation and control
systems –
Part 4-2: Technical security requirements for
IACS components
(IEC 62443-4-2:2019)

Sécurité des systèmes d'automatisation et de
commande industrielles –
Partie 4-2: Exigences de sécurité technique des
composants IACS
(IEC 62443-4-2:2019)

Diese Europäische Norm wurde von CENELEC am 2019-04-03 angenommen. CENELEC-Mitglieder sind gehalten, die CEN/CENELEC-Geschäftsordnung zu erfüllen, in der die Bedingungen festgelegt sind, unter denen dieser Europäischen Norm ohne jede Änderung der Status einer nationalen Norm zu geben ist.

Auf dem letzten Stand befindliche Listen dieser nationalen Normen mit ihren bibliographischen Angaben sind beim CEN-CENELEC Management Centre oder bei jedem CENELEC-Mitglied auf Anfrage erhältlich.

Diese Europäische Norm besteht in drei offiziellen Fassungen (Deutsch, Englisch, Französisch). Eine Fassung in einer anderen Sprache, die von einem CENELEC-Mitglied in eigener Verantwortung durch Übersetzung in seine Landessprache gemacht und dem CEN-CENELEC Management Centre mitgeteilt worden ist, hat den gleichen Status wie die offiziellen Fassungen.

CENELEC-Mitglieder sind die nationalen elektrotechnischen Komitees von Belgien, Bulgarien, Dänemark, Deutschland, der ehemaligen jugoslawischen Republik Mazedonien, Estland, Finnland, Frankreich, Griechenland, Irland, Island, Italien, Kroatien, Lettland, Litauen, Luxemburg, Malta, den Niederlanden, Norwegen, Österreich, Polen, Portugal, Rumänien, Schweden, der Schweiz, Serbien, der Slowakei, Slowenien, Spanien, der Tschechischen Republik, der Türkei, Ungarn, dem Vereinigten Königreich und Zypern.



Europäisches Komitee für Elektrotechnische Normung
European Committee for Electrotechnical Standardization
Comité Européen de Normalisation Electrotechnique

CEN-CENELEC Management Centre: Rue de la Science 23, B-1040 Brüssel

© 2019 CENELEC – Alle Rechte der Verwertung, gleich in welcher Form und in welchem Verfahren, sind weltweit den Mitgliedern von CENELEC vorbehalten.

Ref. Nr. EN IEC 62443-4-2:2019 D

Europäisches Vorwort

Der Text des Dokuments 65/735/FDIS, zukünftige 1. Ausgabe der IEC 62443-4-2, erarbeitet vom IEC/TC 65 „Industrial-process measurement, control and automation“, wurde zur parallelen IEC-CENELEC-Abstimmung vorgelegt und von CENELEC als EN IEC 62443-4-2:2019 angenommen.

Nachstehende Daten wurden festgelegt:

- spätestes Datum, zu dem dieses Dokument auf nationaler Ebene durch Veröffentlichung einer identischen nationalen Norm oder durch Anerkennung übernommen werden muss (dop): 2020-01-03
- spätestes Datum, zu dem nationale Normen, die diesem Dokument entgegenstehen, zurückgezogen werden müssen (dow): 2022-04-03

Es wird auf die Möglichkeit hingewiesen, dass einige Elemente dieses Dokuments Patentrechte berühren können. CENELEC ist nicht dafür verantwortlich, einige oder alle diesbezüglichen Patentrechte zu identifizieren.

Anerkennungsnotiz

Der Text der Internationalen Norm IEC 62443-4-2:2019 wurde von CENELEC als Europäische Norm ohne irgendeine Abänderung als Europäische Norm angenommen.

In der offiziellen Fassung sind unter „Literaturhinweise“ zu den aufgelisteten Normen die nachstehenden Anmerkungen einzutragen:

ISO/IEC 27002:2013	ANMERKUNG	Harmonisiert als EN ISO/IEC 27002:2017 (nicht modifiziert).
IEC 62264-1	ANMERKUNG	Harmonisiert als EN 62264-1.
IEC 62443-3-2	ANMERKUNG	Harmonisiert als EN 62443-3-2 ^{Z1} .

^{Z1} In Vorbereitung. Dokumentstufe zum Zeitpunkt der Veröffentlichung: prEN 62443-3-2:2018.

Anhang ZA (normativ)

Normative Verweisungen auf internationale Publikationen mit ihren entsprechenden europäischen Publikationen

Die folgenden Dokumente werden im Text in solcher Weise in Bezug genommen, dass einige Teile davon oder ihr gesamter Inhalt Anforderungen des vorliegenden Dokuments darstellen. Bei datierten Verweisungen gilt nur die in Bezug genommene Ausgabe. Bei undatierten Verweisungen gilt die letzte Ausgabe des in Bezug genommenen Dokuments (einschließlich aller Änderungen).

ANMERKUNG 1 Ist eine internationale Publikation durch gemeinsame Abänderungen modifiziert worden, gekennzeichnet durch (mod.), dann gilt die entsprechende EN oder das HD.

ANMERKUNG 2 Aktualisierte Informationen über die in diesem Anhang aufgeführten aktuellen Fassungen der Europäischen Normen sind hier verfügbar: www.cenelec.eu.

<u>Publikation</u>	<u>Jahr</u>	<u>Titel</u>	<u>EN/HD</u>	<u>Jahr</u>
IEC/TS 62443-1-1	–	Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models	–	–
IEC 62443-3-3	2013	Industrial communication networks – Network and system security – Part 3-3: System security requirements and security levels	–	–
IEC 62443-4-1	–	Security for industrial automation and control systems – Part 4-1: Secure product development lifecycle requirements	EN IEC 62443-4-1	–

Inhalt

	Seite
Europäisches Vorwort.....	2
Anhang ZA (normativ) Normative Verweisungen auf internationale Publikationen mit ihren entsprechenden europäischen Publikationen	3
Einleitung	16
0.1 Übersicht	16
0.2 Zweck und Anwenderkreis	17
1 Anwendungsbereich	19
2 Normative Verweisungen	19
3 Begriffe, Abkürzungen, Akronyme und Vereinbarungen	19
3.1 Begriffe	19
3.2 Abkürzungen und Akronyme	27
3.3 Vereinbarungen	29
4 Sicherheitsbeschränkungen für gemeinsame Komponenten (en: Common component security constraints).....	30
4.1 Übersicht	30
4.2 CCSC 1: Unterstützung wesentlicher Funktionen	30
4.3 CCSC 2: Ausgleichsmaßnahmen.....	30
4.4 CCSC 3: Minimal erforderliche Rechte	31
4.5 CCSC 4: Softwareentwicklungsprozess.....	31
5 FR 1 – Identifizierung und Authentifikation.....	31
5.1 Zweck und Beschreibungen der SL-C (IAC)	31
5.2 Begründung	31
5.3 CR 1.1 – Identifizierung und Authentifikation von menschlichen Nutzern	32
5.3.1 Anforderung.....	32
5.3.2 Begründungen und zusätzliche Leitfäden	32
5.3.3 Weitergehende Anforderungen	32
5.3.4 Security-Level.....	32
5.4 CR 1.2 – Identifizierung und Authentifikation von Softwareprozessen und Geräten	33
5.4.1 Anforderung.....	33
5.4.2 Begründungen und zusätzliche Leitfäden	33
5.4.3 Weitergehende Anforderungen	33
5.4.4 Security-Level.....	33
5.5 CR 1.3 – Nutzerkontenverwaltung	34
5.5.1 Anforderung.....	34
5.5.2 Begründungen und zusätzliche Leitfäden	34
5.5.3 Weitergehende Anforderungen	34
5.5.4 Security-Level.....	34
5.6 CR 1.4 – Verwaltung der Kennungen.....	34

	Seite
5.6.1 Anforderung	34
5.6.2 Begründungen und zusätzliche Leitfäden.....	34
5.6.3 Weitergehende Anforderungen	35
5.6.4 Security-Level	35
5.7 CR 1.5 – Verwaltung der Authentifizierer.....	35
5.7.1 Anforderung	35
5.7.2 Begründungen und zusätzliche Leitfäden.....	35
5.7.3 Weitergehende Anforderungen	36
5.7.4 Security-Level	36
5.8 CR 1.6 – Verwaltung drahtloser Zugriffsverfahren.....	36
5.9 CR 1.7 – Stärke der Authentifikation durch Passwörter.....	36
5.9.1 Anforderung	36
5.9.2 Begründungen und zusätzliche Leitfäden.....	36
5.9.3 Weitergehende Anforderungen	37
5.9.4 Security-Level	37
5.10 CR 1.8 – PKI-Zertifikate	37
5.10.1 Anforderung	37
5.10.2 Begründungen und zusätzliche Leitfäden.....	37
5.10.3 Weitergehende Anforderungen	37
5.10.4 Security-Level	37
5.11 CR 1.9 – Stärke der Authentifikation durch öffentliche Schlüssel.....	38
5.11.1 Anforderung	38
5.11.2 Begründungen und zusätzliche Leitfäden.....	38
5.11.3 Weitergehende Anforderungen	39
5.11.4 Security-Level	39
5.12 CR 1.10 – Rückmeldung vom Authentifizierer	39
5.12.1 Anforderung	39
5.12.2 Begründungen und zusätzliche Leitfäden.....	39
5.12.3 Weitergehende Anforderungen	39
5.12.4 Security-Level	39
5.13 CR 1.11 – Erfolgreiche Anmeldeversuche	40
5.13.1 Anforderung	40
5.13.2 Begründungen und zusätzliche Leitfäden.....	40
5.13.3 Weitergehende Anforderungen	40
5.13.4 Security-Level	40
5.14 CR 1.12 – Nutzungshinweis des Systems	40
5.14.1 Anforderung	40
5.14.2 Begründungen und zusätzliche Leitfäden.....	41
5.14.3 Weitergehende Anforderungen	41

	Seite
5.14.4 Security-Level.....	41
5.15 CR 1.13 – Zugriff über nicht vertrauenswürdige Netzwerke	41
5.16 CR 1.14 – Stärke der Authentifikation durch symmetrische Schlüssel	41
5.16.1 Anforderung.....	41
5.16.2 Begründungen und zusätzliche Leitfäden	41
5.16.3 Weitergehende Anforderungen	42
5.16.4 Security-Level.....	42
6 FR 2 – Nutzungskontrolle	42
6.1 Zweck und Beschreibungen der SL-C (UC).....	42
6.2 Begründung	43
6.3 CR 2.1 – Durchsetzung der Autorisierung.....	43
6.3.1 Anforderung.....	43
6.3.2 Begründungen und zusätzliche Leitfäden	43
6.3.3 Weitergehende Anforderungen	43
6.3.4 Security-Level.....	44
6.4 CR 2.2 – Nutzungskontrolle von Funkverbindungen.....	44
6.4.1 Anforderung.....	44
6.4.2 Begründungen und zusätzliche Leitfäden	44
6.4.3 Weitergehende Anforderungen	45
6.4.4 Security-Level.....	45
6.5 CR 2.3 – Nutzungskontrolle von tragbaren und mobilen Geräten	45
6.6 CR 2.4 – Mobiler Code	45
6.7 CR 2.5 – Sitzungssperrung	45
6.7.1 Anforderung.....	45
6.7.2 Begründungen und zusätzliche Leitfäden	45
6.7.3 Weitergehende Anforderungen	45
6.7.4 Security-Level.....	45
6.8 CR 2.6 – Beendigung einer Fernzugriffssitzung	46
6.8.1 Anforderung.....	46
6.8.2 Begründungen und zusätzliche Leitfäden	46
6.8.3 Weitergehende Anforderungen	46
6.8.4 Security-Level.....	46
6.9 CR 2.7 – Kontrolle gleichzeitiger Sitzungen	46
6.9.1 Anforderung.....	46
6.9.2 Begründungen und zusätzliche Leitfäden	46
6.9.3 Weitergehende Anforderungen	46
6.9.4 Security-Level.....	46
6.10 CR 2.8 – Prüfbare Ereignisse.....	47
6.10.1 Anforderung.....	47

	Seite
6.10.2 Begründung und zusätzliche Leitfäden.....	47
6.10.3 Weitergehende Anforderungen.....	47
6.10.4 Security-Level	47
6.11 CR 2.9 – Speicherkapazität für Ereignisdatensätze	48
6.11.1 Anforderung	48
6.11.2 Begründungen und zusätzliche Leitfäden.....	48
6.11.3 Weitergehende Anforderungen.....	48
6.11.4 Security-Level	48
6.12 CR 2.10 – Verhalten bei Verarbeitungsfehlern von Ereignisdaten	48
6.12.1 Anforderung	48
6.12.2 Begründung und zusätzliche Leitfäden.....	48
6.12.3 Weitergehende Anforderungen.....	49
6.12.4 Security-Level	49
6.13 CR 2.11 – Zeitstempel	49
6.13.1 Anforderung	49
6.13.2 Begründungen und zusätzliche Leitfäden.....	49
6.13.3 Weitergehende Anforderungen.....	49
6.13.4 Security-Level	49
6.14 CR 2.12 – Nichtabstreitbarkeit	50
6.14.1 Anforderung	50
6.14.2 Begründung und zusätzliche Leitfäden.....	50
6.14.3 Weitergehende Anforderungen.....	50
6.14.4 Security-Level	50
6.15 CR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen	50
7 FR 3 – Systemintegrität.....	50
7.1 Zweck und Beschreibungen der SL-C(SI)	50
7.2 Begründung.....	51
7.3 CR 3.1 – Kommunikationsintegrität	51
7.3.1 Anforderung	51
7.3.2 Begründungen und zusätzliche Leitfäden.....	51
7.3.3 Weitergehende Anforderungen.....	52
7.3.4 Security-Level	52
7.4 CR 3.2 – Schutz vor Schadcodes	52
7.5 CR 3.3 – Verifikation der IT-Sicherheitsfunktionalität	52
7.5.1 Anforderung	52
7.5.2 Begründungen und zusätzliche Leitfäden.....	52
7.5.3 Weitergehende Anforderungen.....	53
7.5.4 Security-Level	53
7.6 CR 3.4 – Software- und Informationsintegrität.....	53

	Seite
7.6.1 Anforderung.....	53
7.6.2 Begründungen und zusätzliche Leitfäden	53
7.6.3 Weitergehende Anforderungen	53
7.6.4 Security-Level.....	54
7.7 CR 3.5 – Eingabevalidierung.....	54
7.7.1 Anforderung.....	54
7.7.2 Begründungen und zusätzliche Leitfäden	54
7.7.3 Weitergehende Anforderungen	54
7.7.4 Security-Level.....	54
7.8 CR 3.6 – Vorbestimmte Zustände der Ausgänge	55
7.8.1 Anforderung.....	55
7.8.2 Begründungen und zusätzliche Leitfäden	55
7.8.3 Weitergehende Anforderungen	55
7.8.4 Security-Level.....	55
7.9 CR 3.7 – Fehlerbehandlung	55
7.9.1 Anforderung.....	55
7.9.2 Begründungen und zusätzliche Leitfäden	55
7.9.3 Weitergehende Anforderungen	56
7.9.4 Security-Level.....	56
7.10 CR 3.8 – Sitzungsintegrität.....	56
7.10.1 Anforderung.....	56
7.10.2 Begründungen und zusätzliche Leitfäden	56
7.10.3 Weitergehende Anforderungen	56
7.10.4 Security-Level.....	56
7.11 CR 3.9 – Schutz von Prüfinformationen	57
7.11.1 Anforderung.....	57
7.11.2 Begründungen und zusätzliche Leitfäden	57
7.11.3 Weitergehende Anforderungen	57
7.11.4 Security-Level.....	57
7.12 CR 3.10 – Unterstützung von Updates.....	57
7.13 CR 3.11 – Physikalische Manipulationssicherheit und -erkennung	57
7.14 CR 3.12 – Bereitstellung von Hersteller-Vertrauensankern	57
7.15 CR 3.13 – Bereitstellung von Betreiber-Vertrauensankern	58
7.16 CR 3.14 – Integrität von Boot-Prozessen.....	58
8 FR 4 – Vertraulichkeit der Daten	58
8.1 Zweck und Beschreibungen der SL-C(DC).....	58
8.2 Begründung	58
8.3 CR 4.1 – Vertraulichkeit von Informationen.....	58
8.3.1 Anforderung.....	58

	Seite
8.3.2 Begründungen und zusätzliche Leitfäden.....	58
8.3.3 Weitergehende Anforderungen.....	59
8.3.4 Security-Level	59
8.4 CR 4.2 – Dauerhaftigkeit von Informationen.....	59
8.4.1 Anforderung	59
8.4.2 Begründungen und zusätzliche Leitfäden.....	59
8.4.3 Weitergehende Anforderungen.....	59
8.4.4 Security-Level	60
8.5 CR 4.3 – Verwendung von Verschlüsselung	60
8.5.1 Anforderung	60
8.5.2 Begründungen und zusätzliche Leitfäden.....	60
8.5.3 Weitergehende Anforderungen.....	60
8.5.4 Security-Level	60
9 FR 5 – Eingeschränkter Datenfluss	61
9.1 Zweck und Beschreibungen der SL-C(RDF)	61
9.2 Begründung.....	61
9.3 CR 5.1 – Netzaufteilung	61
9.3.1 Anforderung	61
9.3.2 Begründungen und zusätzliche Leitfäden.....	61
9.3.3 Weitergehende Anforderungen.....	62
9.3.4 Security-Level	62
9.4 CR 5.2 – Schutz der Zonengrenze.....	62
9.5 CR 5.3 – Allgemeine Beschränkung der persönlichen Kommunikation	62
9.6 CR 5.4 – Partitionierung von Anwendungen.....	62
10 FR 6 – Rechtzeitige Reaktion auf Ereignisse	62
10.1 Zweck und Beschreibungen der SL-C(TRE).....	62
10.2 Begründung.....	63
10.3 CR 6.1 – Zugriffsmöglichkeit auf Ereignisprotokolle	63
10.3.1 Anforderung	63
10.3.2 Begründungen und zusätzliche Leitfäden.....	63
10.3.3 Weitergehende Anforderungen.....	63
10.3.4 Security-Level	63
10.4 CR 6.2 – Kontinuierliche Überwachung	64
10.4.1 Anforderung	64
10.4.2 Begründungen und zusätzliche Leitfäden.....	64
10.4.3 Weitergehende Anforderungen.....	64
10.4.4 Security-Level	64
11 FR 7 – Verfügbarkeit der Ressourcen	64
11.1 Zweck und Beschreibungen der SL-C(RA).....	64

	Seite
11.2 Begründung	65
11.3 CR 7.1 – Schutz vor Denial-of-Service-Ereignissen	65
11.3.1 Anforderung	65
11.3.2 Begründungen und zusätzliche Leitfäden	65
11.3.3 Weitergehende Anforderungen	65
11.3.4 Security-Level.....	65
11.4 CR 7.2 – Ressourcenmanagement	65
11.4.1 Anforderung	65
11.4.2 Begründungen und zusätzliche Leitfäden	65
11.4.3 Weitergehende Anforderungen	66
11.4.4 Security-Level.....	66
11.5 CR 7.3 – Datensicherung im Automatisierungssystem (Backup)	66
11.5.1 Anforderung	66
11.5.2 Begründung und zusätzliche Leitfäden	66
11.5.3 Weitergehende Anforderungen	66
11.5.4 Security-Level.....	66
11.6 CR 7.4 – Wiederherstellung des Automatisierungssystems	67
11.6.1 Anforderung	67
11.6.2 Begründungen und zusätzliche Leitfäden	67
11.6.3 Weitergehende Anforderungen	67
11.6.4 Security-Level.....	67
11.7 CR 7.5 – Notstromversorgung.....	67
11.8 CR 7.6 – Netzwerk- und IT-Sicherheitseinstellungen	67
11.8.1 Anforderung	67
11.8.2 Begründungen und zusätzliche Leitfäden	67
11.8.3 Weitergehende Anforderungen	67
11.8.4 Security-Level.....	68
11.9 CR 7.7 – Geringste Funktionalität	68
11.9.1 Anforderung	68
11.9.2 Begründungen und zusätzliche Leitfäden	68
11.9.3 Weitergehende Anforderungen	68
11.9.4 Security-Level.....	68
11.10 CR 7.8 – Verzeichnis der Komponenten eines Automatisierungssystems	68
11.10.1 Anforderung	68
11.10.2 Begründungen und zusätzliche Leitfäden	68
11.10.3 Weitergehende Anforderungen	68
11.10.4 Security-Level.....	69
12 Anforderungen an Softwareanwendungen.....	69
12.1 Zweck	69

	Seite
12.2 SAR 2.4 – Mobiler Code	69
12.2.1 Anforderung	69
12.2.2 Begründungen und zusätzliche Leitfäden.....	69
12.2.3 Weitergehende Anforderungen	69
12.2.4 Security-Level	69
12.3 SAR 3.2 – Schutz vor Schadcodes	70
12.3.1 Anforderung	70
12.3.2 Begründungen und zusätzliche Leitfäden.....	70
12.3.3 Weitergehende Anforderungen	70
12.3.4 Security-Level	70
13 Anforderungen an eingebettete Geräte	70
13.1 Zweck	70
13.2 EDR 2.4 – Mobiler Code	70
13.2.1 Anforderung	70
13.2.2 Begründungen und zusätzliche Leitfäden.....	71
13.2.3 Weitergehende Anforderungen	71
13.2.4 Security-Level	71
13.3 EDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen.....	71
13.3.1 Anforderung	71
13.3.2 Begründungen und zusätzliche Leitfäden.....	71
13.3.3 Weitergehende Anforderungen	72
13.3.4 Security-Level	72
13.4 EDR 3.2 – Schutz vor Schadcodes.....	72
13.4.1 Anforderung	72
13.4.2 Begründungen und zusätzliche Leitfäden.....	72
13.4.3 Weitergehende Anforderungen	72
13.4.4 Security-Level	72
13.5 EDR 3.10 – Unterstützung von Updates.....	73
13.5.1 Anforderung	73
13.5.2 Begründungen und zusätzliche Leitfäden.....	73
13.5.3 Weitergehende Anforderungen	73
13.5.4 Security-Level	73
13.6 EDR 3.11 – Physikalische Manipulationssicherheit und -erkennung.....	73
13.6.1 Anforderung	73
13.6.2 Begründungen und zusätzliche Leitfäden.....	73
13.6.3 Weitergehende Anforderungen	74
13.6.4 Security-Level	74
13.7 EDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern	74
13.7.1 Anforderung	74

	Seite
13.7.2 Begründung und zusätzliche Leitfäden	74
13.7.3 Weitergehende Anforderungen	74
13.7.4 Security-Level.....	74
13.8 EDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern.....	75
13.8.1 Anforderung.....	75
13.8.2 Begründungen und zusätzliche Leitfäden	75
13.8.3 Weitergehende Anforderungen	75
13.8.4 Security-Level.....	75
13.9 EDR 3.14 – Integrität von Boot-Prozessen	76
13.9.1 Anforderung.....	76
13.9.2 Begründungen und zusätzliche Leitfäden	76
13.9.3 Weitergehende Anforderungen	76
13.9.4 Security-Level.....	76
14 Anforderungen an Host-Geräte	76
14.1 Zweck	76
14.2 HDR 2.4 – Mobiler Code	76
14.2.1 Anforderung.....	76
14.2.2 Begründungen und zusätzliche Leitfäden	77
14.2.3 Weitergehende Anforderungen	77
14.2.4 Security-Level.....	77
14.3 HDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen.....	77
14.3.1 Anforderung.....	77
14.3.2 Begründungen und zusätzliche Leitfäden	77
14.3.3 Weitergehende Anforderungen	78
14.3.4 Security-Level.....	78
14.4 HDR 3.2 – Schutz vor Schadcodes.....	78
14.4.1 Anforderung.....	78
14.4.2 Begründungen und zusätzliche Leitfäden	78
14.4.3 Weitergehende Anforderungen	78
14.4.4 Security-Level.....	78
14.5 HDR 3.10 – Unterstützung von Updates	78
14.5.1 Anforderung.....	78
14.5.2 Begründungen und zusätzliche Leitfäden	79
14.5.3 Weitergehende Anforderungen	79
14.5.4 Security-Level.....	79
14.6 HDR 3.11 – Physikalische Manipulationssicherheit und -erkennung.....	79
14.6.1 Anforderung.....	79
14.6.2 Begründungen und zusätzliche Leitfäden	79
14.6.3 Weitergehende Anforderungen	79

	Seite
14.6.4 Security-Level	80
14.7 HDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern	80
14.7.1 Anforderung	80
14.7.2 Begründungen und zusätzliche Leitfäden.....	80
14.7.3 Weitergehende Anforderungen	80
14.7.4 Security-Level	80
14.8 HDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern	80
14.8.1 Anforderung	80
14.8.2 Begründungen und zusätzliche Leitfäden.....	81
14.8.3 Weitergehende Anforderungen	81
14.8.4 Security-Level	81
14.9 HDR 3.14 – Integrität von Boot-Prozessen.....	81
14.9.1 Anforderung	81
14.9.2 Begründungen und zusätzliche Leitfäden.....	82
14.9.3 Weitergehende Anforderungen	82
14.9.4 Security-Level	82
15 Anforderungen an Netzwerkkomponenten	82
15.1 Zweck	82
15.2 NDR 1.6 – Verwaltung drahtloser Zugriffsverfahren	82
15.2.1 Anforderung	82
15.2.2 Begründungen und zusätzliche Leitfäden.....	82
15.2.3 Weitergehende Anforderungen	82
15.2.4 Security-Level	83
15.3 NDR 1.13 – Zugriff über nicht vertrauenswürdige Netzwerke	83
15.3.1 Anforderung	83
15.3.2 Begründungen und zusätzliche Leitfäden.....	83
15.3.3 Weitergehende Anforderungen	83
15.3.4 Security-Level	83
15.4 NDR 2.4 – Mobiler Code	84
15.4.1 Anforderung	84
15.4.2 Begründungen und zusätzliche Leitfäden.....	84
15.4.3 Weitergehende Anforderungen	84
15.4.4 Security-Level	84
15.5 NDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen	84
15.5.1 Anforderung	84
15.5.2 Begründungen und zusätzliche Leitfäden.....	85
15.5.3 Weitergehende Anforderungen	85
15.5.4 Security-Level	85
15.6 NDR 3.2 – Schutz vor Schadcodes.....	85

	Seite
15.6.1 Anforderung.....	85
15.6.2 Begründungen und zusätzliche Leitfäden	85
15.6.3 Weitergehende Anforderungen	85
15.6.4 Security-Level.....	86
15.7 NDR 3.10 – Unterstützung von Updates	86
15.7.1 Anforderung.....	86
15.7.2 Begründungen und zusätzliche Leitfäden	86
15.7.3 Weitergehende Anforderungen	86
15.7.4 Security-Level.....	86
15.8 NDR 3.11 – Physikalische Manipulationssicherheit und -erkennung.....	86
15.8.1 Anforderung.....	86
15.8.2 Begründungen und zusätzliche Leitfäden	86
15.8.3 Weitergehende Anforderungen	87
15.8.4 Security-Level.....	87
15.9 NDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern.....	87
15.9.1 Anforderung.....	87
15.9.2 Begründungen und zusätzliche Leitfäden	87
15.9.3 Weitergehende Anforderungen	87
15.9.4 Security-Level.....	88
15.10 NDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern	88
15.10.1 Anforderung.....	88
15.10.2 Begründungen und zusätzliche Leitfäden	88
15.10.3 Weitergehende Anforderungen	88
15.10.4 Security-Level.....	88
15.11 NDR 3.14 – Integrität von Boot-Prozessen	89
15.11.1 Anforderung.....	89
15.11.2 Begründungen und zusätzliche Leitfäden	89
15.11.3 Weitergehende Anforderungen	89
15.11.4 Security-Level.....	89
15.12 NDR 5.2 – Schutz der Zonengrenze	89
15.12.1 Anforderung.....	89
15.12.2 Begründungen und zusätzliche Leitfäden	89
15.12.3 Weitergehende Anforderungen	90
15.12.4 Security-Level.....	90
15.13 NDR 5.3 – Allgemeine Beschränkung der persönlichen Kommunikation	90
15.13.1 Anforderung.....	90
15.13.2 Begründungen und zusätzliche Leitfäden	90
15.13.3 Weitergehende Anforderungen	91
15.13.4 Security-Level.....	91

	Seite
Anhang A (informativ) Gerätekategorien.....	92
A.1 Allgemeines.....	92
A.2 Gerätekategorie: Eingebettetes Gerät	92
A.2.1 Speicherprogrammierbare Steuerung (SPS, en: Programmable logic controller).....	92
A.2.2 Intelligentes elektronisches Gerät (IED, en: intelligent electronic device)	92
A.3 Gerätekategorie: Netzwerkkomponente	93
A.3.1 Switch.....	93
A.3.2 VPN-Terminator (en: Virtual private network (VPN) terminator).....	93
A.4 Gerätekategorie: Host-Gerät/Anwendung.....	93
A.4.1 Arbeitsplatzrechner des Bedieners	93
A.4.2 Datenhistorie	94
Anhang B (informativ) Abbildung von Komponentenanforderungen (CR) und weitergehenden Anforderungen (RE) auf die SL 1 bis 4 der grundlegenden Anforderungen (FR)	95
B.1 Übersicht	95
B.2 SL-Abbildungstabelle	95
Literaturhinweise	101
Bilder	
Bild 1 – Teile der Normenreihe IEC 62443.....	18
Tabellen	
Tabelle B.1 – Abbildung von Komponentenanforderungen (CR) und weitergehenden Anforderungen (RE) auf die SL 1 bis 4 der grundlegenden Anforderungen (FR) (1 von 6)	95

Einleitung

0.1 Übersicht

Die auf dem Gebiet der industriellen Automatisierungssysteme (IACS) tätigen Organisationen verwenden in zunehmendem Maße handelsübliche netzwerkfähige Geräte, die kostengünstig, effizient und in hohem Maße automatisiert sind. Ebenfalls werden Automatisierungssysteme zunehmend aus wirtschaftlichen Gründen mit Netzwerken, die nicht zur industriellen Automatisierungstechnik gehören, verbunden. Solche Geräte, offene Netzwerktechnologien und vermehrte Verbindungsfähigkeit bieten eine zunehmende Gelegenheit für IT-Angriffe gegen die Hardware und Software von Automatisierungssystemen. Diese Schwachstellen können bei installierten Automatisierungssystemen Folgen für die Gesundheit, Sicherheit und Umwelt, die wirtschaftliche Situation und/oder das Ansehen haben.

Organisationen, die für die IT-Sicherheit industrieller Automatisierungssysteme Lösungen aus der kommerziellen Informationstechnik (IT) einsetzen, verstehen möglicherweise die Auswirkungen dieser Entscheidung nicht in vollem Umfang. Obwohl viele kommerzielle IT-Anwendungen und IT-Sicherheitslösungen auf industrielle Automatisierungssysteme angewendet werden können, so sollte dies doch in geeigneter Weise erfolgen, um negative Folgen zu vermeiden. Aus diesem Grund muss bei der Festlegung der Systemanforderung auf eine Kombination aus funktionalen Anforderungen und Risikobeurteilung zurückgegriffen werden, häufig auch unter Beachtung betrieblicher Probleme.

Die IT-Sicherheitsmaßnahmen in einem industriellen Automatisierungssystem sollten nicht dazu führen, dass wesentliche Dienste und Funktionen oder gar Notfallprozeduren nicht ausgeführt werden können (IT-Sicherheitsmaßnahmen, wie sie häufig eingesetzt werden, haben dieses Potenzial). Bei den IT-Sicherheitszielen stehen die Verfügbarkeit eines Automatisierungssystems, der Schutz und der Betrieb (selbst bei einem eingeschränkten Betrieb) der Produktionsanlagen und das Antwortverhalten zeitkritischer Systeme im Vordergrund. Reine IT-Sicherheitsziele legen oft nicht dasselbe Gewicht auf diese Faktoren; sie haben eher den Schutz von Informationen als den von Betriebsmitteln im Auge. Diese andersartigen Zielsetzungen sollten klar als Schutzziele formuliert werden, unabhängig vom erreichten Integrationsgrad der Anlage. Ein wichtiger Schritt bei der Risikobeurteilung nach IEC 62443-2-1¹[1]² sollte die Identifizierung der für die Betriebsabläufe wirklich wesentlichen Dienste und Funktionen sein (bei einigen Anlagen kann beispielsweise festgestellt werden, dass die technische Unterstützung keine wesentliche Leistung oder Funktion darstellt). In manchen Fällen könnte es dagegen hinnehmbar sein, dass eine IT-Sicherheitsmaßnahme zu einem vorübergehenden Ausfall eines nicht wesentlichen Dienstes oder einer nicht wesentlichen Funktion führt, dagegen sollte ein wesentlicher Dienst oder eine wesentliche Funktion nicht beeinträchtigt werden.

Dieses Dokument gibt technische Anforderungen an die IT-Sicherheit von Komponenten an, aus denen ein industrielles Automatisierungssystem aufgebaut ist, insbesondere die eingebetteten Geräte, Netzwerkkomponenten, Host-Komponenten und Softwareanwendungen. [Anhang A](#) beschreibt die Kategorien der Geräte, die normalerweise für industrielle Automatisierungssysteme verwendet werden. Die Anforderungen nach diesem Dokument leiten sich aus den in IEC 62443-3-3 beschriebenen IT-Sicherheitsanforderungen an industrielle Automatisierungssysteme ab. In diesem Dokument sollen Sicherheitsfunktionen angegeben werden, mit denen eine Komponente Bedrohungen für eine bestimmte Sicherheitsstufe (SL) abfedern kann, ohne dass Gegenmaßnahmen ergriffen werden müssen. [Anhang B](#) enthält eine Tabelle, in der die Sicherheitsstufen aller in diesem Dokument definierten Anforderungen und Anforderungsverbesserungen zusammengefasst sind.

Hauptziele der Normenreihe IEC 62443 sind die Bereitstellung eines flexiblen Rahmenwerkes zur erleichterten Behandlung gegenwärtiger und zukünftiger Sicherheitslücken eines industriellen Automatisierungssystems und die Anwendung von Abschwächungen in einer systematischen und vertretbaren Weise. Es ist wichtig zu verstehen, dass es die Absicht der Normenreihe IEC 62443 ist, die IT-Sicherheit des Unternehmens mit Erweiterungen zu versehen, die die Anforderungen an die kommerziellen IT-Systeme aufnehmen und mit den besonderen Anforderungen einer starken Integrität und einer hohen Verfügbarkeit, wie sie von industriellen Automatisierungssystemen benötigt werden, zusammenführt.

¹ Viele Dokumente der Normenreihe IEC 62443 befinden sich zurzeit in Überarbeitung oder in Erarbeitung.

² Zahlen in eckigen Klammern beziehen sich auf die Literaturhinweise.

0.2 Zweck und Anwenderkreis

Dieses Dokument richtet sich an die auf dem Gebiet der industriellen Automatisierungstechnik tätigen Betreiber, Systemintegratoren, Hersteller und gegebenenfalls Genehmigungsstellen. Zu letzteren gehören auch Behörden und Regulierer, zu deren rechtlicher Befugnis die Durchführung von Audits gehört, um die Einhaltung von Gesetzen und Vorschriften zu überwachen.

Systemintegratoren werden mit diesem Dokument bei der Beschaffung von Komponenten des Automatisierungssystems, aus denen sich ihre Automatisierungslösung zusammensetzt, unterstützt. Die Unterstützung für Systemintegratoren besteht in der Festlegung des entsprechenden erreichbaren Security-Levels der einzelnen Komponenten, die sie benötigen. Die Grundnormen für Systemintegratoren sind IEC 62443-2-1 [1], IEC 62443-2-4 [3], IEC 62443-3-2 [5]³ und IEC 62443-3-3, die Organisations- und Betriebsanforderungen für ein IT-Sicherheitsprogramm angeben und einen Leitfaden für den Definitionsprozess von IT-Sicherheitszonen für ein System und die zu erreichenden Security-Level (SL-T) für diese Zonen bereitstellen. Sobald der SL-T für jede Zone festgelegt wurde, können die Komponenten, die die nötigen Sicherheitsfunktionen bereitstellen, verwendet werden, um den SL-T für jede Zone zu erreichen.

Hersteller nutzen dieses Dokument, damit sie die an die Komponenten des Automatisierungssystems gestellten Anforderungen für bestimmte Security-Level (SL-C) dieser Komponenten nachvollziehen können. Unter Umständen besitzt eine Komponente die benötigte Fähigkeit nicht selbst, sie kann aber so ausgeführt sein, dass sie in eine Einheit einer höheren Ebene integriert wird und damit von den Fähigkeiten dieser Einheit profitiert – z. B. führt ein eingebettetes Gerät ein Benutzerverzeichnis vielleicht nicht selbst, es kann aber in einen systemweiten Authentifikations- und Autorisierungsdienst integriert werden und erfüllt damit noch die Anforderungen der Fähigkeiten einer individuellen Benutzerauthentifikation, -autorisierung und -verwaltung. Dieses Dokument gibt dem Hersteller einen Leitfaden dafür, welche Anforderungen zugewiesen werden können und welche Anforderungen die Komponenten selbst erfüllen sollten. Wie in Ansatz 8 von IEC 62443-4-1 festgelegt, wird der Hersteller eine Dokumentation bereitstellen, die erklärt, wie die Komponente richtig in ein System integriert wird, damit ein bestimmter SL-T erfüllt wird.

Die in diesem Dokument angegebenen Komponentenanforderungen (CR) werden von den Systemanforderungen (SR) in IEC 62443-3-3 abgeleitet. Die Anforderungen in IEC 62443-3-3 werden als Systemanforderungen (SR) bezeichnet, die aus den in IEC 62443-1-1 festgelegten gesamten grundlegenden Anforderungen (FR) abgeleitet werden. CR dürfen auch eine Menge weitergehender Anforderungen (RE) umfassen. Durch die Kombination von Komponentenanforderungen (CR) und weitergehenden Anforderungen (RE) wird der zu erreichende Security-Level bestimmt, den eine Komponente realisieren kann.

Dieses Dokument enthält Komponentenanforderungen für vier Arten von Komponenten: Softwareanwendung, eingebettetes Gerät, Host-Gerät und Netzwerkkomponente. Damit werden die CR für jede Komponentenart wie folgt bezeichnet:

- Anforderungen an Softwareanwendungen (SAR);
- Anforderungen an eingebettete Geräte (EDR);
- Anforderungen an Host-Geräte (HDR); und
- Anforderungen an Netzwerkkomponenten (NDR).

Die Mehrheit der Anforderungen in diesem Dokument gilt für die vier Komponentenarten gleichermaßen und diese werden deshalb einfach als CR bezeichnet. Bei besonderen komponentenspezifischen Anforderungen gibt dann die generische Anforderung an, dass die Anforderungen komponentenspezifisch sind und in den Abschnitten für die komponentenspezifischen Anforderungen dieses Dokuments beschrieben werden.

Bild 1 stellt grafisch die Zusammensetzung der Normenreihe IEC 62443 zum Zeitpunkt der Ausarbeitung des vorliegenden Dokuments dar.

³ In Vorbereitung. Stand zum Zeitpunkt der Veröffentlichung: IEC PRVC 62443-3-2:2018.

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12
EN IEC 62443-4-2:2019

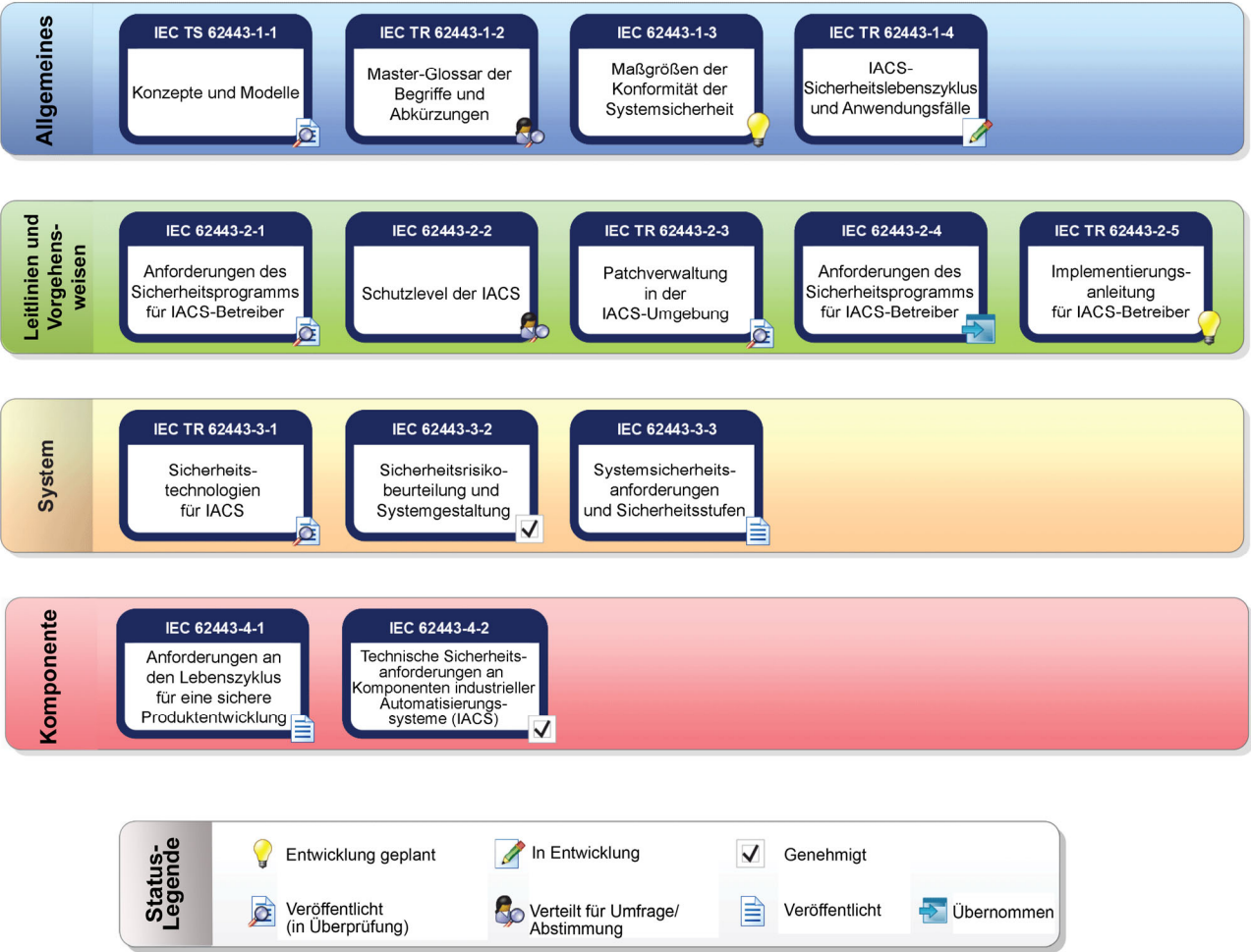


Bild 1 – Teile der Normenreihe IEC 62443

1 Anwendungsbereich

Dieser Teil der IEC 62443 legt anhand der sieben grundlegenden Anforderungen (FR) nach IEC TS 62443-1-1 detaillierte technische Anforderungen an Komponenten von Automatisierungssystemen (CR) fest, einschließlich der Anforderungen an die erreichbaren Security-Level und deren Komponenten, SL-C(Komponente).

Entsprechend der Definition in IEC TS 62443-1-1 gibt es insgesamt sieben grundlegende Anforderungen (FR):

- a) Identifizierung und Authentifikation (IAC),
- b) Nutzungskontrolle (UC),
- c) Systemintegrität (SI),
- d) Vertraulichkeit der Daten (DC),
- e) eingeschränkter Datenfluss (RDF),
- f) rechtzeitige Reaktion auf Ereignisse (TRE), und
- g) Verfügbarkeit der Ressourcen (RA).

Diese sieben FR sind die Grundlage zur Festlegung der erreichbaren Security-Level des Automatisierungssystems. Die Festlegung der erreichbaren Security-Level für die Komponente des Automatisierungssystems ist das Ziel dieses Dokuments und nicht die Festlegung der SL-T oder der erreichten SL (SL-A), die nicht zum Anwendungsbereich dieses Dokuments gehören.

ANMERKUNG 1 Siehe IEC 62443-2-1 [1] für einen Satz von gleichwertigen nichttechnischen, programmbezogenen erreichbaren Anforderungen, die für das vollständige Erreichen eines SL-T(Automatisierungssystem) erforderlich sind.

ANMERKUNG 2 Die in diesem Dokument angegebenen Markennamen und Warenzeichen dienen nur zur Unterrichtung der Anwender dieses Dokuments. Diese Angaben bedeuten keine Anerkennung der genannten Produkte durch IEC.

2 Normative Verweisungen

Die folgenden Dokumente werden im Text in solcher Weise in Bezug genommen, dass einige Teile davon oder ihr gesamter Inhalt Anforderungen des vorliegenden Dokuments darstellen. Bei datierten Verweisungen gilt nur die in Bezug genommene Ausgabe. Bei undatierten Verweisungen gilt die letzte Ausgabe des in Bezug genommenen Dokuments (einschließlich aller Änderungen).

IEC TS 62443-1-1, *Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models*

IEC 62443-3-3:2013, *Industrial communication networks – Network and system security – Part 3-3: System security requirements and security levels*

IEC 62443-4-1, *Security for industrial automation and control systems – Part 4-1: Secure product development lifecycle requirements*

3 Begriffe, Abkürzungen, Akronyme und Vereinbarungen

3.1 Begriffe

Für die Anwendung dieses Dokuments gelten die Begriffe nach IEC TS 62443-1-1, IEC 62443-3-3 und IEC 62443-4-1 und die folgenden Begriffe.

ISO und IEC stellen terminologische Datenbanken für die Verwendung in der Normung unter den folgenden Adressen bereit:

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12

EN IEC 62443-4-2:2019

- IEC Electropedia: verfügbar unter <http://www.electropedia.org/>
- ISO Online Browsing Platform: verfügbar unter <http://www.iso.org/obp>

ANMERKUNG Viele der nachfolgenden Begriffe entstammen Quellen der International Organization for Standardization (ISO), der International Electrotechnical Commission (IEC) oder des U.S. National Institute of Standards and Technology (NIST), manchmal sind sie geringfügig geändert worden, damit sie bei der Festlegung der Sicherheitsanforderungen an industrielle Automatisierungssysteme besser passen.

3.1.1

Schutzobjekt Betriebsmittel

(en: asset)

ein physisches oder logisches Objekt, das einen wahrgenommenen oder tatsächlichen Wert für ein IACS hat

Anmerkung 1 zum Begriff: In diesem spezifischen Fall ist ein Schutzobjekt jede Betrachtungseinheit, die im Rahmen des IT-Sicherheitsmanagementsystems des Automatisierungssystems geschützt werden sollte.

Anmerkung 2 zum Begriff: Ein Schutzobjekt ist nicht auf das industrielle Automatisierungssystem allein beschränkt, sondern es kann auch die zu überwachenden physikalischen Schutzobjekte einschließen.

3.1.2

Betreiber

(en: asset owner)

für ein oder mehrere industrielle Automatisierungssysteme verantwortliche Person oder verantwortliches Unternehmen

Anmerkung 1 zum Begriff: Die Benennung „Betreiber“ wird aus Unterscheidungsgründen anstelle der generischen Benennung „Nutzer“ verwendet.

Anmerkung 2 zum Begriff: Dieser Begriff umfasst auch alle Komponenten, die Teil des industriellen Automatisierungssystems sind.

Anmerkung 3 zum Begriff: Im Zusammenhang mit diesem Dokument gehört zu einem Betreiber auch der Bediener eines industriellen Automatisierungssystems.

3.1.3

Angriff

(en: attack)

nicht autorisierter Versuch, die Vertraulichkeit, Integrität oder Verfügbarkeit eines IACS zu gefährden, der von einer intelligenten Bedrohung herrührt

BEISPIEL Eine intelligente Tat, die ein vorsätzlicher Versuch (besonders im Sinne einer Methode oder einer Technik) ist, Dienste der IT-Sicherheit zu umgehen und die IT-Sicherheitsleitlinien eines Systems zu verletzen.

Anmerkung 1 zum Begriff: Es gibt verschiedene allgemein anerkannte Angriffsklassen:

- Ein „aktiver Angriff“ versucht, die Systemressourcen zu verändern oder ihren Betrieb zu beeinträchtigen.
- Ein „passiver Angriff“ versucht, zu lernen oder Informationen aus dem System zu nutzen, er beeinträchtigt aber keine Systemressourcen.
- Ein „Angriff von innen“ ist ein von einer innerhalb der IT-Sicherheitszone liegenden Einheit veranlasster Angriff (von einem Innentäter), z. B. von einer Einheit, die autorisiert ist, auf Systemressourcen zuzugreifen, die diese jedoch in einer Art und Weise nutzt, wie es von denjenigen, die die Autorisierung erteilt haben, nicht vorgesehen ist.
- Ein „Angriff von außen“ ist ein von außerhalb der IT-Sicherheitszone durch einen nicht autorisierten oder illegalen Systemnutzer veranlasster Angriff (einschließlich eines Innentäters, der von außerhalb der IT-Sicherheitszone aus angreift). Mögliche außenstehende Angreifer reichen von amateurhaften Witzbolden bis zu organisierten Kriminellen, internationalen Terroristen und feindlich gesinnten Regierungen.

3.1.4

Authentifikation

(en: authentication)

Überprüfung der behaupteten Identität einer Einheit

Anmerkung 1 zum Begriff: Authentifikation ist üblicherweise eine Voraussetzung für die Gewährung des Zugriffs auf Ressourcen eines Automatisierungssystems.

3.1.5

Authentifizierer

(en: authenticator)

Mittel zur Bestätigung der Identität einer Einheit

BEISPIEL Ein Passwort oder ein Token kann als Authentifizierer eingesetzt werden.

3.1.6

Authentizität

(en: authenticity)

Eigenschaft, dass eine Einheit das ist, was sie behauptet zu sein, durch Authentifizierung des Ursprungs und Verifizierung der Integrität

Anmerkung 1 zum Begriff: Authentizität wird typischerweise im Zusammenhang mit Vertrauen in die Identität einer Einheit oder in die Gültigkeit einer Übertragung, einer Nachricht oder in den Absender der Nachricht verwendet.

3.1.7

Verfügbarkeit

(en: availability)

Fähigkeit, einen rechtzeitigen und zuverlässigen Zugriff auf die Informationen und die Funktionalität eines Automatisierungssystems sicherzustellen und diese zu nutzen

3.1.8

Kommunikationskanal

(en: communication channel)

eine spezifische logische oder physische Kommunikationsverbindung zwischen Anlagen

Anmerkung 1 zum Begriff: Ein Kanal ermöglicht die Herstellung einer Verbindung.

3.1.9

Ausgleichsmaßnahme

(en: compensating countermeasure)

Maßnahme, die anstelle von oder zusätzlich zu inhärenten Fähigkeiten im Hinblick auf die IT-Sicherheit eingesetzt wird, um einer oder mehreren IT-Sicherheitsanforderungen zu genügen

BEISPIEL

- Komponentenebene: abgeschlossenes Gehäuse einer Steuereinheit, das ansonsten über seine physischen Datenschnittstellen unbefugtem Zugriff ausgesetzt sein könnte;
- Ebene des Automatisierungssystems/der Zonen: physikalische Zugriffskontrolle (Wachpersonal, Tore und Schusswaffen) zum Schutz einer Schaltwarte, um den Zugriff auf eine Gruppe bekannter Mitarbeiter zu beschränken und der technischen Anforderung zu entsprechen, das Personal durch das industrielle Automatisierungssystem eindeutig zu identifizieren; und
- Komponentenebene: eine speicherprogrammierbare Steuerung (SPS) eines Herstellers kann die vom Betreiber geforderten Fähigkeiten der Zugriffskontrolle nicht erfüllen, so dass der Hersteller eine Firewall vor die SPS stellt und dies als ein System verkauft.

3.1.10

Komponente

zu einem IACS gehörende Einheit, die die Merkmale eines (einer) oder mehrerer Host-Geräte, Netzwerkgeräte, Softwareanwendungen oder eingebetteter Geräte aufweist

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12
EN IEC 62443-4-2:2019**3.1.11****Conduit**

(en: conduit)

logische Gruppierung von Kommunikationskanälen, die zwei oder mehr Zonen verbindet, für die gemeinsame IT-Sicherheitsanforderungen gelten

Anmerkung 1 zum Begriff: Ein Conduit darf eine Zone durchqueren, solange die IT-Sicherheit der im Conduit verlaufenden Kanäle durch die Zone nicht beeinträchtigt wird.

3.1.12**Vertraulichkeit**

(en: confidentiality)

Sicherstellung, dass Informationen nicht an unbefugte Personen, Prozesse oder Geräte weitergegeben werden

Anmerkung 1 zum Begriff: Wird diese Benennung im Zusammenhang mit einem industriellen Automatisierungssystem verwendet, so bezieht sie sich vertraulich auf den Schutz der vorhandenen Daten und Informationen vor nicht autorisiertem Zugriff.

3.1.13**Verbindung**

(en: connection)

zwischen zwei oder mehr Endpunkten hergestellter Zusammenschluss, der den Aufbau einer Sitzung unterstützt

3.1.14**Automatisierungssystem**

(en: control system)

Hardware- und Softwarekomponenten eines industriellen Automatisierungssystems

3.1.15**Maßnahme**

(en: countermeasure)

Tätigkeit, Gerät, Prozedur oder Verfahren, durch die eine Bedrohung, eine Sicherheitslücke oder die Folgen eines Angriffs verringert werden, und zwar durch die Verringerung des möglichen Schadens oder durch Entdeckung und Bericht, so dass Korrekturmaßnahmen eingeleitet werden können

Anmerkung 1 zum Begriff: Im Englischen wird in einigen Zusammenhängen auch die Benennung „control“ benutzt, um diesen Begriff zu beschreiben. Die Benennung „countermeasure“ wurde im englischen Dokument verwendet, um eine Verwechslung mit der Benennung „control“ im Zusammenhang mit „process control“ und „control system“ zu vermeiden.

3.1.16**eingeschränkter Betrieb**

(en: degraded mode)

durch das Vorhandensein von Fehlzuständen, die beim Entwurf des Automatisierungssystems bereits berücksichtigt wurden, gekennzeichnete Betriebszustand

Anmerkung 1 zum Begriff: Bei einem eingeschränkten Betrieb kann das Automatisierungssystem trotz des Versagens eines oder mehrerer Systemelemente weiterhin wesentliche Funktionen erbringen, wie z. B. bei Fehlfunktion oder Ausfall von Betriebsmitteln, bei einer durch einen Ausfall verursachten Kommunikationsunterbrechung oder bei absichtlicher Abtrennung des Systems, weil erkannt oder vermutet wird, dass Teilsysteme kompromittiert worden sind.

3.1.17**Gerät**

(en: device)

diskretes physisches Asset, das eine Reihe von Funktionen bietet

BEISPIEL Steuerungen, Mensch-Maschine-Schnittstellen (HMI), SPS, abgesetzte Bediengeräte, Messumformer, Stellglieder, Ventile, Netzwerkschalter.

Anmerkung 1 zum Begriff: Ein Gerät kann die Merkmale eines (einer) oder mehrerer Host-Geräte, Netzwerkgeräte, Softwareanwendungen oder eingebetteter Geräte aufweisen.

3.1.18**eingebettetes Gerät**

(en: embedded device)

Sondergerät, das für eine direkte Überwachung oder Steuerung eines technischen Prozesses vorgesehen ist

BEISPIEL SPS, drahtgebundene oder drahtlose Sensorgeräte, drahtgebundene oder drahtlose Betätigungsgeräte, Steuerungen für sicherheitstechnische Systeme (SIS), Steuerungen für verteilte Steuerungssysteme (DCS).

Anmerkung 1 zum Begriff: Typische Merkmale eingebetteter Geräte sind begrenzter Speicherplatz, begrenzte Anzahl freigegebener Dienste, Programmierung über eine externe Schnittstelle, eingebettete Betriebssysteme oder Firmware, Echtzeit-Steuerungsprogramm, und sie können ein zugeordnetes Bedienfeld und eine Kommunikationsschnittstelle besitzen.

3.1.19**Umgebung**

(en: environment)

umgebende Objekte, Gebiete oder Umstände, die das Verhalten des industriellen Automatisierungssystems beeinflussen dürfen und/oder durch dieses beeinflusst werden dürfen

3.1.20**wesentliche Funktion**

(en: essential function)

zur Erhaltung der Gesundheit, der Sicherheit, der Umwelt sowie der Verfügbarkeit der zu überwachenden Einrichtung erforderliche Funktion oder Fähigkeit

Anmerkung 1 zum Begriff: Zu den wesentlichen Funktionen gehören unter anderem die sicherheitstechnische Funktion (SIF), die Steuer- und Regelfunktion sowie die Fähigkeit des Bedieners, die zu überwachende Einrichtung zu überwachen und zu bedienen. Der Verlust wesentlicher Funktionen wird häufig auch als Verlust der Schutzfunktion, der Steuerfunktion bzw. der Überwachungsfunktion bezeichnet. In einigen Industriebereichen werden noch weitere Funktionen wie z. B. die Dokumentation des Produktionsgeschehens als wesentlich eingestuft.

3.1.21**Ereignis**

(en: event)

Auftreten von oder Änderung zu einer besonderen Menge von Umständen

Anmerkung 1 zum Begriff: In einem industriellen Automatisierungssystem kann dies eine von einer Person (autorisiert oder nicht autorisiert) vorgenommene Handlung, eine in dem Automatisierungssystem festgestellte Veränderung (normal oder anormal) oder eine automatische Reaktion des Automatisierungssystems selbst (normal oder anormal) sein.

3.1.22**Firecall**

Verfahren der Bereitstellung eines Notzugriffs auf ein gesichertes Automatisierungssystem

Anmerkung 1 zum Begriff: In einer Notsituation können nicht berechtigte Nutzer zur Problembeseitigung Zugriff auf Schlüsselsysteme erlangen. Mit einem Firecall ist üblicherweise eine Überprüfung verbunden, durch die sichergestellt wird, dass der Zugriff zur Beseitigung eines Problems korrekt genutzt wurde. Bei diesem Verfahren wird im Allgemeinen eine einmalige Benutzerkennung (ID) oder ein Einmalpasswort erteilt.

3.1.23**Host-Gerät**

(en: host device)

Sondergerät, auf dem ein Betriebssystem läuft (z. B. Microsoft Windows oder Linux) und das eine oder mehrere Softwareanwendungen, Datenspeicher oder Funktionen eines oder mehrerer Hersteller(s) hosten kann

Anmerkung 1 zum Begriff: Typische Eigenschaften schließen Dateisysteme, programmierbare Dienste, Ohne-Echtzeit-Steuerungsprogramm und vollständiger Mensch-Maschine-Schnittstelle (Tastatur, Maus usw.) ein.

3.1.24**Kennung**

(en: identifier)

in einem IT-Sicherheitsbereich eindeutiges Symbol, das eine Einheit, die eine Identität vorgibt oder geltend macht, identifiziert, anzeigt oder benennt

3.1.25**Vorfall**

(en: incident)

Ereignis, das nicht Teil des erwarteten Betriebsverhaltens eines Systems oder Dienstes ist und das zu einer Unterbrechung des vom Automatisierungssystem erbrachten Dienstes oder zu einer Verminderung von dessen Qualität führt oder führen kann

3.1.26**industrielles Automatisierungssystem**

(en: industrial automation and control system)

Zusammenstellung von Personal, Hardware, Software und Leitlinien, die in den Betrieb des industriellen Prozesses eingebunden sind und dessen sicheren und zuverlässigen Betrieb beeinträchtigen oder beeinflussen können

3.1.27**Integrität**

(en: integrity)

Eigenschaft, des Schutzes der Genauigkeit und Vollständigkeit der Schutzobjekte

3.1.28**minimal erforderliche Rechte**

(en: least privilege)

Grundprinzip, demgemäß Nutzern (menschliche Nutzer, Softwareprozesse oder Geräte) die entsprechend ihrer Aufgaben und Funktionen minimal erforderlichen Rechte zugewiesen werden sollten

Anmerkung 1 zum Begriff: Die minimal erforderlichen Rechte werden in einem industriellen Automatisierungssystem üblicherweise mittels einer Menge von Rollen realisiert.

3.1.29**mobiler Code**

(en: mobile code)

Programm, das zwischen Schutzobjekten übertragen wird und ohne explizite Installation durch den Empfänger ausgeführt werden kann

BEISPIEL JavaScript, VBScript, Java Applets, ActiveX-Controls, Flash-Animationen, Shockwave-Movies und Microsoft-Office-Makros.

3.1.30**mobiles Gerät**

(en: mobile device)

intelligentes elektronisches Gerät für eine nicht ortsgebundene Nutzung

BEISPIEL Laptops, mobile Roboter, Smartphones, tragbare Programmier Einrichtungen, Tablets und persönliche digitale Assistenten.

3.1.31**Netzwerkkomponente**

(en: network device)

Komponente, die den Datenfluss zwischen Geräten ermöglicht oder einschränkt, aber dabei möglicherweise nicht direkt mit einem Steuervorgang in Wechselwirkung tritt

Anmerkung 1 zum Begriff: Typische Merkmale sind eingebettete Betriebssysteme oder Firmware, ohne HMI und Echtzeit-Steuerungsprogramm, die über eine externe Schnittstelle konfiguriert werden.

3.1.32**Nicht-Abstreitbarkeit**

(en: non-repudiation)

Fähigkeit, das Auftreten eines behaupteten Ereignisses oder einer Handlung und die verursachende Person oder Stelle nachzuweisen

Anmerkung 1 zum Begriff: Ziel der Nicht-Abstreitbarkeit ist es, Streitigkeiten über das Auftreten oder Nichtauftreten des Ereignisses oder der Handlung und die Beteiligung von betroffenen Personen oder Stellen an diesem Ereignis zu entscheiden.

3.1.33**Hersteller**

(en: product supplier)

Hersteller eines Hardware- und/oder Softwareprodukts

Anmerkung 1 zum Begriff: Diese Benennung wird anstelle des allgemeinen Worts „Verkäufer“ verwendet, um eine Unterscheidung zu bieten.

3.1.34**Fernzugriff**

(en: remote access)

Zugriff auf eine Komponente durch alle Nutzer (menschliche Nutzer, Softwareprozesse oder Geräte), die von außerhalb der adressierten IT-Sicherheitszone kommunizieren

3.1.35**Rolle**

(en: role)

Zusammenstellung von zusammenhängenden Verhaltensweisen, Berechtigungen und Verpflichtungen, die einem Nutzer oder einer Gruppe von Nutzern (menschliche Nutzer, Softwareprozesse oder Geräte) eines industriellen Automatisierungssystems zugewiesen werden können

Anmerkung 1 zum Begriff: Die Berechtigungen, bestimmte Handlungen vorzunehmen, sind bestimmten Rollen zugeordnet.

3.1.36**PLT-Sicherheitseinrichtung**

(en: safety instrumented system)

System zur Ausführung einer oder mehrerer sicherheitsbezogener Funktionen

3.1.37**Security-Level**

(en: security level)

Level, das den erforderlichen Maßnahmen und den inhärenten Sicherheitseigenschaften von Geräten und Systemen für eine Zone oder ein Conduit entspricht, basierend auf der Bewertung des Risikos für die Zone oder das Conduit

3.1.38**Sitzung**

(en: session)

semipermanenter, zustandsbehafteter und interaktiver Informationsaustausch zwischen zwei oder mehr miteinander kommunizierenden Komponenten

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12 **EN IEC 62443-4-2:2019**

Anmerkung 1 zum Begriff: Üblicherweise verfügt eine Sitzung über klar definierte Start- und Endprozesse.

3.1.39

Sitzungs-ID

(en: session ID)

Kennung, die zur Bezeichnung einer bestimmten Sitzung verwendet wird

3.1.40

Sollwert

(en: set point)

in einer Regelung benannter Zielwert, der eine oder mehrere Handlungen im Automatisierungssystem lenkt

3.1.41

Softwareanwendung

(en: software application)

ein oder mehrere Programm(e) und ihre Abhängigkeiten, mit denen eine Verbindung mit dem Prozess oder dem Automatisierungssystem selbst hergestellt wird (z. B. Konfigurationssoftware und Historie)

Anmerkung 1 zum Begriff: Softwareanwendungen werden gewöhnlich auf Host-Geräten oder eingebetteten Geräten ausgeführt.

Anmerkung 2 zum Begriff: Abhängigkeiten sind alle Programme, die für die Funktion der Softwareanwendung notwendig sind, wie z. B. Paketdatenbanken, Berichtswerkzeuge, Software von Dritten oder Open-Source-Software.

3.1.42

Systemintegrator

(en: system integrator)

Dienstleister, der sich darauf spezialisiert hat, Teilsysteme von Komponenten zu einem ganzen System zusammenzufügen, und dafür sorgt, dass diese Teilsysteme sich entsprechend den Projektspezifikationen verhalten

Anmerkung 1 zum Begriff: Dazu können auch andere Herstellerbezeichnungen gehören wie z. B. Hauptauftragnehmer für die Automatisierung (en: general automation contractor, main automation contractor), Geräteanbieter (en: main instrument vendor) und dergleichen.

3.1.43

Bedrohung

(en: threat)

verschiedene Umstände und damit verbundene Abfolge von Ereignissen, die geeignet sind, den Betrieb (einschließlich Aufgabe, Funktionen, Ansehen oder Ruf), Anlagen, Steuerungssysteme oder Personen durch unbefugten Zugang, Vernichtung, Offenlegung, Datenänderung und/oder Denial-of-Service zu beeinträchtigen

3.1.44

Vertrauen

(en: trust)

Zutrauen, dass eine Operation, die Quelle eines Datenverarbeitungsvorgangs, ein Netzwerk oder ein Softwareprozess sich wie erwartet verhält

Anmerkung 1 zum Begriff: Im Allgemeinen kann eine Einheit einer zweiten Einheit „vertrauen“, wenn sie (die erste Einheit) die Annahme trifft, dass sich die zweite Einheit so verhält, wie es die erste Einheit erwartet.

Anmerkung 2 zum Begriff: Dieses Vertrauen kann auf einige besondere Funktionen beschränkt sein.

3.1.45

Unauffindbarkeit

(en: untraceability)

Zusicherung, dass aus der Information nicht auf die Zeit oder den Ort eines spezifischen Nutzers geschlossen werden kann

3.1.46

nicht vertrauenswürdig

(en: untrusted)

Nichterfüllung vorher festgelegter Anforderungen an die Vertrauenswürdigkeit

Anmerkung 1 zum Begriff: Eine Einheit kann einfach als nicht vertrauenswürdig erklärt werden.

3.1.47

Update

schrittweiser Übergang zu neuerer Hardware oder Software, um IT-Sicherheitslücken, Programmfehler, Zuverlässigkeits- oder Funktionsprobleme zu beseitigen

3.1.48

Upgrade

schrittweiser Übergang zu neuerer Hardware oder Software, um neue Merkmale hinzuzufügen

3.1.49

Zone

(en: zone)

Zusammenfassung von Einheiten, die eine Aufteilung eines betrachteten Systems auf der Grundlage ihrer funktionalen, logischen oder physikalischen (einschließlich des Ortes) Beziehungen wiedergeben

Anmerkung 1 zum Begriff: Eine Zone ist klar begrenzt. Die IT-Sicherheitsleitlinien einer Zone werden üblicherweise durch eine Kombination von Mechanismen sowohl am Zonenrand als auch innerhalb der Zone durchgesetzt.

3.2 Abkürzungen und Akronyme

ACL	Zugriffskontrollliste (en: access control list)
AES	erweiterter Verschlüsselungsstandard (en: advance encryption standard)
ANSI	amerikanische Standardisierungsorganisation (en: american national standards institute)
API	Schnittstelle für ein Anwendungsprogramm (en: application program interface)
ASLR	Verwürfelung des Adressraums (en: address space layout randomization)
CA	Zertifizierungsstelle (en: certification authority)
CCSC	Sicherheitsbeschränkung für gemeinsame Komponenten (en: common component security constraint)
CMAC	codebasierter Nachrichtenauthentifikationscode (en: cipher-based Message Authentication Code)
COTS	handelsüblich (en: commercial off the shelf)
CR	Komponentenanforderung (en: component requirement)
CRL	Zertifikatsperrliste (en: certificate revocation list)
DC	Datenvertraulichkeit (en: data confidentiality)
DCS	verteiltes Steuerungssystem (en: distributed control system)
DEP	Datenausführungsverhinderung (en: data execution prevention)
DMZ	demilitarisierte Zone (en: demilitarized zone)
DNS	Domännennamendienst (en: domain name service)
DoS	Ablehnung, einer Stelle, einen Dienst zu erbringen (en: denial of service)
EDR	Anforderung an eingebettete Geräte (en: embedded device requirement)
EICAR	gemeinnütziger Verein mit dem Ziel Computerviren zu erforschen (en: european institute for computer antivirus research)
EMI	elektromagnetische Störung (en: electromagnetic interference)
FDA	Lebensmittelüberwachungs- und Arzneimittelbehörde der Vereinigten Staaten von Amerika (en: food and drug administration)

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12
EN IEC 62443-4-2:2019

FIPS	Bundesstandard für Informationsverarbeitung der Vereinigten Staaten von Amerika (en: federal information processing standard)
FR	grundlegende Anforderung (en: foundational requirement)
FTP	Dateiübertragungsprotokoll (en: file transfer protocol)
GCM	Betriebsmodus für eine symmetrische Verschlüsselungsanwendung (en: Galois/Counter mode)
GMAC	Galois-Nachrichtenauthentifikationscode (en: Galois message authentication code)
GUID	globaler eindeutiger Bezeichner (en: globally unique identifiers)
HDR	Anforderung an Host-Geräte (en: host device requirement)
HMI	Mensch-Maschine-Schnittstelle (en: human machine interface)
HSE	Gesundheit, Sicherheit und Umwelt (en: health, safety and environmental)
HTTP	Protokoll zur Übertragung von HTML-Seiten im Internet (en: hypertext transfer protocol)
HTTPS	Protokoll zur sicheren Übertragung von HTML-Seiten im Internet (en: HTTP secure)
IAC	Identifizierung und Authentifizierung (en: identification and authentication control)
IACS	industrielles Automatisierungssystem (en: industrial automation and control system(s))
ID	Bezeichner (en: identifier)
IDS	System zur Erkennung von Angriffen auf ein Computersystem oder Rechnernetz (en: intrusion detection system)
IED	intelligentes elektronisches Gerät (en: intelligent electronic device)
IEC	Internationale elektrotechnische Kommission (en: international electrotechnical commission)
IEEE	Weltweiter Ingenieurverband (en: Institute of Electrical and Electronics Engineers)
IP	Internetprotokoll (en: Internet protocol)
IPS	ein IDS, das Gegenmaßnahmen einleiten kann (en: intrusion prevention system)
ISA	gemeinnützige Fachgesellschaft für Automatisierung (en: international society of automation)
ISO	internationale Standardisierungsorganisation (en: international organization for standardization)
IT	Informationstechnik (en: information technology)
JTAG	Synonym für den IEEE-Standard 1149.1, der eine Methodik für das Testen und Debuggen integrierter Schaltungen beschreibt (en: Joint Test Action Group)
LDAP	leichtgewichtiges Verzeichniszugriffsprotokoll (en: lightweight directory access protocol)
NDR	Anforderung an Netzwerkkomponenten (en: network device requirement)
NIST	Bundesbehörde der Vereinigten Staaten von Amerika für Standards und Technologie (en: National Institute of Standards and Technology)
NX	keine Ausführung (en: No Execute)
OCSP	Netzwerkprotokoll zur Statusabfrage von Zertifikaten (en: online certificate status protocol)
OS	Betriebssystem (en: operating system)
OWASP	Non-Profit-Organisation mit dem Ziel, die Sicherheit von Anwendungen und Diensten im Internet zu verbessern (en: open web application security project)
PC	Personalcomputer (en: personal computer)
PDF	transportables Datenformat (en: portable document format)
PKI	Sicherheitsinfrastruktur (en: public key infrastructure)
RA	Ressourcenverfügbarkeit (en: resource availability)
RAM	Speicher mit wahlfreiem/direktem Zugriff (en: random access memory)
RDF	eingeschränkter Datenfluss (en: restricted data flow)
RE	weitergehende Anforderung (en: requirement enhancement)

RTOS	Echtzeit-Betriebssystem (en: real-time operating system)
RTU	entferntes Endgerät (en: remote terminal unit)
SAR	Anforderung an Softwareanwendungen (en: software application requirements)
SFTP	sicheres Dateiübertragungsprotokoll (en: secure FTP)
SHA	sicherer Hash-Algorithmus (en: secure hash algorithm)
SI	Systemintegrität (en: system integrity)
SIEM	Sicherheitsinformations- und Ereignismanagement (en: security information and event management)
SIF	sicherheitstechnische Funktion (en: safety instrumented function)
SIS	sicherheitstechnisches System (en: safety instrumented system)
SL	Security-Level (en: security level)
SL-A	erreichter Security-Level (en: achieved security level)
SL-C	erreichbarer Security-Level (en: capability security level)
SL-T	zu erreichender Security-Level (en: target security level)
SNMP	einfaches Netzwerkverwaltungsprotokoll (en: simple network management protocol)
SP	Sonderveröffentlichung der Bundesbehörde der Vereinigten Staaten von Amerika für Standards und Technologie (en: Special Publication)
SPS	speicherprogrammierbare Steuerung (en: programmable logic controller)
SR	Systemanforderung (en: system requirement)
SSH	Unix-basiertes Protokoll für einen sicheren Zugriff auf entfernte Computer (en: secure socket shell)
SuC	betrachtetes System (en: system under consideration)
SQL	strukturierte Abfragesprache (en: structured query language)
TCP	Übertragungssteuerungsprotokoll (en: transmission control protocol)
TPM	Computerchip mit Sicherheitsfunktionen (en: trusted platform module)
TRE	Rechtzeitige Reaktion auf Ereignisse (en: timely response to events)
UC	Nutzungskontrolle (en: use control)
USB	universeller serieller Bus (en: universal serial bus)
VPN	virtuelles privates Netz (en: virtual private network)

3.3 Vereinbarungen

Das vorliegende Dokument erweitert die in IEC 62443-3-3 festgelegten SR und RE zu einer Reihe von CR und RE für die in einem IACS enthaltenen Komponenten. Um die Rückführbarkeit der CR auf die SR nach IEC 62443-3-3 zu vereinfachen, entspricht die Benummerung der CR den zugehörigen SR. Infolgedessen entstehen im vorliegenden Dokument einige Lücken und eine nicht aufeinanderfolgende Benummerung. Für ein besseres Verständnis seitens des Lesers wird jede Hauptanforderung mit einer Begründung und zusätzlichen Hinweisen versehen und jede zugehörige RE, sofern nötig, mit Anmerkungen.

Die in diesem Dokument festgelegten Arten von Komponenten eines IACS sind Softwareanwendungen, Host-Geräte, eingebettete Geräte und Netzwerkkomponenten. Die Mehrheit der CR und RE gilt für alle vier Komponentenarten und wird zu einer einzigen Komponentenanforderung (CR) zusammengefasst. Einige CR und RE gelten nur für einen bestimmten Komponententyp. Um die Bezugnahme zu vereinfachen, wurden diese komponententypspezifischen Anforderungen in separate Abschnitte unterteilt. Spezifische Anforderungen für Softwareanwendungen, eingebettete Geräte, Host-Geräte und Netzwerkgeräte werden ab [Abschnitt 12](#) behandelt. Wenn eine Komponente die Definition einer (eines) oder mehrerer Softwareanwendungen, Host-Geräte, eingebetteter Geräte oder Netzwerkkomponenten erfüllt, muss diese Komponente alle Anforderungen erfüllen, die für die einzelnen Komponententypen aufgeführt sind.

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12 EN IEC 62443-4-2:2019

Jede der sieben in IEC TS 62443-1-1 definierten FR verfügt über einen definierten Satz von vier Security-Level (SL). Diese SL leiten sich aus den in IEC 62443-3-3 definierten System-Security-Level ab. Der Security-Level einer Komponente wird je FR unter Verwendung der Notation SL-C(FR, Komponente) mit einem entsprechenden Wert von 0 bis 4 beschrieben. Der erreichbare Security-Level 0 des Automatisierungssystems für eine bestimmte FR bedeutet bedingungslos keine Anforderung. Die Hauptanforderung und etwaige vorhandene RE für jede FR werden dann auf den erreichbaren Security-Level der Komponente, SL-C(FR, Komponente) 1 bis 4, abgebildet.

Zum Beispiel lautet die Erklärung des Zwecks für [Abschnitt 8](#):

Die Vertraulichkeit von Informationen in Kommunikationskanälen und Datenbeständen ist sicherzustellen, um deren nicht autorisierte Offenlegung zu verhindern.

Die zugehörigen vier SL sind wie folgt definiert:

- SL 1 – Verhindern der nicht autorisierten Offenlegung von Informationen durch Abhören oder zufälliges Aufdecken.
- SL 2 – Verhindern der nicht autorisierten Offenlegung von Informationen an eine danach aktiv mit einfachen Mitteln bei geringem Aufwand, allgemeinen Fertigkeiten und geringer Motivation suchende Einheit.
- SL 3 – Verhindern der nicht autorisierten Offenlegung von Informationen an eine danach aktiv mit raffinierten Mitteln und moderatem Aufwand, IACS-spezifischen Fertigkeiten und mittlerer Motivation suchende Einheit.
- SL 4 – Verhindern der nicht autorisierten Offenlegung von Informationen an eine danach aktiv mit raffinierten Mitteln und erheblichem Aufwand, IACS-spezifischen Fertigkeiten und hoher Motivation suchende Einheit.

Die einzelnen Zuweisungen von CR und RE erfolgen somit auf der Grundlage einer schrittweisen Erhöhung der gesamten IT-Sicherheit der Komponente für diese bestimmte FR anhand der Kenntnisse und der Fachkompetenz der Gruppe, die dieses Dokument entwirft.

Die Bezeichnung „SL-C(Komponente)“, die durchgehend in diesem Dokument verwendet wird, bezeichnet die Fähigkeit, die erforderlich ist, um einen bestimmten SL für eine gegebene CR zu erbringen. Für eine vollständige Beschreibung des SL-Vektorkonzepts wird auf IEC 62443-3-3 verwiesen.

4 Sicherheitsbeschränkungen für gemeinsame Komponenten (en: Common component security constraints)

4.1 Übersicht

Beim Lesen, Spezifizieren und Implementieren der in den [Abschnitten 5 bis 15](#) dieses Dokuments beschriebenen CR für Komponenten gibt es eine Reihe von allgemeinen Einschränkungen, die bei der Implementierung der in diesem Dokument beschriebenen Anforderungen angewendet werden müssen.

4.2 CCSC 1: Unterstützung wesentlicher Funktionen

Die Komponenten des Systems müssen bestimmten Einschränkungen nach IEC 62443-3-3:2013, Abschnitt 4 entsprechen.

4.3 CCSC 2: Ausgleichsmaßnahmen

Es gibt Fälle, in denen in diesem Dokument festgelegte Anforderungen nicht ohne außerhalb der Komponente durchgeführte Ausgleichsmaßnahmen erfüllt werden können. In diesem Fall müssen in der Dokumentation dieser Komponente die geeigneten Maßnahmen beschrieben werden, die vom System durchzuführen sind, damit die Anforderung bei der Integration der Komponente in das System erfüllt werden kann.

4.4 CCSC 3: Minimal erforderliche Rechte

Gegebenenfalls müssen Systemkomponenten (Softwareanwendungen, eingebettete Geräte, Host-Geräte und Netzwerkkomponenten) die Fähigkeit besitzen, das Prinzip der minimal erforderlichen Rechte für das System durchzusetzen. Dabei müssen die einzelnen Systemkomponenten die Rechte so abstufen und so flexibel auf die Rollen abbilden, dass dieses Prinzip unterstützt wird. Falls gefordert, müssen individuelle Zuordnungsmöglichkeiten zur Verfügung stehen. Die Abstufung der Rechte und deren Zuordnung hängt von der Geräteart ab und sollten in der Produktdokumentation für das Gerät angegeben werden.

4.5 CCSC 4: Softwareentwicklungsprozess

Sämtliche in diesem Dokument festgelegten Komponenten müssen nach dem in IEC 62443-4-1 beschriebenen Leitfaden für einen sicheren Produktentwicklungsprozess entwickelt und unterstützt werden.

5 FR 1 – Identifizierung und Authentifikation

5.1 Zweck und Beschreibungen der SL-C (IAC)

Alle Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) identifizieren und authentifizieren, bevor ihnen der Zugriff auf das System oder Betriebsmittel gewährt wird.

- SL 1 – Identifizieren und Authentifizieren aller Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) durch Verfahren, die gegen gelegentlichen oder zufälligen Zugriff von nicht authentifizierten Stellen schützen.
- SL 2 – Identifizieren und Authentifizieren aller Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) durch Verfahren, die gegen einen absichtlichen, nicht authentifizierten Zugriff von Stellen, die mit einfachen Mitteln, geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen, schützen.
- SL 3 – Identifizieren und Authentifizieren aller Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) durch Verfahren, die gegen einen absichtlichen, nicht authentifizierten Zugriff von Stellen, die mit raffinierten Mitteln, mittleren Ressourcen, IACS-spezifischen Fertigkeiten und mittlerer Motivation vorgehen, schützen.
- SL 4 – Identifizieren und Authentifizieren aller Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) durch Verfahren, die gegen einen absichtlichen, nicht authentifizierten Zugriff von Stellen, die mit raffinierten Mitteln, erheblicher Ressourcen, IACS-spezifischen Fertigkeiten und hoher Motivation vorgehen, schützen.

5.2 Begründung

Die Identifizierung von Nutzern wird in Verbindung mit Autorisierungsmechanismen verwendet, um die Zugriffskontrolle für eine Komponente zu implementieren. Das Überprüfen der Identität von Nutzern, die Zugriff anfordern, ist erforderlich, um zu verhindern, dass nicht autorisierte Nutzer Zugriff auf die Komponente erhalten. Zu den Empfehlungen und Leitlinien sollten Verfahren gehören, die mit Mischformen arbeiten. Zum Beispiel erfordern manche Komponenten in einem Kommunikationskanal eine strenge Zugriffskontrolle wie etwa starke Authentifikationsverfahren und andere nicht. Darüber hinaus müssen Anforderungen an die Zugriffskontrolle auf ruhende Daten übertragen werden.

Es ist empfehlenswert, die Anzahl der Identifizierungs- und Authentifikationsverfahren innerhalb einer Zone so gering wie möglich zu halten. Die Nutzung mehrerer Identifikations- und Authentifikationsverfahren erschwert die Aufgabe der Authentifikations- und Identifizierungsverwaltung.

5.3 CR 1.1 – Identifizierung und Authentifikation von menschlichen Nutzern

5.3.1 Anforderung

Komponenten müssen die Fähigkeit haben, alle menschlichen Nutzer an allen Schnittstellen mit der Möglichkeit eines Zugriffs durch menschliche Nutzer nach IEC 62443-3-3 SR 1.1 zu identifizieren und zu authentifizieren. Diese Fähigkeit muss an allen Schnittstellen, die menschlichen Nutzern Zugriff auf die Komponente gewähren, eine Identifizierung und Authentifikation in einer Art und Weise durchsetzen, dass die Trennung von Aufgaben und das Prinzip der minimal erforderlichen Rechte entsprechend den geltenden IT-Sicherheitsleitlinien und -vorgehensweisen unterstützt wird. Diese Fähigkeit darf lokal von der Komponente oder durch Integration in ein Identifizierungs- und Authentifizierungssystem auf Systemebene bereitgestellt werden.

ANMERKUNG Die geltenden Sicherheitsrichtlinien unterliegen lokalen Vorgaben.

5.3.2 Begründungen und zusätzliche Leitfäden

Alle menschlichen Nutzer müssen für alle Arten eines Zugriffs auf die Komponente identifiziert und authentifiziert werden. Die Authentifikation der Identität dieser Nutzer sollte durch die Verwendung solcher Methoden wie z. B. Passwörter, Token, biometrische Merkmale und abschließbare Geräte und im Fall von Multifaktor-Authentifikation durch Kombinationen dieser Methoden erfolgen. Der Aufenthaltsort des betreffenden menschlichen Nutzers kann ebenfalls als Teil des Authentifikationsprozesses verwendet werden. Diese Anforderung sollte sowohl bei lokalem Zugriff als auch bei Fernzugriff auf die Komponente gelten. Sie gilt zusätzlich zur Anforderung einer Authentifikation und Identifikation auf der Systemebene.

Schnittstellen mit einem Zugriff durch menschliche Nutzer sind lokale Benutzerschnittstellen wie Touchscreens, Druckknöpfe, Tastaturen sowie Netzwerkprotokolle für Interaktionen mit menschlichen Nutzern wie HTTP, HTTPS, FTP, SFTP, Protokolle für Gerätekonfigurationswerkzeuge (die mitunter geschützt sind oder auch offene Protokolle nutzen). Die Identifizierung und Authentifikation von Nutzern darf rollenbasiert oder gruppenbasiert erfolgen (z. B. dürfen mehrere Nutzer bei bestimmten Komponentenschnittstellen die gleiche Identität nutzen). Die Identifizierung und Authentifikation von Nutzern sollte schnelle örtliche Notfallmaßnahmen nicht behindern.

Zur Unterstützung von IAC-Richtlinien nach IEC 62443-2-1 [1], sollte die Komponente zuerst die Identität aller menschlichen Nutzer überprüfen. In einem zweiten Schritt sollten die den identifizierten menschlichen Nutzern zugewiesenen Berechtigungen durchgesetzt werden (siehe 6.3).

5.3.3 Weitergehende Anforderungen

(1) Eindeutige Identifizierung und Authentifikation:

Die Komponenten müssen die Fähigkeit haben, alle menschlichen Nutzer eindeutig zu identifizieren und zu authentifizieren.

(2) Multifaktor-Authentifikation über alle Schnittstellen

Die Komponenten müssen die Fähigkeit haben, eine Multifaktor-Authentifikation für den Zugriff aller menschlichen Nutzer auf die Komponente zu verwenden.

5.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.1 beziehen, sind:

- SL-C(IAC,Komponente) 1: CR 1.1;
- SL-C(IAC,Komponente) 2: CR 1.1 (1);
- SL-C(IAC,Komponente) 3: CR 1.1 (1) (2);
- SL-C(IAC,Komponente) 4: CR 1.1 (1) (2).

5.4 CR 1.2 – Identifizierung und Authentifikation von Softwareprozessen und Geräten

5.4.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, nach IEC 62443-3-3 SR1.2 sich selbst zu identifizieren und sich gegenüber anderen Komponenten (Softwareanwendungen, eingebettete Geräte, Host-Geräte und Netzwerkkomponenten) zu authentifizieren.

Wenn die Komponente, wie im Fall einer Anwendung, im Zusammenhang mit einem menschlichen Nutzer verwendet wird, dürfen die Identifizierung und die Authentifikation des menschlichen Nutzers nach IEC 62443-3-3 SR1.1 Teil des Identifizierungs- und Authentifikationsprozesses gegenüber anderen Komponenten sein.

5.4.2 Begründungen und zusätzliche Leitfäden

Die Funktion der Identifizierung und Authentifikation besteht darin, eine bekannte Identität auf einen unbekannten Softwareprozess oder ein unbekanntes Gerät (im Folgenden als Einheit in 5.4.2 bezeichnet) so abzubilden, dass dieser bzw. dieses vor Aufnahme eines Datenaustausches bekannt gemacht wird. Wäre es betrügerischen Einheiten erlaubt, IACS-spezifische Daten zu senden und zu empfangen, so könnte dies zu einem schädlichen Verhalten des Automatisierungssystems führen.

Alle Einheiten sollten für alle Arten eines Zugriffs auf das Automatisierungssystem identifiziert und authentifiziert werden. Die Authentifikation der Identität dieser Einheiten sollte durch die Verwendung von Methoden wie Passwörtern, Token oder Ort (physikalisch oder logisch) erfolgen. Diese Anforderung sollte sowohl bei einem lokalen Zugriff als auch bei einem Fernzugriff auf das Automatisierungssystem gelten. In Szenarien, in denen einzelne Einheiten dazu verwendet werden, sich mit verschiedenen Zielsystemen zu verbinden (z. B. Fernunterstützung durch einen Kundendienst), dürfen jedoch mehrere Identitäten für eine Einheit technisch nicht möglich sein. In diesen Fällen müssten Ausgleichsmaßnahmen angewendet werden.

Besondere Aufmerksamkeit ist bei der Identifizierung und Authentifikation tragbarer und mobiler Geräte erforderlich. Diese Art von Geräten ist eine bekannte Methode, um in Automatisierungssystemen, auch solchen, die ansonsten isoliert sind, einen unerwünschten Netzwerkverkehr zu erzeugen, Schadsoftware einzuschleusen und/oder eine Offenlegung von Informationen herbeizuführen.

Sofern Einheiten wie eine geschlossene Gruppe funktionieren, darf die Identifizierung und Authentifikation auch rollenbasiert, gruppenbasiert oder einheitenbasiert erfolgen. Dabei ist es äußerst wichtig, dass lokale Notfallhandlungen aber auch für das Automatisierungssystem wesentliche Funktionen nicht durch Identifizierungs- und Authentifikationsanforderungen behindert werden (siehe [Abschnitt 4](#) für eine ausführliche Darstellung). Bei üblichen Schutz- und Kontrollverfahren führt z. B. eine Gruppe von Geräten gemeinsam die Schutzfunktionen aus und kommuniziert mittels Multicast-Nachrichten untereinander. In solchen Fällen findet häufig eine Gruppenauthentifikation auf Basis gemeinsamer Nutzerkonten oder gemeinsamer symmetrischer Schlüssel statt.

Zur Unterstützung von IAC-Richtlinien nach IEC 62443-2-1 [\[1\]](#) überprüft das Automatisierungssystem in einem ersten Schritt die Identität aller Einheiten. In einem zweiten Schritt werden die den identifizierten Einheiten zugewiesenen Rechte durchgesetzt (siehe [6.3](#)).

5.4.3 Weitergehende Anforderungen

(1) Eindeutige Identifizierung und Authentifikation

Die Komponenten müssen die Fähigkeit haben, sich selbst eindeutig zu identifizieren und sich gegenüber jeder anderen Komponente zu authentifizieren.

5.4.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.2 beziehen, sind:

- SL-C(IAC,Komponente) 1: keine;

- SL-C(IAC,Komponente) 2: CR 1.2;
- SL-C(IAC,Komponente) 3: CR 1.2 (1);
- SL-C(IAC,Komponente) 4: CR 1.2 (1).

5.5 CR 1.3 – Nutzerkontenverwaltung

5.5.1 Anforderung

Die Komponenten müssen die Fähigkeit bieten, die Verwaltung aller Nutzerkonten direkt zu unterstützen oder in ein System zu integrieren, das Nutzerkonten nach IEC 62443-3-3 SR 1.3 verwaltet.

5.5.2 Begründungen und zusätzliche Leitfäden

Eine Komponente darf diese Fähigkeit zur Verfügung stellen, indem sie in ein Nutzerkontenverwaltungssystem einer höheren Ebene integriert wird. Wenn die Fähigkeit nicht in ein übergeordnetes Nutzerkontenverwaltungssystem integriert ist, wird von der Komponente erwartet, dass sie diese Fähigkeit standardmäßig bereitstellt.

Ein allgemeiner Ansatz für die Erfüllung dieser Anforderung wäre eine Komponente, die die Bewertung der Authentifikation an einen Verzeichnisserver überträgt (z. B. LDAP oder Active Directory), der die nach IEC 62443-3-3 SR 1.3 geforderten Fähigkeiten der Nutzerkontenverwaltung zur Verfügung stellt.

Wenn die Fähigkeiten der Nutzerkontenverwaltung einer Komponente darauf beruhen, dass diese in ein System einer höheren Ebene integriert sind, müssen Betrachtungen über die Auswirkung auf die Komponente für den Fall angestellt werden, dass die Fähigkeiten des Systems der höheren Ebene nicht mehr verfügbar sind.

5.5.3 Weitergehende Anforderungen

Keine.

5.5.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.3 beziehen, sind:

- SL-C(IAC,Komponente) 1: CR 1.3;
- SL-C(IAC,Komponente) 2: CR 1.3;
- SL-C(IAC,Komponente) 3: CR 1.3;
- SL-C(IAC,Komponente) 4: CR 1.3.

5.6 CR 1.4 – Verwaltung der Kennungen

5.6.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, in ein System integriert zu werden, das die Verwaltung von Kennungen unterstützt, und/oder sie müssen die Fähigkeit haben, die Verwaltung von Kennungen nach IEC 62443-3-3 SR 1.4 direkt zu unterstützen.

5.6.2 Begründungen und zusätzliche Leitfäden

Konten, die unter CR 1.3 – Kontenverwaltung (5.5) erstellt wurden, erfordern die Verwendung einer oder mehrerer Kennungen, um jedes Konto eindeutig identifizieren zu können. Diese Kennungen sollten einzigartig sein und eindeutig im Bezug zu dem Konto stehen, mit dem sie verknüpft sind. Einige Beispiele für häufig verwendete Kennungen sind Kontonamen, UNIX-Nutzer-IDs, GUIDs (en: Globally Unique Identifiers) für Microsoft Windows-Konten und gebundene X.509-Zertifikate. Eine Komponente kann eine lokale Fähigkeit zum Zuordnen von Kennungen zu Konten bieten. Wenn die Komponente in ein System integriert ist, das

eine systemweite Sicherheitsrichtlinie durchsetzt, wird dringend empfohlen, dass Kennungen für alle Komponenten im System demselben Konto zugeordnet werden. Zu diesem Zweck sollte eine Komponente in der Lage sein, sich in eine systemweite Kennungsverwaltungsfunktion zu integrieren.

5.6.3 Weitergehende Anforderungen

Keine.

5.6.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.4 beziehen, sind:

- SL-C(IAC,Komponente) 1: CR 1.4;
- SL-C(IAC,Komponente) 2: CR 1.4;
- SL-C(IAC,Komponente) 3: CR 1.4;
- SL-C(IAC,Komponente) 4: CR 1.4.

5.7 CR 1.5 – Verwaltung der Authentifizierer

5.7.1 Anforderung

Komponenten müssen die folgenden Fähigkeiten haben:

- a) die Nutzung des Anfangsinhalts eines Authentifizierers unterstützen;
- b) die Erkennung von Änderungen voreingestellter Authentifizierer nach erfolgter Installation unterstützen;
- c) bei periodischen Änderungen/Erneuerungen des Authentifizierer einwandfrei arbeiten; und
- d) Authentifizierer vor einer nicht autorisierten Offenlegung und Änderung während der Speicherung, Nutzung und Übermittlung schützen.

5.7.2 Begründungen und zusätzliche Leitfäden

Neben einer Kennung (siehe 5.6) ist zum Nachweis der Identität ein Authentifizierer notwendig. Authentifizierer eines Automatisierungssystems sind unter anderem Token, symmetrische Schlüssel, private Schlüssel (als Teil eines öffentlichen/privaten Schlüsselpaares), biometrische Merkmale, Passwörter, physikalische Schlüssel und Schlüsselkarten. Mit IT-Sicherheitsleitlinien sollten menschliche Nutzer angewiesen werden, angemessene Maßnahmen zu treffen, um ihre Authentifizierer zu schützen, einschließlich der Anweisung, ihre persönlichen Authentifizierer in ihrem Besitz zu behalten, Authentifizierer nicht zu verleihen oder mit anderen Personen zu teilen und verlorene oder kompromittierte Authentifizierer sofort zu melden.

Authentifizierer unterliegen einem Lebenszyklus. Wenn ein Nutzerkonto eingerichtet wird, muss automatisch auch ein neuer Authentifizierer erzeugt werden, damit der Kontoinhaber sich authentifizieren kann. Beispielsweise ist in einem passwortbasierten System ein Nutzerkonto mit einem Passwort verbunden. Die Festlegung des Anfangsinhalts des Authentifizierers könnte so interpretiert werden, dass der Administrator das Anfangspasswort festlegt, welches das Kontoverwaltungssystem für alle neuen Nutzerkonten vergibt. Die Fähigkeit der Konfiguration dieser Anfangswerte erschwert es einem Angreifer, das Passwort zwischen Einrichtung und erster Benutzung (bei der der Kontoinhaber ein neues Passwort eintragen sollte) eines Nutzerkontos zu erraten. Einige Automatisierungssysteme werden mit Hilfe von unbeaufsichtigten Installationsprogrammen installiert, die alle benötigten Nutzerkonten mit voreingestellten Passwörtern einrichten, und einige eingebettete Geräte werden sogar mit voreingestellten Passwörtern ausgeliefert. Im Laufe der Zeit werden solche Passwörter häufig allgemein bekannt und sogar im Internet dokumentiert. Die Fähigkeit der Änderung voreingestellter Passwörter schützt das System vor nicht autorisierten Nutzern, die mittels voreingestellter Passwörter Zugriff erlangen würden. Passwörter können durch Speicherung oder Übertragung bei der Authentifikation im Netzwerk erlangt werden. Diese Vorgehensweise kann mittels kryptografischer Schutzmaßnahmen wie Verschlüsselung oder Hash-Funktionen oder durch Handshake-Protokolle, die überhaupt keine Übertragung des Passworts erfordern, komplexer gestaltet werden. Aber dennoch können Passwörter Gegenstand von Angriffen sein, z. B. Brute-Force-Angriffe oder Brechen des

kryptografischen Passwortschutzes bei dessen Übertragung oder Speicherung. Das für solche Gelegenheiten offene Fenster kann verkleinert werden, indem die Passwörter regelmäßig geändert/erneuert werden. Ähnliche Überlegungen gelten für Authentifikationssysteme mittels kryptografischer Schlüssel. Ein erweiterter Schutz kann durch Verwendung von Hardwareverfahren wie z. B. hardwaregebundenen IT-Sicherheitsmodulen wie Trusted-Platform-Modulen (TPM), erreicht werden.

Die Verwaltung der Authentifizierer sollte in geltenden IT-Sicherheitsleitlinien und -vorgehensweisen geregelt werden, z. B. Vorgaben zur Änderung voreingestellter Authentifizierer, Erneuerungsintervalle und die Festlegung des Schutzes der Authentifizierer oder von Firecall-Prozeduren.

Neben den hier geforderten Fähigkeiten der Verwaltung der Authentifizierer hängt die Stärke der Authentifikationsverfahren von der Stärke des gewählten Authentifizierers (z. B. von der Komplexität des Passworts oder der Schlüssellänge bei der Authentifikation durch öffentliche Schlüssel) und den Leitlinien für die Validierung des Authentifizierers im Authentifikationsprozess (z. B. von der Dauer der Gültigkeit eines Passworts oder von den bei der Validierung öffentlicher Schlüsselzertifikate vorzunehmenden Prüfungen) ab. Für die gebräuchlichsten Authentifikationsverfahren, also Authentifikation mittels Passwort oder öffentlichem Schlüssel, gelten weitere Anforderungen nach 5.9, 5.10 und 5.11.

Die Nutzung von Komponenten kann für einige Operationen beschränkt sein und eine zusätzliche Authentifikation (wie Token, Schlüssel und Zertifikate) erfordern, um bestimmte Funktionen auszuführen.

5.7.3 Weitergehende Anforderungen

(1) Hardwaresicherheit für Authentifizierer

Die Authentifizierer, auf die sich die Komponenten stützen, müssen mit Hardwaremechanismen geschützt werden.

BEISPIEL Passwortgeschützter Speicher, OTP-Speicher, Prüfungen der Integrität der Hardwaredaten und Sicherheits-Boot-Mechanismen für Geräte.

5.7.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.5 beziehen, sind:

- SL-C(IAC,Komponente) 1: CR 1.5;
- SL-C(IAC,Komponente) 2: CR 1.5;
- SL-C(IAC,Komponente) 3: CR 1.5 (1);
- SL-C(IAC,Komponente) 4: CR 1.5 (1).

5.8 CR 1.6 – Verwaltung drahtloser Zugriffsverfahren

Die Anforderungen an die Verwaltung drahtloser Zugriffsverfahren sind von der Netzwerkkomponente abhängig und können als Anforderungen an Netzwerkkomponenten in [Abschnitt 15](#) angegeben werden.

5.9 CR 1.7 – Stärke der Authentifikation durch Passwörter

5.9.1 Anforderung

Komponenten, die Passwörter zur Authentifikation verwenden, müssen die Fähigkeit haben, eine konfigurierbare Stärke von Passwörtern gemäß international anerkannten und bewährten Passwortleitlinien zu bieten, oder sie müssen in ein System integriert werden, das diese Fähigkeit besitzt.

5.9.2 Begründungen und zusätzliche Leitfäden

Um die Erhöhung der Gesamtsicherheit der vom Nutzer gewählten Passwörter zu unterstützen, ist die Fähigkeit der Durchsetzung einer konfigurierbaren Stärke von Passwörtern notwendig unabhängig davon, ob diese auf der kleinsten Länge, der Vielfalt ihrer Zeichen oder der Geltungsdauer (die Mindestanforderung ist

ein Einmalpasswort) beruht. Allgemein anerkannte Verfahren und Empfehlungen können Dokumenten wie z. B. [20] entnommen werden.

5.9.3 Weitergehende Anforderungen

(1) Erzeugung und Lebensdauerbeschränkungen von Passwörtern für menschliche Nutzer

Die Komponenten müssen die Fähigkeit haben davor zu schützen, dass ein bestehendes Konto eines menschlichen Nutzers ein Passwort über eine konfigurierbare Anzahl von Erzeugungen hinaus wiederverwendet, oder sie müssen sich in ein System integrieren, das diese Fähigkeit hat. Zusätzlich muss die Komponente die Fähigkeit haben, eine minimale und eine maximale Lebensdauer von Passwörtern für einen menschlichen Nutzer durchzusetzen. Diese Fähigkeiten müssen mit den üblicherweise in der Sicherheits-Industrie anerkannten Praktiken im Einklang stehen. Die Komponente sollte die Fähigkeit haben, den Nutzer vor dem Ablauf einer einstellbaren Zeit zur Änderung seines Passworts aufzufordern.

(2) Lebensdauerbeschränkungen von Passwörtern für alle Nutzer (menschliche Nutzer, Softwareprozess oder Gerät)

Die Komponenten müssen die Fähigkeit haben, eine minimale und eine maximale Lebensdauer von Passwörtern für alle Nutzer durchzusetzen, oder müssen sich in ein System integrieren, das diese Fähigkeit hat.

5.9.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.7 beziehen, sind:

- SL-C(IAC,Komponente) 1: CR 1.7;
- SL-C(IAC,Komponente) 2: CR 1.7;
- SL-C(IAC,Komponente) 3: CR 1.7 (1);
- SL-C(IAC,Komponente) 4: CR 1.7 (1) (2).

5.10 CR 1.8 – PKI-Zertifikate

5.10.1 Anforderung

Falls eine Public-Key-Infrastruktur (PKI) zum Einsatz kommt, muss die Komponente die Fähigkeit haben, nach IEC 62443-3-3 SR1.8 zu kommunizieren und zu arbeiten, oder sie muss in ein System integriert werden, das diese Fähigkeit hat.

5.10.2 Begründungen und zusätzliche Leitfäden

Bei der Wahl einer geeigneten PKI sollten die Zertifizierungsrichtlinien der Organisation beachtet werden, die auf dem Risiko beruhen sollten, das sich aus einem Bruch der Vertraulichkeit der geschützten Information ergibt. Anleitungen zur Festlegung solcher Richtlinien finden sich in allgemein anerkannten Standards und Leitlinien, z. B. im „Request for Comment (RFC)“ der Internet Engineering Task Force (IETF) RFC 3647 [22] für eine X.509-basierte PKI. Beispielsweise sollten der geeignete Ort einer Zertifizierungsstelle, entweder innerhalb des Automatisierungssystems oder im Internet, sowie die Liste der vertrauenswürdigen Zertifizierungsstellen in den Leitlinien berücksichtigt werden, wobei dies von der Netzwerkarchitektur abhängt (siehe auch IEC 62443-2-1 [1]).

5.10.3 Weitergehende Anforderungen

Keine.

5.10.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.8 beziehen, sind:

- SL-C(IAC,Komponente) 1: keine;
- SL-C(IAC,Komponente) 2: CR 1.8;
- SL-C(IAC,Komponente) 3: CR 1.8;
- SL-C(IAC,Komponente) 4: CR 1.8.

5.11 CR 1.9 – Stärke der Authentifikation durch öffentliche Schlüssel

5.11.1 Anforderung

Komponenten, die eine Authentifikation durch öffentliche Schlüssel verwenden, müssen innerhalb derselben IACS-Umgebung nachfolgende Fähigkeiten haben oder sie müssen in ein System integriert werden, das diese Fähigkeiten hat:

- a) Zertifikate validieren durch Prüfung der Gültigkeit der Signatur eines vorliegenden Zertifikats;
- b) Zertifizierungskette validieren oder, im Falle von selbstsignierten Zertifikaten, Vergabe von untergeordneten Zertifikaten an alle Hosts, die mit demjenigen kommunizieren, auf den das Zertifikat ausgestellt wurde;
- c) Zertifikate validieren durch Überprüfung des vorliegenden Widerrufsstatus;
- d) Prüfung des zugehörigen privaten Schlüssels durch den Nutzer (menschliche Nutzer, Softwareprozess oder Gerät) einrichten;
- e) die authentifizierte Identität einem Nutzer zuordnen (Mensch, Softwareprozess oder Gerät); und
- f) sicherstellen, dass die für die Authentifikation durch symmetrischen Schlüssel verwendeten Algorithmen mit 8.5 übereinstimmen.

5.11.2 Begründungen und zusätzliche Leitfäden

Die Erfüllung der Anforderungen von 5.11.1 erfordert nicht unbedingt eine Echtzeitverbindung mit einer Zertifizierungsstelle. Alternativ dürfen für die Erfüllung der Anforderungen von 5.11.1 Out-of-Band-Verfahren angewendet werden. Nicht verbundene Systeme könnten Zertifikate z. B. mit manuellen Out-of-Band-Prozessen installieren und aktualisieren.

Kryptografie mit privaten und öffentlichen Schlüsseln hängt in starkem Maße von der Geheimhaltung des privaten Schlüssels eines bestimmten Eigentümers und der korrekten Handhabung der Vertrauensbeziehung ab. Bei der Verifikation des Vertrauens zwischen zwei mittels öffentlichem Schlüssel authentifizierten Einheiten ist es entscheidend, dass das Zertifikat des öffentlichen Schlüssels auf eine vertrauenswürdige Einheit zurückgeführt werden kann. Ein häufiger Fehler bei der Implementierung der Validierung von Zertifikaten ist, dass lediglich die Gültigkeit der Signatur eines Zertifikats geprüft wird, aber nicht das Vertrauen in den Signierer. In einer PKI wird einem Signierer vertraut, wenn er eine vertrauenswürdige Zertifizierungsstelle ist oder ein Zertifikat besitzt, das von einer solchen herausgegeben wurde, so dass alle Verifizierer die ihnen vorgelegten Zertifikate zu einer vertrauenswürdigen Zertifizierungsstelle zurückverfolgen müssen. Kann solch eine Kette von vertrauenswürdigen Zertifizierungsstellen nicht aufgebaut werden, sollte dem vorgelegten Zertifikat nicht vertraut werden.

Wenn an Stelle einer PKI selbstsignierte Zertifikate eingesetzt werden, der zu zertifizierende Eigentümer sein Zertifikat also selbst signiert, dann gibt es überhaupt keine vertrauenswürdige Dritt- oder Zertifizierungsstelle. Dies sollte durch Ausgabe selbstsignierter Zertifikate für die öffentlichen Schlüssel an alle Partner ausgeglichen werden, die diese durch anderweitig abgesicherte Mechanismen validieren müssen (beispielsweise durch Konfiguration aller Partner in einer vertrauenswürdigen Umgebung). Vertrauenswürdige Zertifikate müssen über sichere Kanäle an die Partner verteilt werden. Während des Validierungsvorgangs sollte einem selbstsignierten Zertifikat nur dann vertraut werden, wenn sich dieses bereits in der Liste der vertrauenswürdigen Zertifikate des validierenden Partners befindet. Die Menge vertrauenswürdiger Zertifikate sollte so klein wie möglich gehalten werden.

In beiden Fällen muss bei der Validierung damit gerechnet werden, dass ein Zertifikat widerrufen wird. In einer PKI geschieht dies meist durch die Führung von Zertifikatssperrlisten oder durch den Betrieb eines Online-Zertifikat-Status-Protokoll (OCSP)-Servers. Sollte auf Grund von Einschränkungen im Auto-

Automatisierungssystem eine Abfrage von Sperrlisten nicht möglich sein, so können Vorkehrungen wie eine kurze Zertifikatslebensdauer diesen Mangel kompensieren. Dabei ist zu beachten, dass gelegentlich Zertifikate mit kurzer Lebensdauer zu erheblichen betrieblichen Belastungen in der Umgebung eines Automatisierungssystems führen können.

Es ist zu erwarten, dass die meisten Komponenten in ein IACS integriert werden und die Schlüsselauthentifikationsmechanismen unterstützen, die das zugrunde liegende IACS zur Verfügung stellt. Bei der Implementierung der Authentifikation durch öffentliche Schlüssel auf der Komponentenebene eines IACS wird der Schutz des Schlüssels das Hauptanliegen und das Ziel der Schlüsselspeicherung in dieser Komponente. Bei der Implementierung sollte sichergestellt werden, dass die in der Komponente gespeicherten privaten Schlüssel nicht aufgerufen oder manipuliert werden können (siehe 5.7).

ANMERKUNG Es gibt manipulationssichere Entwurfsmethoden und -techniken, die den Entwurf eines sicheren Schutzverfahrens für private Schlüssel unterstützen.

5.11.3 Weitergehende Anforderungen

(1) Hardwaresicherheit für eine Authentifikation durch öffentliche Schlüssel

Die Komponenten müssen die Fähigkeit haben, die kritischen, dauerhaften privaten Schlüssel mittels Hardware zu schützen.

5.11.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.9 beziehen, sind:

- SL-C(IAC,Komponente) 1: keine;
- SL-C(IAC,Komponente) 2: CR 1.9;
- SL-C(IAC,Komponente) 3: CR 1.9 (1);
- SL-C(IAC,Komponente) 4: CR 1.9 (1).

5.12 CR 1.10 – Rückmeldung vom Authentifizierer

5.12.1 Anforderung

Wenn eine Komponente die Fähigkeit der Authentifikation bereitstellt, muss sie die Fähigkeit haben, während des Authentifikationsvorgangs die Rückmeldungen von Authentifikatorinformationen zu verschleiern.

5.12.2 Begründungen und zusätzliche Leitfäden

Das Verschleiern von Rückmeldungen schützt Informationen vor einer möglichen Auswertung durch nicht autorisierte Personen, z. B. verschleiert das Anzeigen von Sternchen oder anderen Zufallszeichen die Rückmeldung von Authentifikationsinformationen, wenn ein menschlicher Nutzer sein Passwort eingibt. Weitere Beispiele sind die Eingabe eines „Secure Socket Shell“ (SSH)-Tokens und von Einmalpasswörtern. Die authentifizierende Stelle sollte keine Hinweise wie „unbekannter Nutzernamen“ als Erklärung für die fehlgeschlagene Authentifikation liefern.

5.12.3 Weitergehende Anforderungen

Keine.

5.12.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.10 beziehen, sind:

- SL-C(IAC,Komponente) 1: CR 1.10;
- SL-C(IAC,Komponente) 2: CR 1.10;

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12
EN IEC 62443-4-2:2019

- SL-C(IAC,Komponente) 3: CR 1.10;
- SL-C(IAC,Komponente) 4: CR 1.10.

5.13 CR 1.11 – Erfolgreiche Anmeldeversuche**5.13.1 Anforderung**

Wenn eine Komponente die Fähigkeit der Authentifikation bereitstellt, muss sie die Fähigkeit haben:

- a) einen Grenzwert für eine einstellbare Anzahl erfolgloser aufeinanderfolgender Anmeldeversuche aller Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) innerhalb einer einstellbaren Zeit durchzusetzen; und
- b) nach dem Erreichen dieses Grenzwerts den Zugriff für eine vorgegebene Zeit oder bis zum Entsperrern durch einen Administrator zu verweigern. Ein Administrator kann ein Nutzerkonto vor dem Ablauf der Zeitsperre entsperren.

5.13.2 Begründungen und zusätzliche Leitfäden

Aufgrund der Möglichkeit einer Denial-of-Service-Situation darf die Anzahl aufeinanderfolgender ungültiger Anmeldeversuche begrenzt werden. Falls dieser Grenzwert aktiviert wurde, darf die Anwendung oder das Gerät automatisch die Anzahl der Zugriffsversuche nach einer vorbestimmten Zeit in Übereinstimmung mit den geltenden IT-Sicherheitsrichtlinien und -Verfahren wieder auf null zurücksetzen. Durch das Rücksetzen der Zugriffsversuche auf null können die Nutzer (menschliche Nutzer, Softwareprozesse und Geräte) Zugriff bekommen, sofern sie die richtige Anmeldekennung besitzen. Sind in Notsituationen unmittelbare Reaktionen des Bedienpersonals erforderlich, dann sollte eine automatische Zugriffsverweigerung (ohne menschliches Eingreifen) auf Arbeitsplatzrechner oder Netzknoten des Automatisierungssystems nicht stattfinden. Alle Aussperrungsmechanismen sollten die funktionalen Anforderungen an einen Dauerbetrieb berücksichtigen, um schädliche Denial-of-Service-Situationen, die zu einem Systemausfall führen oder die Sicherheit des Systems gefährden können, zu mildern. Die Zulassung interaktiver Anmeldungen für ein für kritische Dienste verwendetes Nutzerkonto könnte eine Möglichkeit für eine Denial-of-Service-Situation oder anderen Missbrauch darstellen.

5.13.3 Weitergehende Anforderungen

Keine.

5.13.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.11 beziehen, sind:

- SL-C(IAC,Komponente) 1: CR 1.11;
- SL-C(IAC,Komponente) 2: CR 1.11;
- SL-C(IAC,Komponente) 3: CR 1.11;
- SL-C(IAC,Komponente) 4: CR 1.11.

5.14 CR 1.12 – Nutzungshinweis des Systems**5.14.1 Anforderung**

Wenn eine Komponente einen lokalen Zugriff für menschliche Nutzer/eine HMI besitzt, muss sie die Fähigkeit haben, noch vor der Authentifikation die Nutzungshinweise des Systems anzuzeigen. Diese Nachricht für einen Nutzungshinweis des Systems muss von autorisiertem Personal konfiguriert werden können.

5.14.2 Begründungen und zusätzliche Leitfäden

Richtlinien und Verfahren zum Datenschutz und zur IT-Sicherheit müssen in Einklang mit gesetzlichen Vorgaben, Leitlinien, Richtlinien, Normen und Anleitungen stehen. Häufig liegt die Begründung hierfür in der Strafverfolgung und dem Nachweis eines vorsätzlichen Rechtsbruchs. Diese Fähigkeit ist somit zur Unterstützung der Richtlinien notwendig und kann die IT-Sicherheit eines IACS verbessern, weil sie als Abschreckungsmaßnahme dienen kann. Nutzungshinweise des Systems können in Form von Warnbannern implementiert werden, die bei der Anmeldung von Personen im Automatisierungssystem angezeigt werden. Ein in den Räumen des Automatisierungssystems angebrachtes Warnbanner schützt nicht vor Problemen einer Fernanmeldung.

Beispiele für Elemente von Nutzungshinweisen des Systems sind Hinweise:

- dass die Person auf ein System zugreift, das dem Betreiber gehört;
- dass die Systemnutzung überwacht, aufgezeichnet und Gegenstand einer Prüfung sein darf;
- dass eine nicht autorisierte Verwendung des Systems verboten ist und strafrechtlich und/oder zivilrechtlich verfolgt wird; und
- dass mit der Verwendung des Systems der Überwachung und der Aufzeichnung zugestimmt wird.

5.14.3 Weitergehende Anforderungen

Keine.

5.14.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.12 beziehen, sind:

- SL-C(IAC,Komponente) 1: CR 1.12;
- SL-C(IAC,Komponente) 2: CR 1.12;
- SL-C(IAC,Komponente) 3: CR 1.12;
- SL-C(IAC,Komponente) 4: CR 1.12.

5.15 CR 1.13 – Zugriff über nicht vertrauenswürdige Netzwerke

Die Anforderungen an den Zugriff über nicht vertrauenswürdige Netzwerke sind komponentenpezifisch und können als Anforderungen für jede spezifische Komponententyp in den [Abschnitten 12 bis 15](#) angegeben werden.

5.16 CR 1.14 – Stärke der Authentifikation durch symmetrische Schlüssel

5.16.1 Anforderung

Komponenten, die symmetrische Schlüssel nutzen, müssen folgende Fähigkeiten haben:

- Aufbau des gegenseitigen Vertrauens durch Nutzung des symmetrischen Schlüssels;
- sicheres Speichern des gemeinsamen Geheimnisses (die Authentifikation ist gültig, solange das gemeinsame Geheimnis geheim bleibt);
- Einschränkung des Zugriffs auf das gemeinsame Geheimnis; und
- Sicherstellen, dass die für die Authentifikation durch symmetrischen Schlüssel verwendeten Algorithmen mit [8.5](#) übereinstimmen.

5.16.2 Begründungen und zusätzliche Leitfäden

Es sollten Mittel für die Installation der Schlüssel in der Komponente festgelegt werden. Dazu dürfen die Installation und Verwaltung des Komponentenschlüssels mit Out-of-Band-Verfahren gehören. Diese Vor-

gehensweise ist notwendig, da eine Gefährdung eines in einer Komponente gespeicherten symmetrischen Schlüssels zur Gefährdung des gesamten Systems, das diesen Schlüssel nutzt, führen könnte.

In der Praxis gibt es zwei grundlegende Verfahren einer sicheren Authentifikation eines Gerätes gegenüber einem anderen Gerät: entweder mit der asymmetrischen Kryptografie (siehe 5.11) oder mit der symmetrischen Kryptografie. Die Wahl zwischen der asymmetrischen und der symmetrischen Kryptografie wird durch mehrere Kriterien wie die Schlüsselverwaltung, Vertrauensbildung, Unterstützung von Altsystemen und Leistungsfähigkeit bestimmt. Beispiele für die Authentifikation durch symmetrische Schlüssel sind Needham-Schröder oder Kerberos. Bei der Authentifikation durch symmetrische Schlüssel nutzen die Teilnehmer einen geheimen Schlüssel, den sie in der Vergangenheit erfahren haben (z. B. durch Vertrauensbildung). Die Teilnehmer weisen ihre beanspruchte Identität durch die Kenntnis des geheimen Schlüssels nach (z. B. durch Beantworten einer Frage, die vom anderen Teilnehmer, dem Prüfer, gestellt wird). Der Prüfer kennt das gleiche Geheimnis (das er auch in der Vergangenheit durch Vertrauensbildung erfahren hat) und kann die Antwort auf die Frage anhand der gleichen kryptografischen Operationen berechnen wie der Anfragende. Der Prüfer kann dann die Antwort des Anfragenden mit seiner eigenen Berechnung vergleichen. Kommt der Prüfer zum gleichen Ergebnis, ist er überzeugt, dass der Anfragende derjenige ist, der er zu sein vorgibt, und der Prozess kann für eine gegenseitige Authentifikation umgekehrt mit getauschten Rollen durchgeführt werden. Dieser Mechanismus ist nur dann sicher, wenn das gemeinsame Geheimnis ausschließlich dem Anfragenden und dem Prüfer bekannt ist und wenn jeder Prüfer ein anderes Geheimnis besitzt. Ein Beispiel für einen solchen Mechanismus ist die richtige Nutzung der CMAC-Berechnungen oder alternativ von GCM/GMAC.

5.16.3 Weitergehende Anforderungen

(1) Hardwaresicherheit für eine Authentifikation durch symmetrische Schlüssel

Die Komponenten müssen die Fähigkeit haben, die kritischen, dauerhaften symmetrischen Schlüssel mittels Hardware zu schützen.

5.16.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 1.14 beziehen, sind:

- SL-C(IAC,Automatisierungssystem) 1: keine;
- SL-C(IAC,Automatisierungssystem) 2: CR 1.14;
- SL-C(IAC,Automatisierungssystem) 3: CR 1.14 (1);
- SL-C(IAC,Automatisierungssystem) 4: CR 1.14 (1).

6 FR 2 – Nutzungskontrolle

6.1 Zweck und Beschreibungen der SL-C (UC)

Durchsetzung der zugewiesenen Berechtigungen, die es einem authentifizierten Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) erlauben, die geforderten Aktionen in der Komponente durchzuführen und die Verwendung dieser Berechtigungen zu überwachen.

- SL 1 – Beschränken der Nutzung des IACS entsprechend den festgelegten Berechtigungen, um vor gelegentlichem oder zufälligem Missbrauch zu schützen.
- SL 2 – Beschränken der Nutzung des IACS entsprechend den festgelegten Berechtigungen, um vor Überlastung durch Einheiten, die mit einfachen Mitteln bei geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen, zu schützen.
- SL 3 – Beschränken der Nutzung des IACS entsprechend den festgelegten Berechtigungen, um vor Überlastung durch Einheiten, die mit raffinierten Mitteln und mittleren Ressourcen, IACS-spezifischen Fertigkeiten und mittlerer Motivation vorgehen, zu schützen.
- SL 4 – Beschränken der Nutzung des IACS entsprechend den festgelegten Berechtigungen, um vor Überlastung durch Einheiten, die mit raffinierten Mitteln und erheblichen Ressourcen, IACS-spezifischen Fertigkeiten und hoher Motivation vorgehen, zu schützen.

6.2 Begründung

Nach erfolgter Identifizierung und Authentifikation eines Nutzers sollte die Komponente die erlaubten Aktionen auf die autorisierte Nutzung der Komponente beschränken. Betreiber und Systemintegratoren müssen jedem Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät), jeder Gruppe, Rolle usw. (siehe 4.5) die Berechtigungen zuweisen, die die autorisierte Nutzung der Komponente definieren. Das Ziel der Nutzungskontrolle ist der Schutz vor nicht autorisierten Handlungen an den Ressourcen der Komponente durch Verifikation, dass die erforderlichen Berechtigungen erteilt worden sind, bevor dem Nutzer erlaubt wird, die Aktionen durchzuführen. Beispiele für solche Handlungen sind das Auslesen oder Schreiben von Daten, das Herunterladen von Programmen und die Veränderungen von Konfigurationseinstellungen. Zu den Empfehlungen und Leitlinien sollten Verfahren gehören, die mit Mischformen arbeiten. Beispielsweise erfordern einige Ressourcen der Komponente eine strenge Nutzungskontrolle wie restriktive Berechtigungen, andere dagegen nicht. Die Nutzungskontrolle sollte auch auf ruhende Daten ausgedehnt werden. Nutzerberechtigungen dürfen je nach Tageszeit/Datum, Ort und Zugriffsmedium variieren.

6.3 CR 2.1 – Durchsetzung der Autorisierung

6.3.1 Anforderung

Die Komponenten müssen auf der Grundlage der ihr zugeordneten Verantwortlichkeiten einen Mechanismus für die Durchsetzung der Autorisierung für alle identifizierten und authentifizierten Nutzer bereitstellen.

6.3.2 Begründungen und zusätzliche Leitfäden

Verwendungskontrollrichtlinien (z. B. identitätsbasierte Richtlinien, rollenbasierte Richtlinien und regelbasierte Richtlinien) und zugehörige Mechanismen zur Sicherstellung des Lese-/Schreibzugriffs (z. B. Zugriffskontrolllisten, Zugriffskontrollmatrizen und Kryptografie) werden zur Kontrolle der Verwendung zwischen Nutzern (Menschen, Softwareprozesse und -geräte) und Assets (z. B. Geräte, Dateien, Datensätze, Softwareprozesse, Programme und Domänen) eingesetzt.

Nachdem das Automatisierungssystem die Identität eines Nutzers (Mensch, Softwareprozess oder Gerät) überprüft hat (siehe 5.3 und 5.4), muss es auch überprüfen, ob ein angeforderter Vorgang gemäß den definierten Sicherheitsrichtlinien und -verfahren zulässig ist. In einer rollenbasierten Zugriffskontrollrichtlinie prüft das Automatisierungssystem beispielsweise, welche Rollen einem verifizierten Nutzer oder Asset zugewiesen sind und über welche Berechtigungen diese Rollen verfügen – wird der angeforderte Vorgang von den Berechtigungen abgedeckt, wird er ausgeführt, wenn nicht, dann wird er abgelehnt. Dies ermöglicht die Durchsetzung der Aufgabentrennung und der minimal erforderlichen Rechte. Durchsetzungsmechanismen für die Nutzung sollten die Leistungsfähigkeit des Automatisierungssystems nicht nachteilig beeinträchtigen.

Geplante oder ungeplante Änderungen an Komponenten des Automatisierungssystems können erhebliche Auswirkungen auf die Gesamtsicherheit des Steuerungssystems haben. Dementsprechend sollten nur qualifizierte und autorisierte Personen die Komponenten des Automatisierungssystems benutzen dürfen, damit sie Änderungen einleiten können, einschließlich Upgrades und Modifizierungen.

6.3.3 Weitergehende Anforderungen

- (1) Durchsetzung der Autorisierung für alle Nutzer (menschliche Nutzer, Softwareprozesse und Geräte)

Die Komponenten müssen auf der Grundlage der ihnen zugeordneten Verantwortlichkeiten und minimal erforderlichen Rechte einen Mechanismus für die Durchsetzung der Autorisierung für alle Nutzer bereitstellen.

- (2) Abbildung der Berechtigung auf Rollen

Die Komponenten müssen einer autorisierten Rolle direkt oder durch einen Ausgleichmechanismus der IT-Sicherheit die Möglichkeit einräumen, die Abbildung der Berechtigungen aller menschlichen Nutzer auf Rollen festzulegen und zu modifizieren.

Rollen sollten nicht auf fest verschachtelte Hierarchien beschränkt werden, in denen eine Rolle einer höheren Ebene eine übergeordnete Menge einer weniger berechtigten Rolle ist. Beispielsweise sollte ein

Systemadministrator im Allgemeinen nicht zwangsläufig auch über die Berechtigungen eines Anlagenbedieners verfügen.

ANMERKUNG 1 Diese weitergehende Anforderung (RE) ist sowohl auf Softwareprozesse als auch auf Geräte anzuwenden.

(3) Eingriff des Aufsichtspersonals

Die Komponenten müssen für eine konfigurierbare Zeit oder Ereignisfolge manuelle Eingriffe des Aufsichtspersonals unterstützen.

ANMERKUNG 2 Durch Implementierung von kontrollierten, geprüften und manuellen Eingriffen von automatisierten Mechanismen im Notfall oder bei anderen schwerwiegenden Ereignissen kann ein Vorgesetzter einen Bediener schnell auf ungewöhnliche Bedingungen reagieren lassen, ohne die aktuelle Sitzung schließen und eine neue Sitzung als menschlicher Nutzer mit höheren Berechtigungen einrichten zu müssen.

(4) Doppelte Zustimmung

Die Komponenten müssen eine doppelte Zustimmung unterstützen, falls eine Handlung zu schwerwiegenden Auswirkungen auf den industriellen Prozess führen kann.

Eine doppelte Zustimmung sollte auf solche Handlungen beschränkt werden, die ein sehr hohes Maß an Vertrauen erfordern, dass sie zuverlässig und korrekt ausgeführt werden. Die Forderung nach einer doppelten Zustimmung betont die Schwere der Folgen einer eventuell nicht korrekt ausgeführten Handlung. Ein Beispiel dafür ist die Änderung eines Sollwerts eines kritischen industriellen Prozesses. Eine doppelte Zustimmung sollte nicht angewendet werden, wenn eine unmittelbare Reaktion erforderlich ist, um negative Folgen auf Gesundheit, Sicherheit und Umwelt zu vermeiden, z. B. eine Notabschaltung eines industriellen Prozesses.

6.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.1 beziehen, sind:

- SL-C(UC,Komponente) 1: CR 2.1;
- SL-C(UC,Komponente) 2: CR 2.1 (1) (2);
- SL-C(UC,Komponente) 3: CR 2.1 (1) (2) (3);
- SL-C(UC,Komponente) 4: CR 2.1 (1) (2) (3) (4).

6.4 CR 2.2 – Nutzungskontrolle von Funkverbindungen

6.4.1 Anforderung

Wenn eine Komponente einen Zugriff über drahtlose Schnittstellen unterstützt, muss sie die Fähigkeit haben, sich in das System zu integrieren, das die Nutzungsautorisierung unterstützt, die in der industriellen Praxis allgemein übliche Nutzungsbeschränkungen überwacht.

6.4.2 Begründungen und zusätzliche Leitfäden

Eine drahtlose Nutzungskontrolle darf in verschiedenen Geräten des Systems implementiert werden. Netzwerkkomponenten dürfen Geräte sein, die die Nutzungskontrolle durch Kontrollen wie eine Netzwerkzugriffskontrolle unterstützen. Geräte und Anwendungen, die drahtlose Netzwerke nutzen, sollten in der Lage sein, den Schutz drahtloser Netzwerke wie eine Netzwerkzugriffskontrolle richtig anzuwenden. Komponenten dürfen auch andere Beschränkungen für den Zugriff implementieren, die davon abhängen, ob der Zugriff über drahtlose oder drahtgebundene Geräte erfolgt. Das erfordert, dass die Komponente unterscheiden kann, ob die Schnittstelle drahtlos ist oder nicht. Einige Netzwerkkomponenten haben die Fähigkeit, das Funkspektrum nach nicht autorisierten drahtlosen Netzwerken zu scannen. Um eine negative Auswirkung auf die Leistungsfähigkeit der Funktionen des Automatisierungssystems zu verhindern, ist der Einsatz zweckgebundener Geräte für die Durchführung von Prüfungen nicht autorisierter Netzwerkaktivitäten eine gute Praxis.

6.4.3 Weitergehende Anforderungen

Keine.

6.4.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.2 beziehen, sind:

- SL-C(UC,Komponente) 1: CR 2.2;
- SL-C(UC,Komponente) 2: CR 2.2;
- SL-C(UC,Komponente) 3: CR 2.2;
- SL-C(UC,Komponente) 4: CR 2.2.

6.5 CR 2.3 – Nutzungskontrolle von tragbaren und mobilen Geräten

Mit IEC 62443-3-3 SR 2.3 sind keine Anforderungen auf Komponentenebene verbunden.

6.6 CR 2.4 – Mobiler Code

Die Anforderungen an die Nutzungskontrolle für mobile Codes sind komponentenpezifisch und können als Anforderungen für jede spezifische Komponentenart in den [Abschnitten 12 bis 15](#) angegeben werden.

6.7 CR 2.5 – Sitzungssperrung

6.7.1 Anforderung

Wenn eine Komponente eine Benutzerschnittstelle für menschliche Nutzer besitzt, muss sie unabhängig davon, ob ein Zugriff lokal oder über ein Netzwerk erfolgt, die Fähigkeit haben:

- a) durch Initiieren einer Sitzungssperrung nach einem konfigurierbaren Zeitraum der Inaktivität oder durch manuelles Initiieren durch den Nutzer (Mensch, Softwareprozess oder Gerät) sich vor weiterem Zugriff zu schützen und
- b) die Sitzungssperrung so lange zu erhalten, bis der menschliche Nutzer, dem die Sitzung gehört, oder ein anderer autorisierter Nutzer unter Verwendung angemessener Vorgehensweisen zur Identifizierung und Authentifikation den Zugriff wieder herstellt.

6.7.2 Begründungen und zusätzliche Leitfäden

Sitzungssperrungen werden eingesetzt, um den Zugriff auf bestimmte Arbeitsplatzrechner oder Knoten zu verhindern. Komponenten sollten Mechanismen zur Sitzungssperrung automatisch nach einer einstellbaren Zeit aktivieren. In den meisten Fällen werden die Sitzungssperrungen auf Systemebene konfiguriert. Im Rahmen dieser Anforderung implementierte Sitzungssperrungen dürfen durch die Beendigung einer Fernzugriffssitzung nach [6.8](#) vorweggenommen oder eingeschränkt werden.

6.7.3 Weitergehende Anforderungen

Keine.

6.7.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.5 beziehen, sind:

- SL-C(UC,Komponente) 1: CR 2.5;
- SL-C(UC,Komponente) 2: CR 2.5;
- SL-C(UC,Komponente) 3: CR 2.5;
- SL-C(UC,Komponente) 4: CR 2.5.

6.8 CR 2.6 – Beendigung einer Fernzugriffssitzung

6.8.1 Anforderung

Wenn eine Komponente Fernzugriffssitzungen unterstützt, muss sie die Fähigkeit haben, die Fernzugriffssitzung entweder automatisch nach einer einstellbaren Zeit der Inaktivität, von Hand durch eine lokale Stelle oder von Hand durch den Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät), der die Sitzung initiiert hat, zu beenden.

6.8.2 Begründungen und zusätzliche Leitfäden

Eine Fernzugriffssitzung wird eingeleitet, wenn auf eine Komponente über die Grenze einer Zone, die vom Betreiber aufgrund einer Risikobeurteilung festgelegt wurde, hinweg zugegriffen wird. Diese Anforderung darf auf Sitzungen beschränkt werden, die nach der Risikobeurteilung des Automatisierungssystems und den IT-Sicherheitsrichtlinien und -vorgehensweisen der Überwachung und Instandhaltung der Komponente dienen (keine kritischen Handlungen). Einige Komponenten erlauben das Beenden von Sitzungen möglicherweise nicht, da die Sitzung Teil einer wesentlichen Funktion der Komponente ist.

6.8.3 Weitergehende Anforderungen

Keine.

6.8.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.6 beziehen, sind:

- SL-C(UC,Komponente) 1: keine;
- SL-C(UC,Komponente) 2: CR 2.6;
- SL-C(UC,Komponente) 3: CR 2.6;
- SL-C(UC,Komponente) 4: CR 2.6.

6.9 CR 2.7 – Kontrolle gleichzeitiger Sitzungen

6.9.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, die Anzahl der gleichzeitigen Sitzungen je Schnittstelle für jeden gegebenen Nutzer (menschlicher Nutzer, Softwareprozesse oder Geräte) zu begrenzen.

6.9.2 Begründungen und zusätzliche Leitfäden

Wird kein Grenzwert festgelegt, könnte eine DoS-Attacke einen Ressourcenengpass hervorrufen. Es muss daher abgewogen werden zwischen der möglichen Aussperrung eines bestimmten Nutzers und der Aussperrung aller Nutzer und Dienste aufgrund nicht ausreichender Ressourcen. Es bedarf wahrscheinlich der Anleitung durch den Hersteller und/oder Systemintegrator, um ausreichende Informationen zur Verfügung zu stellen, wie die Anzahl gleichzeitiger Sitzungen festgelegt werden sollte.

6.9.3 Weitergehende Anforderungen

Keine.

6.9.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.7 beziehen, sind:

- SL-C(UC,Komponente) 1: keine;
- SL-C(UC,Komponente) 2: keine;

- SL-C(UC,Komponente) 3: CR 2.7;
- SL-C(UC,Komponente) 4: CR 2.7.

6.10 CR 2.8 – Prüfbare Ereignisse

6.10.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, Ereignisdatensätze zur IT-Sicherheit in den folgenden Kategorien zu erzeugen:

- a) Zugriffskontrolle;
- b) fehlerhafte Anfragen;
- c) Ereignisse im Automatisierungssystem;
- d) Ereignisse bei der Sicherung und Wiederherstellung;
- e) Konfigurationsänderungen; und
- f) Ereignisse, die aus dem Ereignisprotokoll hervorgehen.

Die einzelnen Ereignisdatensätze müssen folgende Angaben enthalten:

- a) Zeitstempel;
- b) Quelle (Gerät, Softwareprozess oder Konto des menschlichen Nutzers, von dem das Ereignis herrührt);
- c) Kategorie;
- d) Art;
- e) Ereigniskennung; und
- f) Ergebnis des Ereignisses.

6.10.2 Begründung und zusätzliche Leitfäden

Geräte dürfen entweder eingebettete Firmware enthalten oder sie arbeiten mit einem Betriebssystem. Obwohl die Anforderung vorsieht, dass Ereigniskategorien abgedeckt werden, müssen mindestens alle Ereignisse der angegebenen Kategorien, die durch die Firmware oder das Betriebssystem hervorgerufen werden können, einbezogen werden.

ANMERKUNG Kategorien von IT-Sicherheitsereignissen sind nur anwendbar, wenn die Komponente die Funktion selbst bereitstellt.

6.10.3 Weitergehende Anforderungen

Keine.

6.10.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.8 beziehen, sind:

- SL-C(UC,Komponente) 1: CR 2.8;
- SL-C(UC,Komponente) 2: CR 2.8;
- SL-C(UC,Komponente) 3: CR 2.8;
- SL-C(UC,Komponente) 4: CR 2.8.

6.11 CR 2.9 – Speicherkapazität für Ereignisdatensätze

6.11.1 Anforderung

Komponenten müssen

- a) die Fähigkeit haben, Speicherkapazität für Ereignisdatensätze entsprechend allgemein anerkannten Empfehlungen für die Protokollverwaltung bereitzustellen, und
- b) Mechanismen bereitstellen, die vor einem Ausfall der Komponente schützen, wenn die Speicherkapazität für Ereignisdatensätze erreicht ist oder überschritten wird.

6.11.2 Begründungen und zusätzliche Leitfäden

Die Komponenten sollten unter Berücksichtigung der Aufbewahrungsleitlinien, der durchzuführenden Prüfungen und der Forderung nach Online-Prüfung ausreichend Speicherkapazität bereitstellen. Komponenten dürfen sich bei der Bereitstellung des größten Teils der Speicherkapazität für Ereignisdatensätze auf das System stützen, in das sie integriert sind. Die Komponente sollte jedoch ausreichend lokalen Speicher für eine Zwischenspeicherung der Ereignisdaten haben, bevor diese zum System gesendet werden.

Zu berücksichtigende Richtlinien können NIST Special Publication (SP) 800-92 [19] einschließen. Die Speicherkapazität für Ereignisdatensätze sollte ausreichen, um Ereignisprotokolle nach geltenden Leitlinien, Regelungen oder geschäftlichen Anforderungen genügend lange aufbewahren zu können.

6.11.3 Weitergehende Anforderungen

- (1) Warnung, wenn die Speicherkapazität für Ereignisdatensätze erreicht ist

Wenn die zugeteilte Speicherkapazität für Ereignisdatensätze einen konfigurierbaren Schwellwert erreicht hat, müssen die Komponenten die Fähigkeit haben, eine entsprechende Warnung auszugeben.

6.11.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.9 beziehen, sind:

- SL-C(UC,Komponente) 1: CR 2.9;
- SL-C(UC,Komponente) 2: CR 2.9;
- SL-C(UC,Komponente) 3: CR 2.9 (1);
- SL-C(UC,Komponente) 4: CR 2.9 (1).

6.12 CR 2.10 – Verhalten bei Verarbeitungsfehlern von Ereignisdaten

6.12.1 Anforderung

Komponenten müssen

- a) bei einem Verarbeitungsfehler von Ereignisdaten die Fähigkeit haben, sich gegen den Verlust wesentlicher Dienste und Funktionen zu schützen, und
- b) als Reaktion auf einen Verarbeitungsfehler von Ereignisdaten die Fähigkeit haben, nach allgemein anerkannter industrieller Gepflogenheiten geeignete Maßnahmen zu unterstützen.

6.12.2 Begründung und zusätzliche Leitfäden

Ereignisdaten werden üblicherweise an der Quelle des Ereignisses erzeugt. Die Verarbeitung von Ereignisdaten umfasst die Übertragung, eine mögliche Ergänzung (wie etwa das Hinzufügen eines Zeitstempels) und eine dauerhafte Speicherung der Ereignisdatensätze. Verarbeitungsfehler von Ereignisdaten beinhalten z. B. Software- oder Hardwarefehler, Ausfälle im Erfassungsmechanismus und das Erreichen oder Überschreiten der Speicherkapazität für Ereignisdatensätze. Zu berücksichtigende Leitfäden zur Entwicklung geeigneter Gegenmaßnahmen können NIST SP 800-92, *Guide to Computer Security Log Management* [19]

einschließen. Hierbei sollte beachtet werden, dass sowohl ein Überschreiben der ältesten Prüfaufzeichnungen als auch ein Unterbrechen der Erzeugung neuer Aufzeichnungen mögliche Reaktionen auf ein Überschreiten der Speicherkapazität sein können, die jedoch den Verlust möglicherweise wichtiger forensischer Informationen bewirken. Auch die Alarmierung des Personals kann eine geeignete Unterstützungsmaßnahme als Reaktion auf einen Verarbeitungsfehler von Ereignisdaten sein.

6.12.3 Weitergehende Anforderungen

Keine.

6.12.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.10 beziehen, sind:

- SL-C(UC,Komponente) 1: CR 2.10;
- SL-C(UC,Komponente) 2: CR 2.10;
- SL-C(UC,Komponente) 3: CR 2.10;
- SL-C(UC,Komponente) 4: CR 2.10.

6.13 CR 2.11 – Zeitstempel

6.13.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, Zeitstempel (mit Datum und Zeit) für die Nutzung in Ereignisdatensätzen zu erzeugen.

6.13.2 Begründungen und zusätzliche Leitfäden

Eine gute Referenz für das Format von Zeitstempeln ist ISO/IEC 8601:2004 [7]. Beim Entwurf eines Systems sollte darauf geachtet werden, dass periodische Zeitverschiebungen, z. B. Sommerzeit und Winterzeit, berücksichtigt werden.

6.13.3 Weitergehende Anforderungen

(1) Zeitsynchronisation

Die Komponenten müssen die Fähigkeit haben, Zeitstempel zu erzeugen, die mit einer systemweiten Zeitquelle synchronisiert sind.

(2) Schutz und Integrität der Zeitquelle

Der Zeitsynchronisationsmechanismus muss die Fähigkeit haben, eine nicht autorisierte Änderung zu erkennen, und er muss bei einer Änderung ein prüfbares Ereignis hervorrufen.

6.13.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.11 beziehen, sind:

- SL-C(UC,Komponente) 1: CR 2.11;
- SL-C(UC,Komponente) 2: CR 2.11 (1);
- SL-C(UC,Komponente) 3: CR 2.11 (1);
- SL-C(UC,Komponente) 4: CR 2.11 (1) (2).

6.14 CR 2.12 – Nichtabstreitbarkeit

6.14.1 Anforderung

Wenn eine Komponente eine Benutzerschnittstelle besitzt, muss sie die Fähigkeit haben festzustellen, ob ein bestimmter menschlicher Nutzer eine bestimmte Handlung vorgenommen hat.

Steuerelemente, die diese Fähigkeit nicht unterstützen können, müssen in der Dokumentation der Komponente aufgeführt werden.

6.14.2 Begründung und zusätzliche Leitfäden

Beispiele solcher von einem Nutzer vorgenommenen Handlungen sind die Durchführung von Bedienhandlungen, Konfigurationsänderungen im Automatisierungssystem, Erzeugung von Informationen, Senden einer Nachricht, Bestätigen einer Information (z. B. Zustimmung signalisieren) und Empfangen einer Nachricht. Die Nichtabstreitbarkeit schützt vor späteren falschen Behauptungen eines Nutzers, eine bestimmte Handlung nicht vorgenommen zu haben, eines Autors, ein bestimmtes Dokument nicht geschrieben zu haben, eines Senders, eine Nachricht nicht übermittelt zu haben, eines Empfängers, eine Nachricht nicht erhalten zu haben, oder eines Signierers, ein Dokument nicht signiert zu haben. Nichtabstreitbarkeitsdienste können verwendet werden, um festzustellen, ob eine Information von einem bestimmten Nutzer stammt, ob ein Nutzer bestimmte Handlungen vorgenommen hat (z. B. eine E-Mail gesendet und einen Arbeitsauftrag bestätigt hat) oder bestimmte Informationen erhalten hat. Nichtabstreitbarkeitsdienste werden mit verschiedenen Techniken erreicht (z. B. Identifizierung und Autorisierung von Nutzern, digitale Signaturen, digitale Empfangsquittung einer Nachricht und Zeitstempel).

6.14.3 Weitergehende Anforderungen

(1) Nichtabstreitbarkeit für alle Nutzer

Die Komponenten müssen die Fähigkeit haben festzustellen, ob ein bestimmter Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) eine bestimmte Handlung vorgenommen hat.

6.14.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 2.12 beziehen, sind:

- SL-C(UC,Komponente) 1: CR 2.12;
- SL-C(UC,Komponente) 2: CR 2.12;
- SL-C(UC,Komponente) 3: CR 2.12;
- SL-C(UC,Komponente) 4: CR 2.12 (1).

6.15 CR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen

Die Anforderungen an die Nutzung von physikalischen Diagnose- und Prüfschnittstellen sind komponentenspezifisch und können als Anforderungen für jede spezifische Komponentenart in den [Abschnitten 12 bis 15](#) angegeben werden.

7 FR 3 – Systemintegrität

7.1 Zweck und Beschreibungen der SL-C(SI)

Die Integrität der Komponente sicherstellen, um nicht autorisierte Manipulation oder Modifizierung zu verhindern.

- SL 1 – Schützen der Integrität des IACS gegen gelegentliche oder zufällige Manipulation.

- SL 2 – Schützen der Integrität des IACS gegen Manipulation durch Personen oder Stellen, die mit einfachen Mitteln, geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen.
- SL 3 – Schützen der Integrität des IACS gegen Manipulation durch Personen oder Stellen, die mit raffinierten Mitteln, mittleren Ressourcen, IACS-spezifischen Fertigkeiten und mittlerer Motivation vorgehen.
- SL 4 – Schützen der Integrität des IACS gegen Manipulation durch Personen oder Stellen, die mit raffinierten Mitteln, erheblichen Ressourcen, IACS-spezifischen Fertigkeiten und hoher Motivation vorgehen.

7.2 Begründung

Komponenten werden meist mehreren Prüfphasen unterzogen (Stückprüfung, Systemprüfung usw.), um noch vor Produktionsaufnahme festzustellen, dass sich die Komponenten bestimmungsgemäß verhalten. Nach Betriebsbeginn sind die Betreiber für die Aufrechterhaltung der Integrität der Komponente verantwortlich. Mittels ihrer Risikobeurteilung können Betreiber unterschiedlichen Komponenten, Kommunikationskanälen und Informationen in ihrem IACS unterschiedliche Stufen des Integritätsschutzes zuweisen. Die Integrität der physikalischen Betriebsmittel sollte sowohl im Betriebszustand als auch in Nicht-Betriebszuständen aufrechterhalten werden, z. B. während der Produktion, im Lager oder wenn die Anlage zum Zwecke der Instandhaltung heruntergefahren wurde. Die Integrität der logischen Betriebsmittel sollte bei deren Übertragung und Speicherung aufrechterhalten werden, z. B. bei der Übertragung über ein Netzwerk oder bei der Ablage in einem Datenbestand.

7.3 CR 3.1 – Kommunikationsintegrität

7.3.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, die Integrität der übertragenen Information zu schützen.

7.3.2 Begründungen und zusätzliche Leitfäden

Bei vielen gängigen Angriffen auf Netzwerke werden übertragene Daten manipuliert, z. B. Datenpakete. Netzwerke mit Switches oder Routern bieten Angreifern noch mehr Gelegenheit, Pakete zu manipulieren, da der unerkannte Zugriff auf solche Netzwerke im Allgemeinen leicht ist und die Switching- und Routing-Mechanismen selbst manipuliert werden können, um so noch mehr Zugriffsmöglichkeiten auf die übertragenen Information zu erhalten. Eine Manipulation in einem Automatisierungssystem könnte beispielsweise eine Änderung von Messwerten sein, die von einem Sensor zu einem Empfänger übertragen werden, oder die Veränderung von Stellgrößenwerten, die eine Regelung an ein Stellglied sendet.

Je nach Gegebenheit (z. B. Übertragung über einen lokalen Netzwerkabschnitt gegenüber einer Übertragung über ein nicht vertrauenswürdiges Netzwerk) und der für die Übertragung verwendeten Netzwerktechnik (z. B. TCP/IP gegenüber einer lokalen seriellen Verbindung) werden unterschiedlich umsetzbare und geeignete Techniken verwendet. In einem kleinen Netzwerk mit direkten (Punkt-zu-Punkt-)Verbindungen kann ein physikalischer Zugriffsschutz an allen Knoten für niedrige Security-Level ausreichend sein, wenn die Integrität der Endpunkte ebenfalls geschützt wird (siehe 7.6), während in Netzwerken, die in Bereichen aufgebaut sind, in denen regelmäßig Personal anwesend ist, oder in einem WAN ein physikalischer Zugriffsschutz kaum durchsetzbar ist. Falls für die Erbringung eines Kommunikationsdienstes anstelle eines dafür vollständig ausgerichteten Dienstes ein kommerzieller Dienstleister in Anspruch genommen wird, der seine Dienste wie ein Massenprodukt anbietet, (z. B. Mietleitung gegenüber einer T1-Verbindung), kann es noch schwieriger werden, die erforderlichen Zusicherungen hinsichtlich der Umsetzung der benötigten Maßnahmen zur Kommunikationsintegrität zu erlangen (z. B. wegen rechtlicher Beschränkungen). Sollte es nicht machbar oder unmöglich sein, die bestehenden IT-Sicherheitsanforderungen einzuhalten, dann könnte es angebracht sein, geeignete Ausgleichsmaßnahmen zu ergreifen oder das zusätzliche Risiko ausdrücklich zu akzeptieren.

Industrieeinrichtungen sind häufig Umweltbedingungen ausgesetzt, die eine Beeinträchtigung der Integrität oder Fehlalarme bewirken können. In der Umwelt liegen häufig Partikel, Flüssigkeiten, Schwingungen, Gase, Abstrahlung und elektromagnetische Störungen vor, die die Integrität der Kommunikationskabel und -signale

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12 EN IEC 62443-4-2:2019

stören können. Die Netzinfrastruktur sollte so ausgelegt werden, dass diese physikalischen Einflüsse/Umwelteinflüsse einen möglichst geringen Einfluss auf die Kommunikationsintegrität haben. Wenn z. B. die Anwesenheit von Partikeln, Flüssigkeiten und/oder Gasen anzunehmen ist, könnte es erforderlich sein, für Leitungen abgedichtete RJ-45-Buchsen oder M12-Steckverbinder anstelle handelsüblicher RJ-45 Buchsen zu verwenden. Das Kabel selbst muss unter Umständen einen anderen Mantel haben, um den Partikeln, Flüssigkeiten und/oder Gasen standzuhalten. Im Falle von Schwingungsbeanspruchungen könnten M12-Steckverbinder nötig sein, damit die Federlasche eines RJ-45-Steckers nicht während des Betriebs ausgerastet wird. Sofern Abstrahlung und/oder elektromagnetische Störungen besonders zu beachten sind, könnte es erforderlich sein, geschirmte Kabel mit verdrehten Aderpaaren oder Glasfaserkabel einzusetzen, um Auswirkungen auf die Kommunikationssignale zu verhindern. Falls der Aufbau eines Funknetzes geplant wird, könnte es notwendig werden, das Funkspektrum in der betreffenden Gegend zu analysieren, um zu bestätigen, dass dies eine machbare Lösung ist.

7.3.3 Weitergehende Anforderungen

(1) Authentifikation der Kommunikation

Die Komponenten müssen die Fähigkeit haben, die Information während der Kommunikation zu authentifizieren.

ANMERKUNG Sowohl der Integritätsschutz als auch die Authentifizierung der Ursprungsstelle können ohne Gewährleistung des Schutzes der Vertraulichkeit erreicht werden.

7.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 3.1 beziehen, sind:

- SL-C(SI,Komponente) 1: CR 3.1;
- SL-C(SI,Komponente) 2: CR 3.1 (1);
- SL-C(SI,Komponente) 3: CR 3.1 (1);
- SL-C(SI,Komponente) 4: CR 3.1 (1).

7.4 CR 3.2 – Schutz vor Schadcodes

Die Anforderungen an den Schutz vor Schadcodes sind komponentenspezifisch und können als Anforderungen für jede spezifische Komponententart in den [Abschnitten 12 bis 15](#) angegeben werden.

7.5 CR 3.3 – Verifikation der IT-Sicherheitsfunktionalität

7.5.1 Anforderung

Komponenten müssen die Fähigkeit haben, die Verifikation des vorgesehenen Betriebs von IT-Sicherheitsfunktionen nach IEC 62443-3-3 SR3.3 zu unterstützen.

7.5.2 Begründungen und zusätzliche Leitfäden

Der Hersteller und/oder der Systemintegrator sollten Anleitungen zur Prüfung der vorgesehenen IT-Sicherheitsmaßnahmen liefern. Betreiber müssen sich der möglichen Auswirkungen bewusst sein, die diese Prüfungen während des normalen Betriebs haben können. Einzelheiten zur Durchführung dieser Prüfungen müssen unter sorgfältiger Berücksichtigung der geforderten Aufrechterhaltung des laufenden Betriebs festgelegt werden (z. B. Ablaufplanung, vorherige Ankündigung der Prüfungen).

Beispiele für die Verifikation der IT-Sicherheitsfunktionen sind:

- Verifikation der Antivirus-Maßnahmen durch Prüfungen des Dateisystems des Automatisierungssystems anhand der vom European Institute for Computer Anti-Virus Research e.V. (EICAR) bereitgestellten Prüfdateien. Die Antivirussoftware sollte das EICAR-Prüfmuster entdecken und es sollte ein geeignetes Vorgehen zur Behandlung dieses Vorgangs veranlasst werden.

- Verifikation der Maßnahmen zur Identifizierung, Authentifikation und Nutzungskontrolle durch Zugriffsversuche von einem nicht autorisierten Nutzerkonto (für gewisse Funktionalitäten könnte dies automatisiert durchgeführt werden).
- Verifikation des IDS als eine IT-Sicherheitsmaßnahme, indem im IDS eine Regel vorgesehen wird, die bei einem irregulären, aber bekannt nicht bösartigen Verkehr Alarm auslöst. Die Prüfung kann dann ausgeführt werden, indem ein Verkehr herbeigeführt wird, der diese Regel auslöst und damit eine angemessene Überwachung durch das IDS und das Vorgehen zur Behandlung dieses Vorfalls herbeiführt.
- Bestätigung, dass die Ereignisprotokolle wie von den IT-Sicherheitsleitlinien und -vorgehensweisen vorgesehen geführt werden und ihre Aufzeichnung nicht durch eine interne oder externe Einheit außer Kraft gesetzt wurde.

7.5.3 Weitergehende Anforderungen

(1) Verifikation der IT-Sicherheitsfunktionalität im laufenden Betrieb

Die Komponenten müssen die Fähigkeit haben, die Verifikation des bestimmungsgemäßen Betriebs der IT-Sicherheitsfunktionen im laufenden Betrieb zu unterstützen.

Diese RE muss sorgfältig umgesetzt werden, um nachteilige Folgen zu vermeiden. Sie ist für sicherheitsbezogene Systeme unter Umständen nicht geeignet.

7.5.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 3.3 beziehen, sind:

- SL-C(SI,Komponente) 1: CR 3.3;
- SL-C(SI,Komponente) 2: CR 3.3;
- SL-C(SI,Komponente) 3: CR 3.3;
- SL-C(SI,Komponente) 4: CR 3.3 (1).

7.6 CR 3.4 – Software- und Informationsintegrität

7.6.1 Anforderung

Komponenten müssen die Fähigkeit haben, Integritätsprüfungen der Software, der Konfiguration und anderer Informationen sowie die Aufzeichnung der Ergebnisse dieser Prüfungen durchzuführen oder zu unterstützen, oder sie müssen in ein System integriert werden, das Integritätsprüfungen durchführen oder unterstützen kann.

7.6.2 Begründungen und zusätzliche Leitfäden

Verfahren zur Integritätsverifikation werden eingesetzt, um die Manipulation von Software und Informationen, welche nach Umgehung anderer Schutzmechanismen (wie z. B. Durchsetzung der Autorisierung) auftreten kann, zu erkennen, aufzuzeichnen, zu melden und dagegen zu schützen. Die Komponenten sollten formale oder empfohlene Integritätsmechanismen (wie kryptografische Hash-Funktionen) einsetzen. Beispielsweise könnten solche Mechanismen zur Überwachung des aktuellen Konfigurationsstandes von Feldgeräten verwendet werden, um IT-Sicherheitsverstöße (einschließlich nicht autorisierter Änderungen) zu erkennen.

7.6.3 Weitergehende Anforderungen

(1) Authentizität der Software und der Informationen

Komponenten müssen die Fähigkeit haben, Authentizitätsprüfungen der Software, der Konfiguration und anderer Informationen sowie die Aufzeichnung der Ergebnisse dieser Prüfungen durchzuführen oder zu unterstützen, oder sie müssen in ein System integriert werden, das Authentizitätsprüfungen durchführen oder unterstützen kann.

(2) Automatisierte Meldung von IT-Sicherheitsverstößen

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12

EN IEC 62443-4-2:2019

Wenn die Komponente Integritätsprüfungen durchführt, muss sie die Fähigkeit haben, selbsttätig Meldungen an eine konfigurierbare Einheit über erkannte Versuche einer nicht autorisierten Änderung zu übermitteln.

7.6.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 3.4 beziehen, sind:

- SL-C(SI,Komponente) 1: CR 3.4;
- SL-C(SI,Komponente) 2: CR 3.4 (1);
- SL-C(SI,Komponente) 3: CR 3.4 (1) (2);
- SL-C(SI,Komponente) 4: CR 3.4 (1) (2).

7.7 CR 3.5 – Eingabevalidierung

7.7.1 Anforderung

Die Komponenten müssen Syntax, Länge und Inhalt von jeder Eingabe, die als Eingabedaten für das Automatisierungssystem verwendet werden, oder von Eingaben über externe Schnittstellen, die unmittelbare Auswirkungen auf die Aktionen der Komponente haben, validieren.

7.7.2 Begründungen und zusätzliche Leitfäden

Es sollten Regeln für die Überprüfung der gültigen Syntax von Eingabedaten vorliegen, um nachzuweisen, dass diese Informationen nicht manipuliert wurden und der Spezifikation entsprechen. Eingaben in weiterverarbeitende Programme sollten vorgeprüft werden, um zu vermeiden, dass deren Inhalt unabsichtlich als Befehle interpretiert wird. Es wird darauf hingewiesen, dass dies eine IT-Sicherheitsanforderung an die Komponente (CR) ist und damit keine menschlichen Fehlhandlungen betrifft, z. B. die Angabe einer legitimen ganzzahligen Variablen, die außerhalb des erwarteten Bereichs liegt.

Zu den in der industriellen Praxis allgemein anerkannten Gepflogenheiten der Validierung von Eingabedaten gehören außerhalb des erwarteten Bereichs liegende Werte eines definierten Feldtyps, ungültige Zeichen in Datenfeldern, fehlende oder unvollständige Daten und Pufferüberläufe. Weitere Beispiele für ungültige Eingaben, die zu Problemen mit der IT-Sicherheit des Systems führen, sind Angriffe mit SQL-Injectionen, Cross-Site-Scripting oder ungültige Pakete (wie sie gewöhnlich durch Protokoll-Fuzzer erzeugt werden). Hierbei möglicherweise zu beachtende Anleitungen sind neben anderen der „Open Web Application Security Project (OWASP) Code Review Guide“ [\[21\]](#).

7.7.3 Weitergehende Anforderungen

Keine.

7.7.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 3.5 beziehen, sind:

- SL-C(SI,Komponente) 1: CR 3.5;
- SL-C(SI,Komponente) 2: CR 3.5;
- SL-C(SI,Komponente) 3: CR 3.5;
- SL-C(SI,Komponente) 4: CR 3.5.

7.8 CR 3.6 – Vorbestimmte Zustände der Ausgänge

7.8.1 Anforderung

Komponenten, die physisch oder logisch mit einem Automatisierungsprozess verbunden sind, müssen die Fähigkeit haben, die Ausgänge auf einen vorbestimmten Zustand zu setzen, wenn der vom Anbieter der Komponenten definierte Normalbetrieb nicht aufrechterhalten werden kann.

7.8.2 Begründungen und zusätzliche Leitfäden

Das vorbestimmte Verhalten der Ausgänge eines Automatisierungssystems als Folge von Angriffen gegen dieses ist eine wichtige Eigenschaft zur Sicherstellung der Integrität des normalen Betriebs. Idealerweise fährt das Gerät trotz eines Angriffs mit dem normalen Betrieb fort; wenn das Automatisierungssystem diesen jedoch nicht länger aufrechterhalten kann, müssen seine Ausgänge auf einen vorbestimmten Zustand zurückfallen. Der geeignete vorbestimmte Zustand des Ausgangs des Automatisierungssystems ist geräteabhängig und könnte einer der folgenden vom Nutzer konfigurierbaren Zustände sein:

- Spannungsfrei – Die Ausgänge nehmen einen spannungsfreien Zustand an.
- Halten – Die Ausgänge nehmen den letzten bekannten guten Wert an.
- Festwert – Die Ausgänge nehmen einen festen Wert an, der vom Betreiber oder einer Anwendung festgelegt wurde.
- Dynamisch – Die Ausgänge nehmen auf der Basis des gegenwärtigen Zustands eine der oben angegebenen Optionen an.

7.8.3 Weitergehende Anforderungen

Keine.

7.8.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 3.6 beziehen, sind:

- SL-C(SI,Komponente) 1: CR 3.6;
- SL-C(SI,Komponente) 2: CR 3.6;
- SL-C(SI,Komponente) 3: CR 3.6;
- SL-C(SI,Komponente) 4: CR 3.6.

7.9 CR 3.7 – Fehlerbehandlung

7.9.1 Anforderung

Die Komponenten müssen Fehlerbedingungen auf eine Weise identifizieren und behandeln, die keine Informationen liefert, die von Gegnern zum Angriff auf das IACS ausgenutzt werden könnten.

7.9.2 Begründungen und zusätzliche Leitfäden

Die Struktur und der Inhalt von Fehlermeldungen sollten vom Hersteller und/oder Systemintegrator sorgfältig bedacht werden. Von der Komponente erzeugte Fehlermeldungen sollten zeitnahe und nützliche Informationen liefern, ohne möglicherweise gefährliche Informationen offenzulegen, die von Gegnern zum Angriff auf das IACS verwendet werden können. Eine Offenlegung dieser Informationen sollte durch die Notwendigkeit einer rechtzeitigen Klärung der Fehlzustände gerechtfertigt sein. Hierbei zu beachtende Anleitungen sind neben anderen der OWASP Code Review Guide [\[21\]](#).

Ein gutes Beispiel für eine Fehlermeldung, die Gegnern helfen könnte, ein IACS anzugreifen, wäre die Angabe von Einzelheiten über den Grund, aus dem die Authentifikation im System fehlgeschlagen ist.

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12
EN IEC 62443-4-2:2019

Beispielsweise würde die Angabe eines ungültigen Nutzers oder ungültigen Passworts in der Rückmeldung einem Gegner helfen, das IACS anzugreifen, und sollte deshalb nicht erfolgen.

7.9.3 Weitergehende Anforderungen

Keine.

7.9.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 3.7 beziehen, sind:

- SL-C(SI,Komponente) 1: CR 3.7;
- SL-C(SI,Komponente) 2: CR 3.7;
- SL-C(SI,Komponente) 3: CR 3.7;
- SL-C(SI,Komponente) 4: CR 3.7.

7.10 CR 3.8 – Sitzungsintegrität**7.10.1 Anforderung**

Die Komponenten müssen Mechanismen zum Schutz der Integrität von Kommunikationssitzungen bereitstellen, einschließlich:

- a) der Fähigkeit, die Gültigkeit von Sitzungskennungen nach der Abmeldung durch den Nutzer oder einer andersgearteten Sitzungsbeendigung (einschließlich Browser-Sitzungen) aufzuheben;
- b) der Fähigkeit, eine eindeutige Sitzungskennung für jede Sitzung zu erzeugen und nur Sitzungskennungen anzuerkennen, die vom System erzeugt wurden; und
- c) der Fähigkeit, eindeutige Sitzungskennungen anhand allgemein anerkannter Verfahren zur Erzeugung von Zufallszahlen zu erzeugen.

7.10.2 Begründungen und zusätzliche Leitfäden

Diese Maßnahme richtet sich auf den Schutz der Kommunikation in der Ebene der Sitzungen und nicht auf die Übertragung der Pakete. Mit dieser Maßnahme soll an jedem Ende einer Kommunikationssitzung eine Vertrauensbasis in die Aufrechterhaltung der Identität der anderen Stelle und die Gültigkeit der übertragenen Informationen geschaffen werden. Diese Maßnahme richtet sich beispielsweise gegen Man-in-the-Middle-Angriffe einschließlich Sitzungsübernahme, Einspeisung falscher Informationen in eine Sitzung oder Replay-Angriffe. Der Einsatz von Mechanismen zur Bewahrung der Sitzungsintegrität kann zu einem erheblichen Verwaltungsaufwand führen und sollte daher im Lichte der Anforderungen an eine Echtzeitkommunikation betrachtet werden.

Für die Übernahme von Sitzungen und andere Man-in-the-Middle-Angriffe oder für die Einspeisung falscher Informationen machen sich Angreifer häufig leicht zu erratende Sitzungskennungen (Schlüssel oder andere gemeinsame Geheimnisse) zu Nutze oder verwenden Sitzungskennungen, die nach Sitzungsbeendigung nicht richtig ungültig gemacht wurden. Daher sollte die Gültigkeit eines Sitzungsauthentifizierers eng an die Lebensdauer einer Sitzung geknüpft sein. Die Einbeziehung von Zufälligkeit in die Erzeugung eindeutiger Sitzungskennungen hilft, sich gegen Brute-Force-Angriffe zum Erraten zukünftiger Sitzungskennungen zu schützen.

7.10.3 Weitergehende Anforderungen

Keine.

7.10.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 3.8 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: CR 3.8;
- SL-C(SI,Komponente) 3: CR 3.8;
- SL-C(SI,Komponente) 4: CR 3.8.

7.11 CR 3.9 – Schutz von Prüfinformationen

7.11.1 Anforderung

Komponenten müssen Prüfinformationen, Prüfaufzeichnungen und Prüfwerkzeuge (soweit vorhanden) vor nicht autorisiertem Zugriff, Änderung und Löschung schützen.

7.11.2 Begründungen und zusätzliche Leitfäden

Zu den Prüfinformationen zählen alle Informationen (z. B. Ereignisdatensätze, Prüfeinstellungen und Prüfaufzeichnungen), die für eine erfolgreiche Prüfung der Aktivität eines Automatisierungssystems benötigt werden. Die Prüfinformationen sind wichtig für Fehlerkorrektur, Wiederherstellung nach IT-Sicherheitsverstößen, Untersuchungen und damit zusammenhängenden Bemühungen. Zu Mechanismen für einen vereinfachten Schutz gegen Modifikation und Löschung gehört die Speicherung der Prüfinformationen auf nur einmal beschreibbaren Hardware-gebundenen Speichermedien.

7.11.3 Weitergehende Anforderungen

- (1) Ereignisdatensätze auf nur einmal beschreibbaren Speichermedien

Komponenten müssen die Fähigkeit haben, Ereignisdatensätze auf nur einmal beschreibbaren und Hardware-gebundenen Speichermedien zu speichern.

7.11.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 3.9 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: CR 3.9;
- SL-C(SI,Komponente) 3: CR 3.9;
- SL-C(SI,Komponente) 4: CR 3.9 (1).

7.12 CR 3.10 – Unterstützung von Updates

Die Anforderungen an das Update-Management sind komponentenspezifisch und können als Anforderungen für jede spezifische Geräteart in den [Abschnitten 12 bis 15](#) angegeben werden.

7.13 CR 3.11 – Physikalische Manipulationssicherheit und -erkennung

Die Anforderungen an die physikalische Manipulationssicherheit und -erkennung sind komponentenspezifisch und können als Anforderungen für jede spezifische Geräteart in den [Abschnitten 12 bis 15](#) angegeben werden.

7.14 CR 3.12 – Bereitstellung von Hersteller-Vertrauensankern

Die Anforderungen an die Bereitstellung von Hersteller-Vertrauensankern sind komponentenspezifisch und können als Anforderungen für jede spezifische Geräteart in den [Abschnitten 12 bis 15](#) angegeben werden.

7.15 CR 3.13 – Bereitstellung von Betreiber-Vertrauensankern

Die Anforderungen an die Bereitstellung von Betreiber-Vertrauensankern sind komponentenpezifisch und können als Anforderungen für jede spezifische Geräteart in den [Abschnitten 12 bis 15](#) angegeben werden.

7.16 CR 3.14 – Integrität von Boot-Prozessen

Die Anforderungen an die Integrität von Boot-Prozessen sind komponentenpezifisch und können als Anforderungen für jede spezifische Geräteart in den [Abschnitten 12 bis 15](#) angegeben werden.

8 FR 4 – Vertraulichkeit der Daten

8.1 Zweck und Beschreibungen der SL-C(DC)

Die Vertraulichkeit der Informationen in Kommunikationskanälen und Datenspeichern wird sichergestellt, um sich vor jeder unbefugten Offenlegung zu schützen.

- SL 1 – Verhindern der nicht autorisierten Offenlegung von Informationen durch Abhören oder zufälliges Aufdecken.
- SL 2 – Verhindern der nicht autorisierten Offenlegung von Informationen an eine danach aktiv mit einfachen Mitteln bei geringem Aufwand, allgemeinen Fertigkeiten und geringer Motivation suchende Einheit.
- SL 3 – Verhindern der nicht autorisierten Offenlegung von Informationen an eine danach aktiv mit raffinierten Mitteln und moderatem Aufwand, IACS-spezifischen Fertigkeiten und mittlerer Motivation suchende Einheit.
- SL 4 – Verhindern der nicht autorisierten Offenlegung von Informationen an eine danach aktiv mit raffinierten Mitteln und erheblichem Aufwand, IACS-spezifischen Fertigkeiten und hoher Motivation suchende Einheit.

8.2 Begründung

Einige von Komponenten erzeugte Informationen, sowohl bei der Speicherung als auch bei der Übertragung, sind von vertraulicher oder sensibler Natur. Dies hat zur Folge, dass einige Kommunikationskanäle und Datenbestände Schutz gegen Abhören und nicht autorisierten Zugriff benötigen.

8.3 CR 4.1 – Vertraulichkeit von Informationen

8.3.1 Anforderung

Komponenten müssen

- a) die Fähigkeit haben, die Vertraulichkeit von ruhenden Informationen zu schützen, für die ausdrücklich eine Leseberechtigung vorgesehen ist, und
- b) den Schutz der Vertraulichkeit von Informationen bei der Übertragung nach IEC 62443-3-3 SR 4.1 unterstützen.

8.3.2 Begründungen und zusätzliche Leitfäden

Die Entscheidung, ob eine bestimmte Information geschützt werden sollte oder nicht, hängt vom Zusammenhang ab und kann nicht schon während der Produktentwicklung getroffen werden. Jedoch kann der Umstand, dass eine Organisation den Zugriff auf eine Information durch das Einrichten ausdrücklicher Leseberechtigungen im Automatisierungssystem beschränkt, als ein Indikator dafür angesehen werden, dass diese Information von der Organisation als vertraulich eingestuft werden sollte. Somit sollten alle Informationen, für die die Komponente die Fähigkeit der Einrichtung ausdrücklicher Leseberechtigungen vorsieht, als potenziell vertraulich eingestuft werden, und die Komponente sollte daher die Fähigkeit haben, diese zu schützen.

Die Vertraulichkeit von Informationen bei der Übertragung erfordert Fähigkeiten auf der Systemebene, die die Komponente unterstützen sollte.

Für den Schutz der Vertraulichkeit gibt 8.5 weitere Informationen.

8.3.3 Weitergehende Anforderungen

Keine.

8.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 4.1 beziehen, sind:

- SL-C(DC,Komponente) 1: CR 4.1;
- SL-C(DC,Komponente) 2: CR 4.1;
- SL-C(DC,Komponente) 3: CR 4.1;
- SL-C(DC,Komponente) 4: CR 4.1.

8.4 CR 4.2 – Dauerhaftigkeit von Informationen

8.4.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, wenn sie außer Betrieb genommen und/oder stillgelegt werden, alle Informationen, für die eine ausdrückliche Leseberechtigung vorgesehen war, zu löschen.

8.4.2 Begründungen und zusätzliche Leitfäden

Die Entfernung einer Komponente des Automatisierungssystems aus dem aktiven Betrieb sollte keine Gelegenheit für eine unbeabsichtigte Freigabe von Informationen, für die eine ausdrückliche Leseberechtigung gefordert war, bieten. Ein Beispiel für solche Informationen können Authentifizierungsinformationen und Netzwerkkonfigurationsinformationen sein, die in einem nicht-flüchtigen Speicher aufbewahrt werden, oder andere kryptografische Informationen, die nicht autorisierte oder bösartige Handlungen erleichtern würden.

Durch Handlungen eines Nutzers oder einer Rolle erzeugte Information (oder im Namen eines Nutzers oder einer Rolle ausgeführte Handlungen eines Softwareprozesses) sollten gegenüber einem anderen Nutzer oder einer anderen Rolle nicht auf eine unkontrollierte Art und Weise offengelegt werden. Die Beschränkung von Informationen über das Automatisierungssystem oder der Dauerhaftigkeit von Daten verhindert, dass Informationen, die in einer gemeinsam genutzten Ressource gespeichert sind, unbeabsichtigt offengelegt werden, nachdem diese Ressource wieder für das Automatisierungssystem freigegeben wurde.

8.4.3 Weitergehende Anforderungen

(1) Löschen gemeinsam genutzter Speicherressourcen

Die Komponenten müssen die Fähigkeit haben, sich gegen eine nicht autorisierte und unbeabsichtigte Informationsübertragung über flüchtige, gemeinsam genutzte Speichermittel zu schützen.

Flüchtige Speicherressourcen sind solche, in denen üblicherweise keine zuvor gespeicherten Informationen verbleiben, nachdem sie an das Speichermanagement zurücksendet wurden. Es kann jedoch Angriffe gegen RAM-Speicher geben, die möglicherweise Informationen über Schlüssel oder andere vertrauliche Daten extrahieren, bevor sie wirklich überschrieben werden. Daher ist es allgemein übliche Praxis, alle eindeutigen Daten und Verbindungen zu einzelnen Daten in einem flüchtigen, gemeinsam genutzten Speicher zu löschen, wenn dieser zur Verwendung durch einen anderen Nutzer freigegeben und an das Automatisierungssystem zurückgegeben wird, damit diese Daten für den neuen Nutzer nicht sichtbar und auch nicht zugänglich sind.

(2) Verifikation der Löschung

Die Komponenten müssen die Fähigkeit haben nachzuweisen, dass die Löschung von Informationen durchgeführt wurde.

8.4.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 4.2 beziehen, sind:

- SL-C(DC,Komponente) 1: keine;
- SL-C(DC,Komponente) 2: CR 4.2;
- SL-C(DC,Komponente) 3: CR 4.2 (1) (2);
- SL-C(DC,Komponente) 4: CR 4.2 (1) (2).

8.5 CR 4.3 – Verwendung von Verschlüsselung

8.5.1 Anforderung

Falls eine Verschlüsselung gefordert ist, muss die Komponente kryptografische Sicherheitsmechanismen nach den in der Informationstechnik allgemein anerkannten IT-Sicherheitsgepflogenheiten und -empfehlungen verwenden.

8.5.2 Begründungen und zusätzliche Leitfäden

Die Auswahl des Verschlüsselungsschutzes sollte auf einer Bedrohungs- und Risikoanalyse beruhen, die dem Wert der zu schützenden Information, den Auswirkungen des Bruchs ihrer Vertraulichkeit, der Dauer ihrer Vertraulichkeit und den Einschränkungen von Seiten des Automatisierungssystems entspricht. Dies kann ruhende Informationen und/oder Informationen bei der Übertragung betreffen. Es wird darauf hingewiesen, dass auch Sicherungskopien ein Beispiel für ruhende Informationen sind und daher bei der Beurteilung der erforderlichen Datenvertraulichkeit und Integrität mit beachtet werden sollten. Der Hersteller des Automatisierungssystems sollte die Verfahren für die kryptografische Schlüsselerstellung und die Schlüsselverwaltung dokumentieren. Das Automatisierungssystem sollte eingeführte und geprüfte Verschlüsselungs- und Hash-Algorithmen wie AES (en: advanced encryption standard) und SHA (en: secure hash algorithm) einsetzen und Schlüsselgrößen entsprechend eines bestimmten Standards verwenden. Zur Schlüsselerzeugung ist ein wirkungsvoller Zufallszahlengenerator erforderlich. IT-Sicherheitsleitlinien und -vorgehensweisen der Schlüsselverwaltung müssen periodische Schlüsseländerungen, Schlüsselzerstörung, Schlüsselverteilung und deren Sicherungskopien entsprechend zutreffender Normen vorsehen. Allgemein anerkannte Verfahren und Empfehlungen können in Dokumenten wie z. B. NIST SP 800-57, *Recommendation for Key Management – Part 1: General* [18] gefunden werden. Die Implementierungsanforderungen können z. B. in FIPS 140-2, *Security Requirements for Cryptographic Modules* [17] oder ISO/IEC 19790 [9] gefunden werden.

Diese CR darf zusammen mit 5.10, CR 1.8 – PKI-Zertifikate, angewendet werden, um viele in diesem Dokument definierte weitere Anforderungen zu erfüllen.

8.5.3 Weitergehende Anforderungen

Keine.

8.5.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 4.3 beziehen, sind:

- SL-C(DC,Komponente) 1: CR 4.3;
- SL-C(DC,Komponente) 2: CR 4.3;
- SL-C(DC,Komponente) 3: CR 4.3;
- SL-C(DC,Komponente) 4: CR 4.3.

9 FR 5 – Eingeschränkter Datenfluss

9.1 Zweck und Beschreibungen der SL-C(RDF)

Das Automatisierungssystem in Zonen und Conduits aufteilen, um einen unnötigen Datenfluss zu verhindern.

- SL 1 – Verhindern der gelegentlichen oder zufälligen Umgehung der Aufteilung in Zonen und Conduits.
- SL 2 – Verhindern der absichtlichen Umgehung der Aufteilung in Zonen und Conduits durch Einheiten, die mit einfachen Mitteln, geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen.
- SL 3 – Verhindern der absichtlichen Umgehung der Aufteilung in Zonen und Conduits durch Einheiten, die mit raffinierten Mitteln, mittleren Ressourcen, IACS-spezifischen Fertigkeiten und mittlerer Motivation vorgehen.
- SL 4 – Verhindern der absichtlichen Umgehung der Aufteilung in Zonen und Conduits durch Einheiten, die mit raffinierten Mitteln, erheblichen Ressourcen, IACS-spezifischen Fertigkeiten und hoher Motivation vorgehen.

9.2 Begründung

Anhand einer Risikobeurteilung nach IEC 62443-3-2 [5], sollten Betreiber die notwendigen Einschränkungen des Informationsflusses bestimmen und damit folglich auch die Einrichtung der zur Übermittlung dieser Informationen benutzten Conduits festlegen. Hieraus abgeleitete Empfehlungen und Leitlinien sollten Mechanismen enthalten, die von der Trennung der Automatisierungssysteme von kommerziellen oder öffentlichen Netzwerken bis zur Verwendung unidirektionaler Gateways, einzelner zustandsorientierter Firewalls oder DMZ-Konfigurationen reichen, um so den Informationsfluss zu lenken.

9.3 CR 5.1 – Netzaufteilung

9.3.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, nach Bedarf die Zonen und Conduits eines abgeteilten Netzwerks zu unterstützen, um eine breitete Netzwerkarchitektur auf der Basis einer logischen Aufteilung und Kritikalität zu unterstützen.

9.3.2 Begründungen und zusätzliche Leitfäden

Die Netzaufteilung wird von Organisationen für eine Vielzahl von Zwecken verwendet, einschließlich der IT-Sicherheit. Die Hauptgründe für die Aufteilung von Netzwerken sind die Verringerung der Exposition oder des Eindringens von Netzwerkverkehr in ein Steuerungssystem und die Verringerung der Streuung oder des Austritts von Netzwerkverkehr aus einem Steuerungssystem. Dies verbessert die allgemeine Reaktion und Zuverlässigkeit des Systems und bietet ein gewisses Maß an Schutz für die IT-Sicherheit. Es ermöglicht auch die Aufteilung verschiedener Netzwerksegmente innerhalb des Automatisierungssystems von anderen Systemen, einschließlich kritischer Automatisierungssysteme und sicherheitsrelevanter Systeme, um ein zusätzliches Schutzniveau zu erreichen.

Der Zugriff vom Steuerungssystem auf das World Wide Web sollte anhand der betrieblichen Anforderungen des Steuerungssystems eindeutig gerechtfertigt sein.

Die Netzwerkaufteilung und dessen Schutzniveau hängen stark von der gesamten Netzwerkarchitektur ab, die von einem Betreiber in seiner Einrichtung und sogar von Systemintegratoren in deren Steuerungssystemen verwendet wird. Das logische Segmentieren von Netzwerken auf der Grundlage ihrer Funktionalität stellt eine Schutzmaßnahme dar, kann aber dennoch zu einzelnen Fehlerpunkten führen, wenn eine Netzwerkkomponente kompromittiert wird. Die physische Segmentierung von Netzwerken bietet ein weiteres Schutzniveau, indem dieser Fall eines einzelnen Fehlerpunkts beseitigt wird. Dies führt jedoch zu einem komplexeren und kostenintensiverem Netzwerkentwurf. Diese Abwägungen müssen während des Prozesses des Netzwerkentwurfs bewertet werden (siehe IEC 62443-2-1 [1]).

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12 EN IEC 62443-4-2:2019

Bei der Reaktion auf einen Vorfall kann es erforderlich sein, die Verbindungen zwischen verschiedenen Netzwerksegmenten zu unterbrechen. In diesem Fall sollten die Dienste, die zur Unterstützung wesentlicher Betriebsabläufe erforderlich sind, so aufrechterhalten werden, dass die Geräte weiterhin ordnungsgemäß funktionieren und/oder ordnungsgemäß heruntergefahren werden können. Dies erfordert möglicherweise, dass einige Server im Netzwerk des Steuerungssystems dupliziert werden müssen, um die normalen Netzwerkfunktionen zu unterstützen, z. B. DHCP (en: dynamic host onfiguration protocol), DNS (en: domain name service) oder lokale CA. Dies kann auch bedeuten, dass einige kritische Steuerungssysteme und sicherheitsbezogene Systeme von Anfang an so konzipiert werden, dass sie vollständig von anderen Netzwerken isoliert sind.

9.3.3 Weitergehende Anforderungen

Keine.

9.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 5.1 beziehen, sind:

- SL-C(RDF,Komponente) 1: CR 5.1;
- SL-C(RDF,Komponente) 2: CR 5.1;
- SL-C(RDF,Komponente) 3: CR 5.1;
- SL-C(RDF,Komponente) 4: CR 5.1.

9.4 CR 5.2 – Schutz der Zonengrenze

Die Anforderungen an den Schutz der Zonengrenze sind von der Netzwerkkomponente abhängig und können als Anforderungen an Netzwerkkomponenten in [Abschnitt 15](#) angegeben werden.

9.5 CR 5.3 – Allgemeine Beschränkung der persönlichen Kommunikation

Die Anforderungen an die allgemeine Beschränkung der persönlichen Kommunikation sind von der Netzwerkkomponente abhängig und können als Anforderungen an Netzwerkkomponenten in [Abschnitt 15](#) angegeben werden.

9.6 CR 5.4 – Partitionierung von Anwendungen

Mit IEC 62443-3-3 SR 5.4 sind keine Anforderungen auf Komponentenebene verbunden.

10 FR 6 – Rechtzeitige Reaktion auf Ereignisse

10.1 Zweck und Beschreibungen der SL-C(TRE)

Auf Sicherheitsverletzungen wird reagiert, indem die zuständige Behörde informiert wird, der erforderliche Nachweis des Verstoßes gemeldet wird und zeitnah zur Entdeckung von Vorfällen Korrekturmaßnahmen getroffen werden.

- SL 1 – Überwachen des Betriebs der Komponente des IACS und Reagieren auf Vorfälle, sobald diese entdeckt worden sind, durch die Erfassung und Weitergabe forensischer Beweise auf Nachfrage.
- SL 2 – Überwachen des Betriebs der Komponente des IACS und Reagieren auf Vorfälle, sobald diese entdeckt worden sind, durch eine aktive Erfassung und periodische Berichte mit forensischen Beweisen.
- SL 3 – Überwachen des Betriebs der Komponente des IACS und Reagieren auf Vorfälle, sobald diese entdeckt worden sind, durch eine aktive Erfassung und Veranlassung eines Berichtes mit forensischen Beweisen an die richtigen Stellen.

- SL 4 – Überwachen des Betriebs der Komponente des IACS und Reagieren auf Vorfälle, sobald diese entdeckt worden sind, durch eine aktive Erfassung und Veranlassung eines Berichtes mit forensischen Beweisen an die richtigen Stellen in nahezu Echtzeit.

10.2 Begründung

Obwohl ein System möglicherweise in einem sicheren Zustand in Betrieb genommen wird, ist es wichtig, das System überwachen zu können, um sicherzustellen, dass es in diesem sicheren Zustand bleibt. Wenn sich ein Ereignis auf die Sicherheit eines Systems auswirkt, kann eine rechtzeitige Benachrichtigung über dieses Ereignisses entscheidend sein, um das damit verbundene Risiko zu mindern. Betreiber sollten IT-Sicherheitsrichtlinien und -vorgehensweisen sowie eindeutige Kommunikations- und Eingriffswege, die zur Reaktion auf IT-Sicherheitsverstöße benötigt werden, festlegen. Daraus abgeleitete Empfehlungen und Leitfäden sollten Mechanismen zur Erfassung, Weiterleitung, Aufbewahrung und automatischen Korrelation forensischer Beweise einschließen, um zeitnahe Maßnahmen sicherzustellen. Der Einsatz von Überwachungswerkzeugen und -techniken sollte die Leistung des Automatisierungssystems nicht nachteilig beeinflussen.

10.3 CR 6.1 – Zugriffsmöglichkeit auf Ereignisprotokolle

10.3.1 Anforderung

Die Komponenten müssen autorisierten menschlichen Nutzern und/oder Werkzeugen die Fähigkeit zur Verfügung stellen, auf Ereignisprotokolle lesend zuzugreifen.

10.3.2 Begründungen und zusätzliche Leitfäden

Die Anwendungen und Geräte dürfen Ereignisdatensätze über Ereignisse, die in dieser Anwendung oder diesem Gerät eintreten, erzeugen (siehe 6.10). Der Zugriff auf diese Ereignisprotokolle ist zum Filtern von Ereignisdatensätzen, Feststellen und Beseitigen redundanter Informationen, zur Durchsicht und zur Berichterstattung für Ermittlungen im Nachgang zu IT-Sicherheitsvorfällen erforderlich. Im Allgemeinen sollten die Auswahl der Aufzeichnungen und die Berichterstellung auf einem separaten Informationssystem durchgeführt werden. Manueller Zugriff auf die Prüfaufzeichnungen (wie Bildschirmanzeigen oder Papierausdrucke) ist zur Erfüllung der Grundforderung ausreichend, für höhere SL jedoch nicht. Zur Weitergabe der Ereignisprotokolle an Analysewerkzeuge wie SIEM wird meist ein programmierter Zugriff verwendet.

10.3.3 Weitergehende Anforderungen

(1) Programmgesteuerter Zugriff auf Ereignisprotokolle

Die Komponenten müssen mittels einer API oder dem Senden von Prüfaufzeichnungen an ein zentrales System einen programmierten Zugriff auf Prüfaufzeichnungen zur Verfügung stellen.

10.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 6.1 beziehen, sind:

- SL-C(TRE,Komponente) 1: CR 6.1;
- SL-C(TRE,Komponente) 2: CR 6.1;
- SL-C(TRE,Komponente) 3: CR 6.1 (1);
- SL-C(TRE,Komponente) 4: CR 6.1 (1).

10.4 CR 6.2 – Kontinuierliche Überwachung

10.4.1 Anforderung

Komponenten müssen die Fähigkeit haben, unter Verwendung der in der Industrie allgemein anerkannten IT-Sicherheitsgepflogenheiten und -empfehlungen den IT-Sicherheitsmechanismus kontinuierlich zu überwachen, um so IT-Sicherheitsverstöße rechtzeitig zu entdecken, einzuordnen und zu berichten.

10.4.2 Begründungen und zusätzliche Leitfäden

Die Fähigkeit zur Überwachung von Automatisierungssystem kann durch eine Vielzahl von Werkzeugen und Techniken erreicht werden (z. B. IDS, IPS, Schutzmechanismen gegen Schadcodes und Netzwerküberwachungsmechanismen). In dem Maße, wie die Angriffe immer raffinierter werden, müssen auch diese Überwachungswerkzeuge und -techniken immer raffinierter werden, z. B. durch verhaltensabhängige IDS/IPS.

Überwachungsgeräte sollten innerhalb des Automatisierungssystems an strategischen Stellen aufgebaut werden (z. B. an der Grenze einer IT-Sicherheitszone und nahe bei Server-Farmen, auf denen kritische Anwendungen laufen), um dort wichtige Informationen zu erfassen. Überwachungsmechanismen dürfen auch provisorisch an ausgewählten Orten innerhalb des Automatisierungssystems eingerichtet werden, um dort besondere Tätigkeiten zu verfolgen.

Zur Überwachung sollten auch geeignete Berichtsverfahren gehören, die eine rechtzeitige Reaktion auf Ereignisse ermöglichen. Um Berichte begrenzt und den Umfang der weitergemeldeten Informationen für die Empfänger verarbeitbar zu halten, werden häufig Verfahren wie SIEM eingesetzt, um einzelne Ereignisse in Berichten zusammenzufassen, in denen die Einzelereignisse in einen weiterreichenden Zusammenhang gestellt werden.

10.4.3 Weitergehende Anforderungen

Keine.

10.4.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 6.2 beziehen, sind:

- SL-C(TRE,Komponente) 1: keine;
- SL-C(TRE,Komponente) 2: CR 6.2;
- SL-C(TRE,Komponente) 3: CR 6.2;
- SL-C(TRE,Komponente) 4: CR 6.2.

11 FR 7 – Verfügbarkeit der Ressourcen

11.1 Zweck und Beschreibungen der SL-C(RA)

Die Verfügbarkeit der Komponenten wird bei einer Beeinträchtigung oder Blockierung wesentlicher Dienste sichergestellt.

- SL 1 – Sicherstellen, dass die Komponente unter normalen Produktionsbedingungen zuverlässig arbeitet und DoS-Situationen verhindert, die eine Einheit durch gelegentliche oder zufällige Handlungen verursacht hat.
- SL 2 – Sicherstellen, dass die Komponente unter normalen und außergewöhnlichen Produktionsbedingungen zuverlässig arbeitet und DoS-Situationen durch Einheiten verhindert, die mit einfachen Mitteln, geringen Ressourcen, allgemeinen Fertigkeiten und geringer Motivation vorgehen.
- SL 3 – Sicherstellen, dass die Komponente unter normalen, außergewöhnlichen und extremen Produktionsbedingungen zuverlässig arbeitet und DoS-Situationen durch Einheiten verhindert, die

mit raffinierten Mitteln, mittleren Ressourcen, IACS-spezifischen Fertigkeiten und mittlerer Motivation vorgehen.

- SL 4 – Sicherstellen, dass die Komponente unter normalen, außergewöhnlichen und extremen Produktionsbedingungen zuverlässig arbeitet und DoS-Situationen durch Einheiten verhindert, die mit raffinierten Mitteln, erhebliche Ressourcen, IACS-spezifischen Fertigkeiten und hoher Motivation vorgehen.

11.2 Begründung

Das Ziel dieser Reihe von CR ist es sicherzustellen, dass die Komponente gegen verschiedene Arten von DoS-Ereignissen widerstandsfähig ist. Dieses schließt die teilweise oder vollständige Nichtverfügbarkeit von Komponentenfunktionen auf verschiedenen Ebenen ein. Insbesondere sollten IT-Sicherheitsvorfälle in der Komponente keine wesentlichen Funktionen oder andere sicherheitsbezogene Funktionen beeinträchtigen.

11.3 CR 7.1 – Schutz vor Denial-of-Service-Ereignissen

11.3.1 Anforderung

Komponenten müssen die Fähigkeit haben, wesentliche Funktionen aufrechtzuerhalten, wenn sie infolge eines DoS-Ereignisses mit einem eingeschränkten Betrieb funktionieren.

11.3.2 Begründungen und zusätzliche Leitfäden

Komponenten dürfen verschiedenen Formen von DoS-Situationen ausgesetzt sein. Wenn das der Fall ist, sollte die Komponente so entworfen werden, dass wesentliche Funktionen, die für einen kontinuierlichen sicheren Betrieb notwendig sind, mit einem eingeschränkten Betrieb erhalten bleiben.

11.3.3 Weitergehende Anforderungen

(1) Verwaltung der Kommunikationslast durch eine Komponente

Die Komponenten müssen die Fähigkeit haben, die Auswirkungen von Informations- und/oder Datenüberflutung von DoS-Ereignissen zu mindern.

11.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 7.1 beziehen, sind:

- SL-C(RA,Komponente) 1: CR 7.1;
- SL-C(RA,Komponente) 2: CR 7.1 (1);
- SL-C(RA,Komponente) 3: CR 7.1 (1);
- SL-C(RA,Komponente) 4: CR 7.1 (1).

11.4 CR 7.2 – Ressourcenmanagement

11.4.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, die Verwendung von Ressourcen durch IT-Sicherheitsfunktionen zu begrenzen, um vor einer Ressourcenüberlastung zu schützen.

11.4.2 Begründungen und zusätzliche Leitfäden

Ressourcenmanagement (z. B. mittels Netzaufteilung oder Prioritätsvorgaben) hindert einen Softwareprozess niedrigerer Priorität daran, die Ausführung eines Softwareprozesses höherer Priorität zu verzögern oder das Automatisierungssystem bei der Bedienung eines solchen zu stören. So könnten beispielsweise das Auslösen von Netzwerk-Scans, das Einspielen von Sicherheits-Patches und/oder Antivirusprüfungen in

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12 EN IEC 62443-4-2:2019

einem Betriebssystem schwerwiegende Störungen des normalen Betriebs bewirken. Beschränkungen des Datenverkehrs sollten als Abhilfemaßnahme erwogen werden.

11.4.3 Weitergehende Anforderungen

Keine.

11.4.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 7.2 beziehen, sind:

- SL-C(RA,Komponente) 1: CR 7.2;
- SL-C(RA,Komponente) 2: CR 7.2;
- SL-C(RA,Komponente) 3: CR 7.2;
- SL-C(RA,Komponente) 4: CR 7.2.

11.5 CR 7.3 – Datensicherung im Automatisierungssystem (Backup)

11.5.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, bei Datensicherungsoperationen auf Systemebene (Informationen auf der Nutzer- und der Systemebene) mitzuwirken, um den Zustand der Komponente zu schützen. Der Datensicherungsprozess darf den Betrieb der Komponente nicht beeinträchtigen.

11.5.2 Begründung und zusätzliche Leitfäden

Die Verfügbarkeit aktueller Datensicherungen ist für die Wiederherstellung nach einem Ausfall des Automatisierungssystems und/oder nach dessen fehlerhafter Konfiguration unerlässlich. Durch eine Automatisierung dieser Funktion wird sichergestellt, dass alle benötigten Dateien erfasst werden und die Arbeitsbelastung des Bedieners reduziert wird.

Beim Entwurf der Fähigkeit der Datensicherung sollten die Informationen berücksichtigt werden, die in den Datensicherungen gespeichert werden. Einige dieser Informationen dürfen kryptografische Schlüssel und andere Informationen enthalten, die durch IT-Sicherheitsmaßnahmen geschützt werden, während sie Teil des Systems sind. Wird die Information in einer Datensicherung gespeichert, liegen wahrscheinlich nicht die gleichen Maßnahmen für ihren Schutz vor. Somit muss die Datensicherungsfähigkeit der Komponente Mechanismen enthalten, die den notwendigen Schutz der in der Datensicherung enthaltenen Informationen unterstützt. Dazu kann eine Verschlüsselung der Datensicherung, eine Verschlüsselung schützenswerter Daten als Teil der Datensicherungsprozedur oder der Ausschluss schützenswerter Informationen aus der Datensicherung gehören. Wird die Datensicherung verschlüsselt, ist es wichtig, die kryptografischen Schlüssel nicht in der Datensicherung abzulegen, sondern sie mit einer gesonderten, noch sichereren Datensicherungsprozedur zu speichern.

11.5.3 Weitergehende Anforderungen

(1) Verifikation der Integrität der Datensicherung

Die Komponenten müssen die Fähigkeit haben, vor einer Wiederherstellung der Information die Integrität dieser gesicherten Information zu überprüfen.

11.5.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 7.3 beziehen, sind:

- SL-C(RA,Komponente) 1: CR 7.3;
- SL-C(RA,Komponente) 2: CR 7.3 (1);
- SL-C(RA,Komponente) 3: CR 7.3 (1);
- SL-C(RA,Komponente) 4: CR 7.3 (1).

11.6 CR 7.4 – Wiederherstellung des Automatisierungssystems

11.6.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, nach einer Unterbrechung oder einem Ausfall in einen bekannten, sicheren Zustand wiederhergestellt zu werden.

11.6.2 Begründungen und zusätzliche Leitfäden

Die Wiederherstellung der Komponente in einen bekannten, sicheren Zustand bedeutet, dass alle Systemparameter (entweder voreingestellte oder konfigurierbare) auf sichere Werte gesetzt werden, Sicherheits-Patches wieder eingespielt werden, das System im Sinne der IT-Sicherheit wieder richtig konfiguriert wird, Systemdokumentation und Betriebsprozeduren verfügbar sind, Komponenten erneut installiert und mit festgelegten Einstellungen konfiguriert werden, Informationen der letzten bekannten Datensicherung wieder geladen werden und das System vollständig geprüft und funktionsfähig ist.

11.6.3 Weitergehende Anforderungen

Keine.

11.6.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 7.4 beziehen, sind:

- SL-C(RA,Komponente) 1: CR 7.4;
- SL-C(RA,Komponente) 2: CR 7.4;
- SL-C(RA,Komponente) 3: CR 7.4;
- SL-C(RA,Komponente) 4: CR 7.4.

11.7 CR 7.5 – Notstromversorgung

Mit IEC 62443-3-3 SR 7.5 sind keine Anforderungen auf Komponentenebene verbunden.

11.8 CR 7.6 – Netzwerk- und IT-Sicherheitseinstellungen

11.8.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, nach den empfohlenen Netzwerk- und IT-Sicherheitseinstellungen, so wie sie in den vom Hersteller des Automatisierungssystems zur Verfügung gestellten Anleitungen beschrieben sind, konfiguriert zu werden. Die Komponente muss eine Schnittstelle zu den momentan angewendeten Netzwerk- und IT-Sicherheitseinstellungen bereithalten.

11.8.2 Begründungen und zusätzliche Leitfäden

Diese Konfigurationseinstellungen sind die einstellbaren Parameter der Komponenten des Automatisierungssystems. Standardmäßig sollte die Komponente auf die empfohlenen Einstellungen konfiguriert werden. Um Abweichungen von den genehmigten und/oder empfohlenen Konfigurationseinstellungen einer Komponente erkennen und korrigieren zu können, muss die Komponente die Überwachung und Lenkung der Änderungen der Konfigurationseinstellungen nach den IT-Sicherheitsleitlinien und -vorgehensweisen unterstützen.

11.8.3 Weitergehende Anforderungen

- (1) maschinenlesbare Berichte über die momentanen IT-Sicherheitseinstellungen

Die Komponenten müssen die Fähigkeit haben, Berichte, die die momentan angewendeten IT-Sicherheitseinstellungen in einem maschinenlesbaren Format aufführen, zu erzeugen.

11.8.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 7.6 beziehen, sind:

- SL-C(RA,Komponente) 1: CR 7.6;
- SL-C(RA,Komponente) 2: CR 7.6;
- SL-C(RA,Komponente) 3: CR 7.6 (1);
- SL-C(RA,Komponente) 4: CR 7.6 (1).

11.9 CR 7.7 – Geringste Funktionalität

11.9.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, gezielt die Verwendung unnötiger Funktionen, Ports, Protokolle und/oder Dienste zu beschränken.

11.9.2 Begründungen und zusätzliche Leitfäden

Komponenten können eine große Vielfalt von Funktionen und Diensten zur Verfügung stellen. Einige der bereitgestellten Funktionen und Dienste sind möglicherweise für die Unterstützung des IACS nicht erforderlich. Daher sollten standardmäßig alle über eine Grundkonfiguration hinausgehende Funktionen gesperrt werden. Außerdem ist es gelegentlich zweckmäßig, mehrere Dienste von einer einzigen Komponente des Automatisierungssystems aus bereitzustellen, dadurch erhöht sich jedoch das Risiko, die von einer beliebigen anderen Komponente bereitgestellten Dienste einzuschränken.

11.9.3 Weitergehende Anforderungen

Keine.

11.9.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 7.7 beziehen, sind:

- SL-C(RA,Komponente) 1: CR 7.7;
- SL-C(RA,Komponente) 2: CR 7.7;
- SL-C(RA,Komponente) 3: CR 7.7;
- SL-C(RA,Komponente) 4: CR 7.7.

11.10 CR 7.8 – Verzeichnis der Komponenten eines Automatisierungssystems

11.10.1 Anforderung

Die Komponenten müssen die Fähigkeit haben, ein Verzeichnis der Komponenten des Automatisierungssystems nach IEC 62443-3-3 SR 7.8 zu unterstützen.

11.10.2 Begründungen und zusätzliche Leitfäden

Komponenten dürfen ihren eigenen Komponentensatz in das gesamte Automatisierungssystem einbringen. In diesem Fall müssen diese Komponenten einen Mechanismus bereitstellen, mit dem das Gesamtverzeichnis der Komponenten erweitert werden kann, der IEC 62443-2-4 SP.06.02 [3] entspricht.

11.10.3 Weitergehende Anforderungen

Keine.

11.10.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf CR 7.8 beziehen, sind:

- SL-C(RA,Komponente) 1: keine;
- SL-C(RA,Komponente) 2: CR 7.8;
- SL-C(RA,Komponente) 3: CR 7.8;
- SL-C(RA,Komponente) 4: CR 7.8.

12 Anforderungen an Softwareanwendungen

12.1 Zweck

Der Zweck dieser Anforderungen ist die Dokumentation der für Softwareanwendungen spezifischen Anforderungen.

12.2 SAR 2.4 – Mobiler Code

12.2.1 Anforderung

Falls eine Softwareanwendung Technologien mit einem mobilen Code nutzt, muss die Anwendung die Fähigkeit haben, IT-Sicherheitsleitlinien für die Nutzung dieser Technologien durchzusetzen. Die IT-Sicherheitsleitlinie muss mindestens folgende Aktionen für jede Technologie mit einem mobilen Code, die in der Softwareanwendung verwendet wird, zulassen:

- a) Kontrolle der Ausführung des mobilen Codes;
- b) Kontrolle darüber, welche Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) einen mobilen Code zu/von der Anwendung übertragen dürfen;
- c) Kontrolle über die Ausführung des mobilen Codes anhand der Ergebnisse einer Integritätsprüfung, bevor der Code ausgeführt wird.

12.2.2 Begründungen und zusätzliche Leitfäden

Technologien mit mobilem Code sind unter anderem Java, JavaScript, ActiveX, PDF, Postscript, Shockwave-Movies, Flash-Animationen und VBScript. Nutzungsbeschränkungen gelten sowohl für die Auswahl und Verwendung von auf Servern installierten als auch für die auf einzelne Arbeitsplatzrechner heruntergeladenen und dort ausgeführten mobilen Codes. Die Entwicklung, der Erwerb und die Einführung eines unzulässigen mobilen Codes innerhalb des Automatisierungssystems, in das die Komponente integriert ist, sollten durch geeignete Vorgehensweisen unterbunden werden. So könnte beispielsweise der direkte Austausch eines mobilen Codes mit dem Automatisierungssystem verboten, aber in einer überwachten, angrenzenden Umgebung, die vom Personal des IACS kontrolliert wird, erlaubt sein.

12.2.3 Weitergehende Anforderungen

- (1) Authentizitätsprüfung von mobilen Codes

Die Anwendung muss die Fähigkeit haben, eine Sicherheitsrichtlinie durchzusetzen, die es dem Gerät ermöglicht, die Ausführung von mobilen Codes auf der Grundlage der Ergebnisse einer Authentizitätsprüfung zu steuern, bevor dieser Code ausgeführt wird.

12.2.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf SAR 2.4 beziehen, sind:

- SL-C(UC,Komponente) 1: SAR 2.4;
- SL-C(UC,Komponente) 2: SAR 2.4 (1);
- SL-C(UC,Komponente) 3: SAR 2.4 (1);

- SL-C(UC,Komponente) 4: SAR 2.4 (1).

12.3 SAR 3.2 – Schutz vor Schadcodes

12.3.1 Anforderung

Der Hersteller einer Anwendung muss genau angeben und dokumentieren, welche Schutzmechanismen vor Schadcodes mit der Anwendung vereinbar sind, und er muss alle besonderen Konfigurationsanforderungen aufzeichnen.

12.3.2 Begründungen und zusätzliche Leitfäden

Der Schutz vor Schadcodes (z. B. Viren, Würmer, Trojaner und Spyware) kann von der Anwendung des Automatisierungssystems oder von einem externen Dienst oder einer externen Anwendung bereitgestellt werden. Anwendungen des Automatisierungssystems müssen mit den Mechanismen, die für ihren Schutz vor Schadcodes vorgesehen sind, vereinbar sein. Diese Anforderung impliziert nicht, dass der Hersteller alle mit der Anwendung kompatiblen Schutzmechanismen für Schadcodes qualifizieren und dokumentieren muss, sondern dass der Hersteller mindestens einen Mechanismus qualifizieren und dokumentieren muss.

12.3.3 Weitergehende Anforderungen

Keine.

12.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf SAR 3.2 beziehen, sind:

- SL-C(SI,Komponente) 1: SAR 3.2;
- SL-C(SI,Komponente) 2: SAR 3.2;
- SL-C(SI,Komponente) 3: SAR 3.2;
- SL-C(SI,Komponente) 4: SAR 3.2.

13 Anforderungen an eingebettete Geräte

13.1 Zweck

Der Zweck dieser Anforderungen ist die Dokumentation der für die eingebetteten Geräte spezifischen Anforderungen.

13.2 EDR 2.4 – Mobiler Code

13.2.1 Anforderung

Falls ein eingebettetes Gerät Technologien mit einem mobilen Code nutzt, muss das eingebettete Gerät die Fähigkeit haben, IT-Sicherheitsleitlinien für die Nutzung dieser Technologien durchzusetzen. Die IT-Sicherheitsleitlinie muss mindestens folgende Aktionen für jede Technologie mit einem mobilen Code, die im eingebetteten Gerät verwendet wird, zulassen:

- a) Kontrolle der Ausführung des mobilen Codes;
- b) Kontrolle darüber, welche Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) einen mobilen Code in das Gerät laden dürfen;
- c) Kontrolle über die Ausführung des mobilen Codes anhand der Ergebnisse einer Integritätsprüfung, bevor der Code ausgeführt wird.

13.2.2 Begründungen und zusätzliche Leitfäden

Technologien mit mobilem Code sind unter anderem Java, JavaScript, ActiveX, PDF, Postscript, Shockwave-Movies, Flash-Animationen und VBScript. Nutzungsbeschränkungen gelten sowohl für die Auswahl und Verwendung von auf Servern installierten als auch für die auf einzelne Arbeitsplatzrechner heruntergeladenen und dort ausgeführten mobilen Codes. Die Entwicklung, der Erwerb und die Einführung eines unzulässigen mobilen Codes innerhalb des Automatisierungssystems, in das die Komponente integriert ist, sollten durch geeignete Vorgehensweisen unterbunden werden. So könnte beispielsweise der direkte Austausch eines mobilen Codes mit dem Automatisierungssystem verboten, aber in einer überwachten, angrenzenden Umgebung, die vom Personal des IACS kontrolliert wird, erlaubt sein.

13.2.3 Weitergehende Anforderungen

(1) Authentizitätsprüfung von mobilen Codes

Das eingebettete Gerät muss die Fähigkeit haben, eine Sicherheitsrichtlinie durchzusetzen, die es dem Gerät ermöglicht, die Ausführung von mobilen Codes auf der Grundlage der Ergebnisse einer Authentizitätsprüfung zu steuern, bevor dieser Code ausgeführt wird.

13.2.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf EDR 2.4 beziehen, sind:

- SL-C(UC,Komponente) 1: EDR 2.4;
- SL-C(UC,Komponente) 2: EDR 2.4 (1);
- SL-C(UC,Komponente) 3: EDR 2.4 (1);
- SL-C(UC,Komponente) 4: EDR 2.4 (1).

13.3 EDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen

13.3.1 Anforderung

Eingebettete Geräte müssen vor einer nicht autorisierten Nutzung der werksseitigen physikalischen Diagnose- und Prüfschnittstelle(n) (z. B. JTAG, Fehlersuche) schützen.

13.3.2 Begründungen und zusätzliche Leitfäden

Werksseitige Diagnose- und Prüfschnittstellen werden an verschiedenen Stellen innerhalb des eingebetteten Geräts angelegt, um die Entwickler der eingebetteten Geräte und Werkspersonal bei der Prüfung der funktionellen Implementierung zu unterstützen und, wenn Fehler festgestellt werden, bei der nachfolgenden Beseitigung aus dem eingebetteten Gerät. Dieselben Schnittstellen sollten jedoch sorgfältig vor einem Zugriff durch nicht autorisierte Einheiten geschützt werden, um die wesentlichen Funktionen zu schützen, die das eingebettete Gerät für das IACS zur Verfügung stellt.

Wenn eine Diagnose- und Prüfschnittstelle nicht die Fähigkeit hat, das eingebettete Gerät zu steuern oder auf nicht öffentliche Informationen zuzugreifen, ist kein Authentifizierungsmechanismus erforderlich. Dies muss durch eine Gefährdungs- und Risikobeurteilung ermittelt werden. Ein Beispiel hierfür wäre die JTAG-Fehlersuche, bei der JTAG verwendet wird, um die Kontrolle über den Prozessor zu übernehmen und beliebige Befehle auszuführen, im Gegensatz zu einem JTAG-Boundary-Scan, bei dem JTAG zum einfachen Lesen von Informationen verwendet wird (wobei es sich um öffentlich verfügbare Informationen handeln kann).

In bestimmten Fällen nutzen die werksseitigen Diagnose- und Prüfschnittstellen eine Netzwerk-Kommunikation mit dem Gerät. Dann gelten für die betreffenden Schnittstellen alle Anforderungen dieses Dokuments.

13.3.3 Weitergehende Anforderungen

(1) Aktive Überwachung

Eingebettete Geräte müssen die Diagnose- und Prüfschnittstellen des Gerätes aktiv überwachen und ein Ereignisprotokoll erzeugen, wenn Versuche eines Zugriffs über diese Schnittstellen festgestellt wurden.

13.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf EDR 2.13 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: EDR 2.13;
- SL-C(SI,Komponente) 3: EDR 2.13 (1);
- SL-C(SI,Komponente) 4: EDR 2.13 (1).

13.4 EDR 3.2 – Schutz vor Schadcodes

13.4.1 Anforderung

Das eingebettete Gerät muss die Fähigkeit des Schutzes vor der Installation und Ausführung von nicht autorisierter Software haben.

13.4.2 Begründungen und zusätzliche Leitfäden

Nicht autorisierte Software kann Schadcodes enthalten und somit die Komponente schädigen. Wenn ein eingebettetes Gerät in der Lage ist, eine Ausgleichsmaßnahme anzuwenden, benötigt es keine direkte Unterstützung des Schutzes vor Schadcodes. Es wird davon ausgegangen, dass das IACS verantwortlich für die Bereitstellung der geforderten Schutzmaßnahmen ist. Bei Szenarien wie einem Host-Zugriff über einen lokalen USB sollte die Notwendigkeit eines Schutzes vor Schadcodes jedoch mit einer Risikobeurteilung bestimmt werden.

Erkennungsverfahren sollten Integritätsverletzungen von Programm- und Datendateien erkennen können. Hierfür verwendete Techniken sind unter anderem die Überwachung der binären Integrität und Attribute, Hash-Funktionen sowie Signaturverfahren.

Abhilfeverfahren dürfen unter anderem die Kontrolle mobiler Datenträger, Sandbox-Techniken sowie Verfahren spezieller Systemplattformen wie eingeschränkte Updates von Firmware, NX-Bits, DEP, ASLR, Erkennung einer Stack-Korruption und verbindliche Zugriffskontrollen sein. Siehe [10.4](#) für eine zugehörige Anforderung unter Einbeziehung von Überwachungswerkzeugen und -verfahren im Automatisierungssystem.

13.4.3 Weitergehende Anforderungen

Keine.

13.4.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf EDR 3.2 beziehen, sind:

- SL-C(SI,Komponente) 1: EDR 3.2;
- SL-C(SI,Komponente) 2: EDR 3.2;
- SL-C(SI,Komponente) 3: EDR 3.2;
- SL-C(SI,Komponente) 4: EDR 3.2.

13.5 EDR 3.10 – Unterstützung von Updates

13.5.1 Anforderung

Das eingebettete Gerät muss die Fähigkeit für Updates und Upgrades unterstützen.

13.5.2 Begründungen und zusätzliche Leitfäden

Innerhalb der vorgesehenen Lebensdauer müssen für eingebettete Geräte unter Umständen Updates und Upgrades installiert werden. In einigen Fällen unterstützen eingebettete Geräte auch wesentliche Funktionen und deren Ausführung. Dann muss das eingebettete Gerät Mechanismen besitzen, die ein Einspielen von Sicherheits-Patches und Updates ohne Beeinflussung der wesentlichen Funktion eines Systems mit hoher Verfügbarkeit unterstützen (siehe 4.2). Ein Beispiel für die Bereitstellung dieser Fähigkeit wäre die Unterstützung von Redundanz innerhalb des eingebetteten Gerätes.

13.5.3 Weitergehende Anforderungen

(1) Authentizität und Integrität von Updates

Das eingebettete Gerät muss vor der Installation die Authentizität und die Integrität eines Software-Updates oder Upgrades prüfen.

13.5.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf EDR 3.10 beziehen, sind:

- SL-C(SI,Komponente) 1: EDR 3.10;
- SL-C(SI,Komponente) 2: EDR 3.10 (1);
- SL-C(SI,Komponente) 3: EDR 3.10 (1);
- SLC(SI,Komponente) 4: EDR 3.10 (1).

13.6 EDR 3.11 – Physikalische Manipulationssicherheit und -erkennung

13.6.1 Anforderung

Das eingebettete Gerät muss Manipulationssicherheits- und -erkennungsmechanismen für einen nicht autorisierten physikalischen Zugriff auf das Gerät bereitstellen.

13.6.2 Begründungen und zusätzliche Leitfäden

Der Zweck von Manipulationssicherheitsmechanismen ist die Verhinderung eines Versuchs der Ausführung einer nicht autorisierten physikalischen Aktion eines Angreifers gegen ein IACS-Gerät. Neben der Verhinderung sind die Erkennung und die Reaktion maßgeblich, sollte ein Manipulationsereignis auftreten.

Manipulationssicherheitsmechanismen sind zusammen mit der Verhinderung eines Zugriffs auf kritische Komponenten am wirksamsten. Manipulationssicherheit besteht in der Anwendung besonderer Materialien, um eine Manipulation eines Gerätes oder Moduls zu erschweren. Dazu können Merkmale wie robuste Gehäuse, Schlösser, Umhüllung oder Sicherheitsschrauben gehören. Enge Luftstromwege erschweren eine interne Sondierung des Produkts.

Ein Manipulationsbeweis dient dazu, dass ein sichtbarer oder elektronischer Beweis erhalten bleibt, wenn ein Manipulationsereignis aufgetreten ist. Einfache Beweistechniken bestehen in Abdichtungen und Klebebändern, die eine physikalische Manipulation sichtbar machen. Ausgereifere Techniken beziehen Switche ein.

13.6.3 Weitergehende Anforderungen

(1) Meldung eines Manipulationsversuchs

Das eingebettete Gerät muss in der Lage sein, an einen konfigurierbaren Satz von Empfängern automatisch eine Meldung über die Erkennung eines Versuchs eines nicht autorisierten physikalischen Zugriffs abzusetzen. Sämtliche Meldungen über Manipulationen müssen als Teil des gesamten Ereignisprotokolls protokolliert werden.

13.6.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf EDR 3.11 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: EDR 3.11;
- SL-C(SI,Komponente) 3: EDR 3.11 (1);
- SL-C(SI,Komponente) 4: EDR 3.11 (1).

13.7 EDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern

13.7.1 Anforderung

Eingebettete Geräte müssen die Fähigkeit haben, Vertraulichkeit, Integrität und Authentizität der Herstellerschlüssel und -daten, die zum Zeitpunkt der Herstellung des Gerätes als Vertrauensanker benutzt werden, bereitzustellen und zu schützen.

13.7.2 Begründung und zusätzliche Leitfäden

Damit eine Komponente in der Lage ist, die Authentizität und Integrität von Hardware, Software und Daten, die vom Hersteller bereitgestellt werden, zu überprüfen, sollte sie eine vertrauenswürdige Datenquelle besitzen, um die Validierung durchzuführen. Diese vertrauenswürdige Datenquelle wird als „Vertrauensanker“ für das System bezeichnet. Sie darf aus einem Satz kryptografischer Hash-Funktionen bewährter Software bestehen oder sie darf der öffentliche Teil eines asymmetrischen kryptografischen Schlüsselpaares bei der Validierung kryptografischer Signaturen sein. Mit diesen vertrauenswürdigen Daten werden oft kritische Software, Firmware und Daten vor dem Booten der Firmware oder des Betriebssystems einer Komponente überprüft, um nachzuweisen, dass die Komponente in einen bewährten Zustand versetzt wird, in dem alle IT-Sicherheitsmechanismen bekanntermaßen betriebsbereit und unverfälscht sind. Daten von „Vertrauensankern“ werden oft durch Hardwaremechanismen geschützt, die jegliche Modifikation der Daten während des bestimmungsgemäßen Betriebs der Komponente verhindern. Eine Modifikation der Daten des Vertrauensankers des Herstellers ist gewöhnlich auf den Beschaffungsprozess des Herstellers beschränkt, in dem der Hersteller einen vertrauenswürdigen Prozess für die Beschaffung der Daten besitzt. Stattdessen werden die anhand des Vertrauensankers zu überprüfenden Informationen über eine Hardware- oder Software-API dem Validierungsprozess unterzogen, mit dem die Validierung durchgeführt wird und die Ergebnisse ohne Offenlegung der geschützten Daten zurücksendet werden.

13.7.3 Weitergehende Anforderungen

Keine.

13.7.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf EDR 3.12 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: EDR 3.12;
- SL -C(SI,Komponente) 3: EDR 3.12;
- SL-C(SI,Komponente) 4: EDR 3.12.

13.8 EDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern

13.8.1 Anforderung

Eingebettete Geräte müssen

- a) die Fähigkeit haben, Vertraulichkeit, Integrität und Authentizität der Betreiberschlüssel und -daten, die als „Vertrauensanker“ benutzt werden, bereitzustellen und zu schützen, und
- b) die Fähigkeit unterstützen, ohne auf Komponenten zu vertrauen, die sich unter Umständen außerhalb der IT-Sicherheitszone des Gerätes befinden können, bereitzustellen.

13.8.2 Begründungen und zusätzliche Leitfäden

Hersteller haben Mechanismen eingerichtet, um sicherzustellen, dass die Software und Firmware ihrer Komponenten echt ist und die Integrität dieser Software und Firmware nicht beeinträchtigt worden ist. Damit kann der Hersteller dem Betreiber einen bewährten Zustand bereitstellen, der dem Betrieb zugrunde liegt. Viele Hersteller stellen außerdem Mechanismen bereit, mit denen Betreiber die Funktionalität ihrer Geräte durch die Nutzung eines mobilen Codes, von Nutzerprogrammen oder andere Mittel erweitern können. Um die IT-Sicherheit der Komponente zu schützen, ist es wichtig, dass diese Erweiterungen der Funktionalität der Komponente auch überprüft werden, um sicherzustellen, dass sie autorisiert sind und der Betreiber ihre Herkunft bestätigt hat.

Zur Durchführung dieser Validierungen sollte die Komponente Daten enthalten, mit denen zwischen einer gültigen und einer ungültigen Herkunft unterschieden werden kann. Die Liste einer gültigen und einer ungültigen Herkunft variiert von Betreiber zu Betreiber und es ist unwahrscheinlich, dass ein Hersteller zum Zeitpunkt der Herstellung eine vollständige Liste einer jeden gültigen Herkunft besitzt. Deshalb ist es wichtig, dass der Hersteller dem Betreiber einen Weg zur Verfügung stellt, seine eigenen Vertrauensanker sicher zu erstellen, die die Fähigkeit haben, zwischen einer Herkunft, die nach den IT-Sicherheitsleitlinien des Betreibers zulässig ist, und einer Herkunft, die es nicht ist, zu unterscheiden. Die Authentizität und Integrität dieser „Vertrauensanker“ sollten geschützt werden, so dass böswillige Täter nicht zusätzliche Vertrauensanker hinzufügen können, die ihnen die Fähigkeit verschaffen, mit der Komponente zu arbeiten.

Ein Vertrauensanker kann auch als Basis für die Kommunikationssicherheit verwendet werden, z. B. Kommunikationsintegrität nach CR 3.1 – Kommunikationsintegrität (7.3) oder Kommunikationsvertraulichkeit nach CR 4.1 – Informationsvertraulichkeit (8.3).

Anforderungen wie DER 2.4 – Mobiler Code (13.2) erfordern, dass die Komponente eine Authentizitätsprüfung des mobilen Codes durchführt, bevor dieser ausgeführt wird. Die nach dieser Anforderung bereitgestellten Vertrauensanker liefern die Daten, die für die Validierung der Herkunft und Integrität des mobilen Codes erforderlich sind, wodurch die Komponente allein bestimmen kann, ob die Ausführung des Codes zulässig ist.

13.8.3 Weitergehende Anforderungen

Keine.

13.8.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf EDR 3.13 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: EDR 3.13;
- SL-C(SI,Komponente) 3: EDR 3.13;
- SL-C(SI,Komponente) 4: EDR 3.13.

13.9 EDR 3.14 – Integrität von Boot-Prozessen

13.9.1 Anforderung

Eingebettete Geräte müssen die Integrität der für den Boot-Prozess benötigten Firmware, Software und Konfigurationsdaten vor deren Anwendung beim Booten verifizieren.

13.9.2 Begründungen und zusätzliche Leitfäden

Um einem Betreiber zuzusichern, dass die IT-Sicherheitsfunktionen einer Komponente nicht gefährdet worden sind, muss sichergestellt werden, dass die Software und Firmware der Komponente nicht manipuliert wurden und die Software und Firmware gültig sind und in der Komponente ausgeführt werden können. Dafür sollte die Komponente vor dem Boot-Prozess Prüfungen zur Validierung der Integrität der Firmware und/oder Software der Komponente durchführen, um sicherzustellen, dass die Komponente nicht in einen unsicheren oder ungültigen Betriebszustand gebootet wird, der sie zerstören oder einen Weg für böswillige Täter bereitstellen kann, um Zugriff auf weitere Komponenten, Betriebsmittel oder Daten zu erlangen.

13.9.3 Weitergehende Anforderungen

(1) Authentizität des Boot-Prozesses

Eingebettete Geräte müssen die Vertrauensanker des Herstellers der Komponente nutzen, um die Authentizität der für den Boot-Prozess benötigten Firmware, Software und Konfigurationsdaten vor deren Anwendung beim Booten zu verifizieren.

13.9.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf EDR 3.14 beziehen, sind:

- SL-C(SI,Komponente) 1: EDR 3.14;
- SL-C(SI,Komponente) 2: EDR 3.14 (1);
- SL-C(SI,Komponente) 3: EDR 3.14 (1);
- SL-C(SI,Komponente) 4: EDR 3.14 (1).

14 Anforderungen an Host-Geräte

14.1 Zweck

Der Zweck dieser Anforderungen ist die Dokumentation der für die Host-Geräte spezifischen Anforderungen.

14.2 HDR 2.4 – Mobiler Code

14.2.1 Anforderung

Falls ein Host-Gerät Technologien mit einem mobilen Code nutzt, muss es die Fähigkeit haben, IT-Sicherheitsleitlinien für die Nutzung dieser Technologien durchzusetzen. Die IT-Sicherheitsleitlinie muss mindestens folgende Aktionen für jede Technologie mit einem mobilen Code, der in einem Host-Gerät verwendet wird, zulassen:

- a) Kontrolle der Ausführung des mobilen Codes;
- b) Kontrolle darüber, welche Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) einen mobilen Code in das Host-Gerät laden dürfen; und
- c) Kontrolle der Codeausführung basierend auf Integritätsprüfungen des mobilen Codes und vor der Ausführung des Codes.

14.2.2 Begründungen und zusätzliche Leitfäden

Technologien mit mobilem Code sind unter anderem Java, JavaScript, ActiveX, PDF, Postscript, Shockwave-Movies, Flash-Animationen und VBScript. Nutzungsbeschränkungen gelten sowohl für die Auswahl und Verwendung von auf Servern installierten als auch für die auf einzelne Arbeitsplatzrechner heruntergeladenen und dort ausgeführten mobilen Codes. Die Entwicklung, der Erwerb und die Einführung eines unzulässigen mobilen Codes innerhalb des Automatisierungssystems, in das das Host-Gerät integriert ist, sollten durch geeignete Vorgehensweisen unterbunden werden. So könnte beispielsweise der direkte Austausch eines mobilen Codes mit dem Automatisierungssystem verboten, aber in einer überwachten, angrenzenden Umgebung, die vom Personal des IACS kontrolliert wird, erlaubt sein.

Der mobile Code könnte durch Hinzufügen von Integritäts-, Authentizitäts- und Autorisierungsprüfungen des Codes selbst (Anwendungsebene) gesichert werden oder für eine „Just-in-Time“-Codeausführung durch Übertragen des mobilen Codes über einen sicheren Kommunikationstunnel, der diese Attribute bereitstellt, oder durch einen Mechanismus, der dieser Option entspricht, gesichert werden.

14.2.3 Weitergehende Anforderungen

(1) Authentizitätsprüfung von mobilen Codes

Das Host-Gerät muss die Fähigkeit haben, eine Sicherheitsrichtlinie durchzusetzen, die es dem Gerät ermöglicht, die Ausführung von mobilen Codes auf der Grundlage der Ergebnisse einer Authentizitätsprüfung zu steuern, bevor dieser Code ausgeführt wird.

14.2.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf HDR 2.4 beziehen, sind:

- SL-C(UC,Komponente) 1: HDR 2.4;
- SL-C(UC,Komponente) 2: HDR 2.4(1);
- SL-C(UC,Komponente) 3: HDR 2.4 (1);
- SL-C(UC,Komponente) 4: HDR 2.4 (1).

14.3 HDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen

14.3.1 Anforderung

Host-Geräte müssen vor einer nicht autorisierten Nutzung der werksseitigen physikalischen Diagnose- und Prüfschnittstelle(n) (z. B. JTAG) schützen.

14.3.2 Begründungen und zusätzliche Leitfäden

Werksseitige Diagnose- und Prüfschnittstellen werden an verschiedenen Stellen innerhalb der Host-Geräte angelegt, um Komponentenentwickler und Werkspersonal bei der Prüfung der funktionellen Implementierung zu unterstützen und, wenn Fehler festgestellt werden, bei der nachfolgenden Beseitigung aus der Komponente. Dieselben Schnittstellen sollten jedoch sorgfältig vor einem Zugriff durch nicht autorisierte Einheiten geschützt werden, um die wesentlichen Funktionen zu schützen, die die Komponente für das IACS zur Verfügung stellt.

In bestimmten Fällen nutzen die werksseitigen Diagnose- und Prüfschnittstellen eine Netzwerk-kommunikation mit dem Gerät. Dann gelten für die betreffenden Schnittstellen alle Anforderungen dieses Dokuments.

Wenn eine Diagnose- und Prüfschnittstelle nicht die Fähigkeit hat, das Host-Gerät zu steuern oder auf nicht öffentliche Informationen zuzugreifen, ist kein Authentifizierungsmechanismus erforderlich. Dies muss durch eine Gefährdungs- und Risikobeurteilung ermittelt werden. Ein Beispiel hierfür wäre die JTAG-Fehlersuche, bei der JTAG verwendet wird, um die Kontrolle über den Prozessor zu übernehmen und beliebige Befehle

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12

EN IEC 62443-4-2:2019

auszuführen, im Gegensatz zu einem JTAG-Boundary-Scan, bei dem JTAG zum einfachen Lesen von Informationen verwendet wird (wobei es sich um öffentlich verfügbare Informationen handeln kann).

14.3.3 Weitergehende Anforderungen

(1) Aktive Überwachung

Host-Geräte müssen die Diagnose- und Prüfschnittstellen des Gerätes aktiv überwachen und ein Ereignisprotokoll erzeugen, wenn Versuche eines Zugriffs über diese Schnittstellen festgestellt wurden.

14.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf HDR 2.13 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: HDR 2.13;
- SL-C(SI,Komponente) 3: HDR 2.13 (1);
- SL-C(SI,Komponente) 4: HDR 2.13 (1).

14.4 HDR 3.2 – Schutz vor Schadcodes

14.4.1 Anforderung

Host-Geräte müssen Mechanismen besitzen, die vom IACS-Hersteller für den Schutz vor Schadcodes zugelassen sind. Der IACS-Hersteller muss alle speziellen Konfigurationsanforderungen in Bezug auf den Schutz vor Schadcodes dokumentieren.

14.4.2 Begründungen und zusätzliche Leitfäden

Host-Geräte müssen den Schutz vor Schadcodes (z. B. gegen Viren, Würmer, Trojaner und Spyware) unterstützen. Der Hersteller sollte die Konfiguration von Schutzmechanismen gegen Schadcodes genau beschreiben und dokumentieren, so dass die Hauptaufgabe des Automatisierungssystems erhalten bleibt.

14.4.3 Weitergehende Anforderungen

(1) Angabe der Version des Codeschutzes

Das Host-Gerät muss automatisch die benutzte Software- oder Dokumentversion des Schutzes vor Schadcodes angeben (als Teil der gesamten Protokollierungsfunktion).

14.4.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf HDR 3.2 beziehen, sind:

- SL-C(SI,Komponente) 1: HDR 3.2;
- SL-C(SI,Komponente) 2: HDR 3.2 (1);
- SL-C(SI,Komponente) 3: HDR 3.2 (1);
- SL-C(SI,Komponente) 4: HDR 3.2 (1).

14.5 HDR 3.10 – Unterstützung von Updates

14.5.1 Anforderung

Host-Geräte müssen die Fähigkeit für Updates und Upgrades nach der Installation unterstützen.

14.5.2 Begründungen und zusätzliche Leitfäden

Innerhalb der vorgesehenen Lebensdauer müssen für Host-Geräte unter Umständen Updates und Upgrades installiert werden. In einigen Fällen unterstützen Host-Geräte auch wesentliche Funktionen und deren Ausführung. Dann sollte das Host-Gerät Mechanismen besitzen, die ein Einspielen von Sicherheits-Patches und Updates ohne Beeinflussung der wesentlichen Funktion des Systems mit hoher Verfügbarkeit unterstützen (siehe 4.2). Ein Beispiel für die Bereitstellung dieser Fähigkeit wäre die Unterstützung von Redundanz innerhalb des Host-Gerätes.

14.5.3 Weitergehende Anforderungen

(1) Authentizität und Integrität von Updates

Host-Geräte müssen vor der Installation die Authentizität und die Integrität eines Software-Updates oder Upgrades prüfen.

14.5.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf HDR 3.10 beziehen, sind:

- SL-C(SI,Komponente) 1: HDR 3.10;
- SL-C(SI,Komponente) 2: HDR 3.10 (1);
- SL-C(SI,Komponente) 3: HDR 3.10 (1);
- SL-C(SI,Komponente) 4: HDR 3.10 (1).

14.6 HDR 3.11 – Physikalische Manipulationssicherheit und -erkennung

14.6.1 Anforderung

Host-Geräte müssen Manipulationssicherheits- und -erkennungsmechanismen für einen nicht autorisierten physikalischen Zugriff auf das Gerät bereitstellen.

14.6.2 Begründungen und zusätzliche Leitfäden

Der Zweck von Manipulationssicherheitsmechanismen ist die Verhinderung eines Versuchs der Ausführung einer nicht autorisierten physikalischen Aktion eines Angreifers gegen ein IACS-Gerät. Neben der Verhinderung sind die Erkennung und die Reaktion maßgeblich, sollte ein Manipulationsereignis auftreten.

Manipulationssicherheitsmechanismen sind zusammen mit der Verhinderung eines Zugriffs auf kritische Komponenten am wirksamsten. Manipulationssicherheit besteht in der Anwendung besonderer Materialien, um eine Manipulation eines Gerätes oder Moduls zu erschweren. Dazu können Merkmale wie robuste Gehäuse, Schlösser, Umhüllung oder Sicherheitsschrauben gehören. Enge Luftstromwege erschweren eine interne Sondierung des Produkts.

Ein Manipulationsbeweis dient dazu, dass ein sichtbarer oder elektronischer Beweis erhalten bleibt, wenn ein Manipulationsereignis aufgetreten ist. Einfache Beweistechniken bestehen in Abdichtungen und Klebebändern, die eine physikalische Manipulation sichtbar machen. Ausgereifere Techniken beziehen Switches ein.

14.6.3 Weitergehende Anforderungen

(1) Meldung eines Manipulationsversuchs

Host-Geräte müssen in der Lage sein, an einen konfigurierbaren Satz von Empfängern automatisch eine Meldung über die Erkennung eines Versuchs eines nicht autorisierten physikalischen Zugriffs abzusetzen. Sämtliche Meldungen über Manipulationen müssen als Teil des gesamten Ereignisprotokolls protokolliert werden.

14.6.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf HDR 3.11 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: HDR 3.11;
- SL-C(SI,Komponente) 3: HDR 3.11 (1);
- SL-C(SI,Komponente) 4: HDR 3.11 (1).

14.7 HDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern

14.7.1 Anforderung

Host-Geräte müssen die Fähigkeit haben, Vertraulichkeit, Integrität und Authentizität der Herstellerschlüssel und -daten, die zum Zeitpunkt der Herstellung des Gerätes als „Vertrauensanker“ benutzt werden, bereitzustellen und zu schützen.

14.7.2 Begründungen und zusätzliche Leitfäden

Damit eine Komponente in der Lage ist, die Authentizität und Integrität von Hardware, Software und Daten, die vom Hersteller bereitgestellt werden, zu überprüfen, sollte sie eine vertrauenswürdige Datenquelle besitzen, um die Validierung durchzuführen. Diese vertrauenswürdige Datenquelle wird als „Vertrauensanker“ für das System bezeichnet. Sie darf aus einem Satz kryptografischer Hash-Funktionen bewährter Software bestehen oder sie darf der öffentliche Teil eines asymmetrischen kryptografischen Schlüsselpaares bei der Validierung kryptografischer Signaturen sein. Mit diesen vertrauenswürdigen Daten werden oft kritische Software, Firmware und Daten vor dem Booten der Firmware oder des Betriebssystems einer Komponente überprüft, um nachzuweisen, dass die Komponente in einen bewährten Zustand versetzt wird, in dem alle IT-Sicherheitsmechanismen bekanntermaßen betriebsbereit und unverfälscht sind. Daten von „Vertrauensankern“ können oft durch Hardwaremechanismen geschützt werden, die jegliche Modifikation der Daten während des bestimmungsgemäßen Betriebs der Komponente verhindern. Eine Modifikation der Daten des Vertrauensankers des Herstellers ist gewöhnlich auf den Beschaffungsprozess des Herstellers beschränkt, in dem der Hersteller einen vertrauenswürdigen Prozess für die Beschaffung der Daten besitzt. Stattdessen werden die anhand des Vertrauensankers zu überprüfenden Informationen über eine Hardware- oder Software-API dem Validierungsprozess unterzogen, mit dem die Validierung durchgeführt wird und die Ergebnisse ohne Offenlegung der geschützten Daten zurücksendet werden.

14.7.3 Weitergehende Anforderungen

Keine.

14.7.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf HDR 3.12 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: HDR 3.12;
- SL-C(SI,Komponente) 3: HDR 3.12;
- SL-C(SI,Komponente) 4: HDR 3.12.

14.8 HDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern

14.8.1 Anforderung

Host-Geräte müssen

- a) die Fähigkeit haben, Vertraulichkeit, Integrität und Authentizität der Betreiberschlüssel und -daten, die als „Vertrauensanker“ benutzt werden, bereitzustellen und zu schützen, und

- b) betriebsfähig sein, ohne auf Komponenten zu vertrauen, die sich unter Umständen außerhalb der IT-Sicherheitszone des Gerätes befinden können.

14.8.2 Begründungen und zusätzliche Leitfäden

Hersteller haben Mechanismen eingerichtet, um sicherzustellen, dass die Software und Firmware ihrer Komponenten echt ist und die Integrität dieser Software und Firmware nicht beeinträchtigt worden ist. Damit kann der Hersteller dem Betreiber einen bewährten Zustand bereitstellen, der dem Betrieb zugrunde liegt. Viele Hersteller stellen außerdem Mechanismen bereit, mit denen Betreiber die Funktionalität ihrer Geräte durch die Nutzung eines mobilen Codes, von Nutzerprogrammen oder anderen Mitteln erweitern können. Um die IT-Sicherheit der Komponente zu schützen, ist es wichtig, dass diese Erweiterungen der Funktionalität der Komponente auch überprüft werden, um sicherzustellen, dass sie autorisiert sind und der Betreiber ihre Herkunft bestätigt hat.

Zur Durchführung dieser Validierungen sollte die Komponente Daten enthalten, mit denen zwischen einer gültigen und einer ungültigen Herkunft unterschieden werden kann. Die Liste einer gültigen und einer ungültigen Herkunft variiert von Betreiber zu Betreiber und es ist unwahrscheinlich, dass ein Hersteller zum Zeitpunkt der Herstellung eine vollständige Liste einer jeden gültigen Herkunft besitzt. Deshalb ist es wichtig, dass der Hersteller dem Betreiber einen Weg zur Verfügung stellt, seine eigenen Vertrauensanker sicher zu erstellen, die die Fähigkeit haben, zwischen einer Herkunft, die nach den IT-Sicherheitsleitlinien des Betreibers zulässig ist, und einer Herkunft, die es nicht ist, zu unterscheiden. Die Authentizität und Integrität dieser „Vertrauensanker“ sollten geschützt werden, so dass böswillige Täter nicht zusätzliche Vertrauensanker hinzufügen können, die ihnen die Fähigkeit verschaffen, mit der Komponente zu arbeiten.

Anforderungen wie HDR 2.4 – Mobiler Code (14.2) erfordern, dass die Komponente eine Authentizitätsprüfung des mobilen Codes durchführt, bevor dieser ausgeführt wird. Die nach dieser Anforderung bereitgestellten Vertrauensanker liefern die Daten, die für die Validierung der Herkunft und Integrität des mobilen Codes erforderlich sind, wodurch die Komponente allein bestimmen kann, ob die Ausführung des Codes zulässig ist.

Ein Vertrauensanker kann auch als Basis für die Kommunikationssicherheit verwendet werden, z. B. Kommunikationsintegrität nach CR 3.1 – Kommunikationsintegrität (7.3) oder Kommunikationsvertraulichkeit nach CR 4.1 – Informationsvertraulichkeit (8.3).

14.8.3 Weitergehende Anforderungen

Keine.

14.8.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf HDR 3.13 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: HDR 3.13;
- SL-C(SI,Komponente) 3: HDR 3.13;
- SL-C(SI,Komponente) 4: HDR 3.13.

14.9 HDR 3.14 – Integrität von Boot-Prozessen

14.9.1 Anforderung

Host-Geräte müssen die Integrität der für den Boot-Prozess benötigten Firmware, Software und Konfigurationsdaten vor deren Anwendung beim Booten verifizieren.

14.9.2 Begründungen und zusätzliche Leitfäden

Um einem Betreiber zuzusichern, dass die IT-Sicherheitsfunktionen einer Komponente nicht gefährdet worden sind, muss sichergestellt werden, dass die Software und Firmware der Komponente nicht manipuliert wurden und die Software und Firmware gültig sind und in der Komponente ausgeführt werden können. Dafür sollte die Komponente vor dem Boot-Prozess Prüfungen zur Validierung der Integrität und Authentizität der Firmware und/oder Software der Komponente durchführen, um sicherzustellen, dass die Komponente nicht in einen unsicheren oder ungültigen Betriebszustand gebootet wird, der sie zerstören oder einen Weg für böswillige Täter bereitstellen kann, um Zugriff auf weitere Komponenten, Betriebsmittel oder Daten zu erlangen.

14.9.3 Weitergehende Anforderungen

(1) Authentizität des Boot-Prozesses

Host-Geräte müssen die Vertrauensanker des Herstellers nutzen, um die für den Boot-Prozess benötigte(n) Firmware, Software und Konfigurationsdaten vor deren Anwendung beim Booten zu verifizieren.

14.9.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf HDR 3.14 beziehen, sind:

- SL-C(SI,Komponente) 1: HDR 3.14;
- SL-C(SI,Komponente) 2: HDR 3.14 (1);
- SL-C(SI,Komponente) 3: HDR 3.14 (1);
- SL-C(SI,Komponente) 4: HDR 3.14 (1).

15 Anforderungen an Netzwerkkomponenten

15.1 Zweck

Der Zweck dieser Anforderungen ist die Dokumentation der für die Netzwerkkomponenten spezifischen Anforderungen.

15.2 NDR 1.6 – Verwaltung drahtloser Zugriffsverfahren

15.2.1 Anforderung

Eine Netzwerkkomponente, die eine Verwaltung drahtloser Zugriffsverfahren unterstützt, muss die Fähigkeit haben, alle Nutzer (menschliche Nutzer, Softwareprozesse oder Geräte), die an der drahtlosen Kommunikation beteiligt sind, zu identifizieren und zu authentifizieren.

15.2.2 Begründungen und zusätzliche Leitfäden

Alle drahtlosen Technologien können und sollten in den meisten Fällen nur als eine weitere Möglichkeit für ein Kommunikationsprotokoll angesehen werden. Sie sollten daher auch denselben IT-Sicherheitsanforderungen wie jede andere vom IACS benutzte Kommunikationsart unterliegen. Von einem IT-Sicherheitsstandpunkt aus gesehen gibt es daher mindestens einen signifikanten Unterschied zwischen einer drahtgebunden und einer drahtlosen Kommunikation. Physikalische IT-Sicherheitsmaßnahmen sind bei drahtloser Kommunikation normalerweise weniger wirksam.

15.2.3 Weitergehende Anforderungen

(1) Eindeutige Identifizierung und Authentifikation

Die Netzwerkkomponente muss die Fähigkeit haben, alle Nutzer (menschliche Nutzer, Softwareprozesse oder Geräte), die an der drahtlosen Kommunikation beteiligt sind, eindeutig zu identifizieren und zu authentifizieren.

15.2.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 1.6 beziehen, sind:

- SL-C(UC,Komponente) 1: NDR 1.6;
- SL-C(UC,Komponente) 2: NDR 1.6 (1);
- SL-C(UC,Komponente) 3: NDR 1.6 (1);
- SL-C(UC,Komponente) 4: NDR 1.6 (1).

15.3 NDR 1.13 – Zugriff über nicht vertrauenswürdige Netzwerke

15.3.1 Anforderung

Die Netzwerkkomponente, die einen Zugriff des Gerätes auf das Netzwerk unterstützt, muss die Fähigkeit haben, alle Arten von über nicht vertrauenswürdige Netzwerke ausgeführten Zugriffen auf das Netzwerk zu überwachen und zu kontrollieren.

15.3.2 Begründungen und zusätzliche Leitfäden

Die Netzwerkkomponente sollte vor nicht-autorisierten Verbindungen oder der Subversion von autorisierten Verbindungen schützen.

Beispiele für den Zugriff auf die Netzwerkkomponente über nicht vertrauenswürdige Netzwerke sind gewöhnlich Fernzugriffe (wie Einwählen, Breitband und Funk) sowie Verbindungen von einem Büronetz des Unternehmens (nicht über das Automatisierungssystem). Die Netzwerkkomponente kann ACL-Funktionen (en: access control list) bereitstellen, um den Zugriff durch Folgendes zu beschränken:

Schicht 2 weiterleitende Geräte, wie z. B. Ethernet-Switches:

- a) MAC-Adresse;
- b) VLAN.

Schicht 3 weiterleitende Geräte, wie Router, Gateways und Firewalls:

- a) IP-Adresse;
- b) Port und Protokoll;
- c) virtuelles privates Netz (en: virtual private network).

15.3.3 Weitergehende Anforderungen

- (1) Ausdrückliche Genehmigung von Zugriffsanforderungen

Die Netzwerkkomponente muss die Fähigkeit haben, über nichtvertrauenswürdige Netzwerke übermittelte Zugriffsanforderungen zu verweigern, sofern diese nicht durch eine zugewiesene Rolle ausdrücklich zugelassen sind.

15.3.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 1.13 beziehen, sind:

- SL-C(UC,Komponente) 1: NDR 1.13;
- SL-C(UC,Komponente) 2: NDR 1.13;
- SL-C(UC,Komponente) 3: NDR 1.13 (1);

- SL-C(UC,Komponente) 4: NDR 1.13 (1).

15.4 NDR 2.4 – Mobiler Code

15.4.1 Anforderung

Falls eine Netzwerkkomponente Technologien mit einem mobilen Code nutzt, muss sie die Fähigkeit haben, IT-Sicherheitsleitlinien für die Nutzung dieser Technologien durchzusetzen. Die IT-Sicherheitsleitlinie muss mindestens folgende Aktionen für jede Technologie mit einem mobilen Code, die in der Netzwerkkomponente angewendet wird, zulassen:

- a) Kontrolle der Ausführung des mobilen Codes;
- b) Kontrolle darüber, welche Nutzer (menschlicher Nutzer, Softwareprozess oder Gerät) einen mobilen Code zu/von einer Netzwerkkomponente übertragen dürfen; und
- c) Kontrolle der Codeausführung basierend auf Integritätsprüfungen des mobilen Codes und vor der Ausführung des Codes.

15.4.2 Begründungen und zusätzliche Leitfäden

Technologien mit mobilem Code sind unter anderem Java, JavaScript, ActiveX, PDF, Postscript, Shockwave-Movies, Flash-Animationen und VBScript. Nutzungsbeschränkungen gelten sowohl für die Auswahl und Verwendung von auf Servern installierten als auch für die auf einzelne Arbeitsplatzrechner heruntergeladenen und dort ausgeführten mobilen Codes. Die Entwicklung, der Erwerb und die Einführung eines unzulässigen mobilen Codes innerhalb des Automatisierungssystems, in das die Komponente integriert ist, sollten durch geeignete Vorgehensweisen unterbunden werden. So könnte beispielsweise der direkte Austausch eines mobilen Codes mit dem Automatisierungssystem verboten, aber in einer überwachten, angrenzenden Umgebung, die vom Personal des IACS kontrolliert wird, erlaubt sein.

Der mobile Code könnte durch Hinzufügen von Integritäts-, Authentizitäts- und Autorisierungsprüfungen des Codes selbst (Anwendungsebene) gesichert werden oder für eine „Just-in-Time“-Codeausführung durch Übertragen des mobilen Codes über einen sicheren Kommunikationstunnel, der diese Attribute bereitstellt, oder durch einen Mechanismus, der dieser Option entspricht, gesichert werden.

15.4.3 Weitergehende Anforderungen

(1) Authentizitätsprüfung von mobilen Codes

Die Netzwerkkomponente muss die Fähigkeit haben, eine Sicherheitsrichtlinie durchzusetzen, die es dem Gerät ermöglicht, die Ausführung von mobilen Codes auf der Grundlage der Ergebnisse einer Authentizitätsprüfung zu steuern, bevor dieser Code ausgeführt wird.

15.4.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 2.4 beziehen, sind:

- SL-C(UC,Komponente) 1: NDR 2.4;
- SL-C(UC,Komponente) 2: NDR 2.4 (1);
- SL-C(UC,Komponente) 3: NDR 2.4 (1);
- SL-C(UC,Komponente) 4: NDR 2.4 (1).

15.5 NDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen

15.5.1 Anforderung

Netzwerkkomponenten müssen vor einer nicht autorisierten Nutzung der werksseitigen physikalischen Diagnose- und Prüfschnittstelle(n) (z. B. JTAG, Fehlersuche) schützen.

15.5.2 Begründungen und zusätzliche Leitfäden

Werkseitige Diagnose- und Prüfschnittstellen werden an verschiedenen Stellen innerhalb der Komponente angelegt, um Komponentenentwickler und Werkspersonal bei der Prüfung der funktionellen Implementierung zu unterstützen und, wenn Fehler festgestellt werden, bei der nachfolgenden Beseitigung aus der Komponente. Dieselben Schnittstellen sollten jedoch sorgfältig vor einem Zugriff durch nicht autorisierte Einheiten geschützt werden, um die wesentlichen Funktionen zu schützen, die die Komponente für das IACS zur Verfügung stellt.

In bestimmten Fällen nutzen die werkseitigen Diagnose- und Prüfschnittstellen eine Netzwerk-kommunikation mit dem Gerät. Dann gelten für die betreffenden Schnittstellen alle Anforderungen dieses Dokuments.

Es ist zu beachten, dass, wenn eine Diagnose- und Prüfschnittstelle nicht die Fähigkeit hat, das Produkt zu steuern oder auf nicht öffentliche Informationen zuzugreifen, kein Authentifizierungsmechanismus erforderlich ist. Dies sollte durch eine Gefährdungsbeurteilung ermittelt werden. Ein Beispiel hierfür wäre die JTAG-Fehlersuche, bei der JTAG verwendet wird, um die Kontrolle über den Prozessor zu übernehmen und beliebige Befehle auszuführen, im Gegensatz zu einem JTAG-Boundary-Scan, bei dem JTAG zum einfachen Lesen von Informationen verwendet wird (wobei es sich um öffentlich verfügbare Informationen handeln kann).

15.5.3 Weitergehende Anforderungen

(1) Aktive Überwachung

Netzwerkkomponenten müssen die Diagnose- und Prüfschnittstellen des Gerätes aktiv überwachen und ein Ereignisprotokoll erzeugen, wenn Versuche eines Zugriffs über diese Schnittstellen festgestellt wurden.

15.5.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 2.13 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: NDR 2.13;
- SL-C(SI,Komponente) 3: NDR 2.13 (1);
- SL-C(SI,Komponente) 4: NDR 2.13 (1).

15.6 NDR 3.2 – Schutz vor Schadcodes

15.6.1 Anforderung

Die Netzwerkkomponente muss einen Schutz vor Schadcodes bereitstellen.

15.6.2 Begründungen und zusätzliche Leitfäden

Wenn eine Netzwerkkomponente in der Lage ist, eine Ausgleichsmaßnahme anzuwenden, benötigt sie keine direkte Unterstützung des Schutzes vor Schadcodes. Eine mögliche Ausgleichsmaßnahme wäre die Anwendung von Paketfiltern im Netzwerk, um Schadcodes während der Übertragung zu identifizieren und zu entfernen. Es wird davon ausgegangen, dass das IACS verantwortlich für die Bereitstellung der geforderten Schutzmaßnahmen ist. Bei Szenarien wie einem Host-Zugriff über einen lokalen USB sollte jedoch die Notwendigkeit eines Schutzes vor Schadcodes bestimmt werden.

15.6.3 Weitergehende Anforderungen

Keine.

15.6.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 3.2 beziehen, sind:

- SL-C(SI,Komponente) 1: NDR 3.2;
- SL-C(SI,Komponente) 2: NDR 3.2;
- SL-C(SI,Komponente) 3: NDR 3.2;
- SL-C(SI,Komponente) 4: NDR 3.2.

15.7 NDR 3.10 – Unterstützung von Updates

15.7.1 Anforderung

Netzwerkkomponenten müssen die Fähigkeit für Updates und Upgrades nach der Installation unterstützen.

15.7.2 Begründungen und zusätzliche Leitfäden

Innerhalb der vorgesehenen Lebensdauer müssen für Netzwerkkomponenten unter Umständen Updates und Upgrades installiert werden. In einigen Fällen unterstützen Netzwerkkomponenten auch wesentliche Funktionen und deren Ausführung. Dann sollten die Netzwerkkomponente Mechanismen besitzen, die ein Einspielen von Sicherheits-Patches und Updates ohne Beeinflussung der wesentlichen Funktion des Systems mit hoher Verfügbarkeit unterstützen (siehe 4.2). Ein Beispiel für die Bereitstellung dieser Fähigkeit wäre die Unterstützung von Redundanz innerhalb der Netzwerkkomponente.

15.7.3 Weitergehende Anforderungen

(1) Authentizität und Integrität von Updates

Netzwerkkomponenten müssen vor der Installation die Authentizität und die Integrität eines Software-Updates oder Upgrades prüfen.

15.7.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 3.10 beziehen, sind:

- SL-C(SI,Komponente) 1: NDR 3.10;
- SL-C(SI,Komponente) 2: NDR 3.10 (1);
- SL-C(SI,Komponente) 3: NDR 3.10 (1);
- SL-C(SI,Komponente) 4: NDR 3.10 (1).

15.8 NDR 3.11 – Physikalische Manipulationssicherheit und -erkennung

15.8.1 Anforderung

Netzwerkkomponenten müssen Manipulationssicherheits- und -erkennungsmechanismen für einen nicht autorisierten physikalischen Zugriff auf das Gerät bereitstellen.

15.8.2 Begründungen und zusätzliche Leitfäden

Der Zweck von Manipulationssicherheitsmechanismen ist die Verhinderung eines Versuchs der Ausführung einer nicht autorisierten physikalischen Aktion eines Angreifers gegen ein IACS-Gerät. Neben der Verhinderung sind die Erkennung und die Reaktion maßgeblich, sollte ein Manipulationsereignis auftreten.

Manipulationssicherheitsmechanismen sind zusammen mit der Verhinderung eines Zugriffs auf kritische Komponenten am wirksamsten. Manipulationssicherheit besteht in der Anwendung besonderer Materialien, um eine Manipulation eines Gerätes oder Moduls zu erschweren. Dazu können Merkmale wie robuste

Gehäuse, Schlösser, Umhüllung oder Sicherheitsschrauben gehören. Enge Luftstromwege erschweren eine interne Sondierung des Produkts.

Ein Manipulationsbeweis dient dazu, dass ein sichtbarer oder elektronischer Beweis erhalten bleibt, wenn ein Manipulationsereignis aufgetreten ist. Einfache Beweistechniken bestehen in Abdichtungen und Klebebändern, die eine physikalische Manipulation sichtbar machen. Ausgereifere Techniken beziehen Switche ein.

15.8.3 Weitergehende Anforderungen

(1) Meldung eines Manipulationsversuchs

Netzwerkkomponenten müssen in der Lage sein, an einen konfigurierbaren Satz von Empfängern automatisch eine Meldung über die Erkennung eines Versuchs eines nicht autorisierten physikalischen Zugriffs abzusetzen. Sämtliche Meldungen über Manipulationen müssen als Teil des gesamten Ereignisprotokolls protokolliert werden.

15.8.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 3.11 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: NDR 3.11;
- SL-C(SI,Komponente) 3: NDR 3.11 (1);
- SL-C(SI,Komponente) 4: NDR 3.11 (1).

15.9 NDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern

15.9.1 Anforderung

Netzwerkkomponenten müssen die Fähigkeit haben, Vertraulichkeit, Integrität und Authentizität der Herstellerschlüssel und -daten, die zum Zeitpunkt der Herstellung des Gerätes als „Vertrauensanker“ benutzt werden, bereitzustellen und zu schützen.

15.9.2 Begründungen und zusätzliche Leitfäden

Damit eine Komponente in der Lage ist, die Authentizität und Integrität von Hardware, Software und Daten, die vom Hersteller bereitgestellt werden, zu überprüfen, sollte sie eine vertrauenswürdige Datenquelle besitzen, um die Validierung durchzuführen. Diese vertrauenswürdige Datenquelle wird als „Vertrauensanker“ für das System bezeichnet. Sie darf aus einem Satz kryptografischer Hash-Funktionen bewährter Software bestehen oder sie darf der öffentliche Teil eines asymmetrischen kryptografischen Schlüsselpaares bei der Validierung kryptografischer Signaturen sein. Mit diesen vertrauenswürdigen Daten werden oft kritische Software, Firmware und Daten vor dem Booten der Firmware oder des Betriebssystems einer Komponente überprüft, um nachzuweisen, dass die Komponente in einen bewährten Zustand versetzt wird, in dem alle IT-Sicherheitsmechanismen bekanntermaßen betriebsbereit und unverfälscht sind. Daten von „Vertrauensankern“ werden oft durch Software- oder Hardwaremechanismen geschützt, die jegliche Modifikation der Daten während des bestimmungsgemäßen Betriebs der Komponente verhindern. Eine Modifikation der Daten des Vertrauensankers des Herstellers ist gewöhnlich auf den Beschaffungsprozess des Herstellers beschränkt, in dem der Hersteller einen vertrauenswürdigen Prozess für die Beschaffung der Daten besitzt. Stattdessen werden die anhand des Vertrauensankers zu überprüfenden Informationen über eine Hardware- oder Software-API dem Validierungsprozess unterzogen, mit dem die Validierung durchgeführt wird und die Ergebnisse ohne Offenlegung der geschützten Daten zurücksendet werden.

15.9.3 Weitergehende Anforderungen

Keine.

15.9.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 3.12 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: NDR 3.12;
- SL-C(SI,Komponente) 3: NDR 3.12;
- SL-C(SI,Komponente) 4: NDR 3.12.

15.10 NDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern

15.10.1 Anforderung

Netzwerkkomponenten müssen

- a) die Fähigkeit haben, Vertraulichkeit, Integrität und Authentizität der Betreiberschlüssel und -daten, die als „Vertrauensanker“ benutzt werden, bereitzustellen und zu schützen, und
- b) betriebsfähig sein, ohne auf Komponenten zu vertrauen, die sich unter Umständen außerhalb der IT-Sicherheitszone des Gerätes befinden können.

15.10.2 Begründungen und zusätzliche Leitfäden

Hersteller haben Mechanismen eingerichtet, um sicherzustellen, dass die Software und Firmware ihrer Komponenten echt ist und die Integrität dieser Software und Firmware nicht beeinträchtigt worden ist. Damit kann der Hersteller dem Betreiber einen bewährten Zustand bereitstellen, der dem Betrieb zugrunde liegt. Viele Hersteller stellen außerdem Mechanismen bereit, mit denen Betreiber die Funktionalität ihrer Geräte durch die Nutzung eines mobilen Codes, von Nutzerprogrammen oder andere Mittel erweitern können. Um die IT-Sicherheit der Komponente zu schützen, ist es wichtig, dass diese Erweiterungen der Funktionalität der Komponente auch überprüft werden, um sicherzustellen, dass sie autorisiert sind und der Betreiber ihre Herkunft bestätigt hat.

Zur Durchführung dieser Validierungen sollte die Komponente Daten enthalten, mit denen zwischen einer gültigen und einer ungültigen Herkunft unterschieden werden kann. Die Liste einer gültigen und einer ungültigen Herkunft variiert von Betreiber zu Betreiber und es ist unwahrscheinlich, dass ein Hersteller zum Zeitpunkt der Herstellung eine vollständige Liste einer jeden gültigen Herkunft besitzt. Deshalb ist es wichtig, dass der Hersteller dem Betreiber einen Weg zur Verfügung stellt, seine eigenen Vertrauensanker sicher zu erstellen, die die Fähigkeit haben, zwischen einer Herkunft, die nach den IT-Sicherheitsleitlinien des Betreibers zulässig ist, und einer Herkunft, die es nicht ist, zu unterscheiden. Die Authentizität und Integrität dieser „Vertrauensanker“ sollten geschützt werden, so dass böswillige Täter nicht zusätzliche Vertrauensanker hinzufügen können, die ihnen die Fähigkeit verschaffen, mit der Komponente zu arbeiten.

Anforderungen wie NDR 2.4 – Mobiler Code (15.4) erfordern, dass die Komponente eine Authentizitätsprüfung des mobilen Codes durchführt, bevor dieser ausgeführt wird. Die nach dieser Anforderung bereitgestellten Vertrauensanker liefern die Daten, die für die Validierung der Herkunft und Integrität des mobilen Codes erforderlich sind, wodurch die Komponente allein bestimmen kann, ob die Ausführung des Codes zulässig ist.

Ein Vertrauensanker wird als Basis für die Kommunikationssicherheit verwendet, z. B. Kommunikationsintegrität nach CR 3.1 – Kommunikationsintegrität (7.3) oder Kommunikationsvertraulichkeit nach CR 4.1 – Informationsvertraulichkeit (8.3).

15.10.3 Weitergehende Anforderungen

Keine.

15.10.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 3.13 beziehen, sind:

- SL-C(SI,Komponente) 1: keine;
- SL-C(SI,Komponente) 2: NDR 3.13;
- SL-C(SI,Komponente) 3: NDR 3.13;
- SL-C(SI,Komponente) 4: NDR 3.13.

15.11 NDR 3.14 – Integrität von Boot-Prozessen

15.11.1 Anforderung

Netzwerkkomponenten müssen die Integrität der für den Boot-Prozess benötigten Firmware, Software und Konfigurationsdaten vor deren Anwendung beim Booten verifizieren.

15.11.2 Begründungen und zusätzliche Leitfäden

Um einem Betreiber zuzusichern, dass die IT-Sicherheitsfunktionen einer Komponente nicht gefährdet worden sind, muss sichergestellt werden, dass die Software und Firmware der Komponente nicht manipuliert wurden und die Software und Firmware gültig sind und in der Komponente ausgeführt werden können. Dafür sollte die Komponente vor dem Boot-Prozess Prüfungen zur Validierung der Integrität und Authentizität der Firmware und/oder Software der Komponente durchführen, um sicherzustellen, dass die Komponente nicht in einen unsicheren oder ungültigen Betriebszustand gebootet wird, der sie zerstören oder einen Weg für böswillige Täter bereitstellen kann, um Zugriff auf weitere Komponenten, Betriebsmittel oder Daten zu erlangen.

15.11.3 Weitergehende Anforderungen

(1) Authentizität des Boot-Prozesses

Netzwerkkomponenten müssen die Vertrauensanker des Herstellers nutzen, um die für den Boot-Prozess benötigte(n) Firmware, Software und Konfigurationsdaten vor deren Anwendung beim Booten zu verifizieren.

15.11.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 3.14 beziehen, sind:

- SL-C(SI,Komponente) 1: NDR 3.14;
- SL-C(SI,Komponente) 2: NDR 3.14 (1);
- SL-C(SI,Komponente) 3: NDR 3.14 (1);
- SL-C(SI,Komponente) 4: NDR 3.14 (1).

15.12 NDR 5.2 – Schutz der Zonengrenze

15.12.1 Anforderung

Eine Netzwerkkomponente an einer Zonengrenze muss die Fähigkeit haben, die Kommunikation an Zonengrenzen zu überwachen und zu kontrollieren, um die im risikobasierten Zonen- und Conduits-Modell festgelegten Abtrennungen durchsetzen zu können.

15.12.2 Begründungen und zusätzliche Leitfäden

Alle Verbindungen über die jeweilige IT-Sicherheitszone nach außen sollten über verwaltete Schnittstellen erfolgen, die aus zum Schutz der Zonengrenze geeigneten Geräten bestehen (z. B. Proxies, Gateways, Router, Firewalls, unidirektionale Gateways, Guards und verschlüsselte Tunnel), die in einer effektiven Architektur aufgebaut sind (z. B. schützen Firewalls Anwendungsgateways, die sich innerhalb einer DMZ befinden). Der Schutz der Zonengrenzen des Automatisierungssystems an irgendeinem anderen Standort sollte dasselbe Schutzniveau bieten wie an dem primären Ort.

15.12.3 Weitergehende Anforderungen

- (1) Standardmäßig verweigern, als Ausnahme zulassen (en: Deny all, permit by exception)

Die Netzwerkkomponente muss die Fähigkeit haben, Netzwerkverkehr von vornherein zu verweigern und ihn nur in Ausnahmefällen zuzulassen (wird auch als „standardmäßig verweigern, als Ausnahme zulassen“ bezeichnet).

- (2) Inselbetrieb

Die Netzwerkkomponente muss die Fähigkeit haben, vor jeder Kommunikation über die Grenzen des Automatisierungssystems hinaus zu schützen (wird auch als „Inselbetrieb“ bezeichnet).

ANMERKUNG 1 Beispiele für den Einsatz dieser Fähigkeit sind Fälle, in denen ein IT-Sicherheitsverstoß oder eine IT-Sicherheitslücke im Automatisierungssystem festgestellt wurde oder ein Angriff auf Unternehmensebene stattfindet.

- (3) Im Fehlerfall geschlossen

Die Netzwerkkomponente muss die Fähigkeit haben, vor jeder Kommunikation über die Grenzen des Automatisierungssystems hinaus zu schützen, falls es zu einem Ausfall des Schutzmechanismus an den Grenzen gekommen ist (wird auch als „Fail close“ bezeichnet).

ANMERKUNG 2 Beispiele für die Nutzung dieser Fähigkeit sind Szenarien, in denen ein Versagen der Hardware oder der Stromversorgung dazu führt, dass die Schutzeinrichtungen an den Grenzen mit einem eingeschränkten Betrieb arbeiten oder vollkommen versagen.

15.12.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 5.2 beziehen, sind:

- SL-C(SI,Komponente) 1: NDR 5.2;
- SL-C(SI,Komponente) 2: NDR 5.2 (1);
- SL-C(SI,Komponente) 3: NDR 5.2 (1) (2) (3);
- SL-C(SI,Komponente) 4: NDR 5.2 (1) (2) (3).

15.13 NDR 5.3 – Allgemeine Beschränkung der persönlichen Kommunikation

15.13.1 Anforderung

Eine Netzwerkkomponente an einer Zonengrenze muss die Fähigkeit haben, davor zu schützen, dass allgemeine Nachrichten einer persönlichen Kommunikation von Nutzern oder Systemen außerhalb des Automatisierungssystems empfangen werden.

15.13.2 Begründungen und zusätzliche Leitfäden

Allgemeine persönliche Kommunikationssysteme sind unter anderem E-Mail-Systeme, soziale Medien (Twitter, Facebook, Fotogalerien usw.) oder sonstige Nachrichtendienste, die die Übertragung ausführbarer Dateien erlauben. Solche Systeme dienen üblicherweise privaten Zwecken, die nichts mit dem Betrieb des Automatisierungssystems zu tun haben, und damit übersteigen die mit einem solchen System verbundenen Risiken normalerweise jeden wahrgenommenen Nutzen.

Solche allgemeinen Kommunikationssysteme sind häufig genutzte Angriffsvektoren zur Einschleusung von Schadsoftware in ein Automatisierungssystem, zur Weiterleitung von Information, zu deren Lesen eine Berechtigung erforderlich ist, an außerhalb des Automatisierungssystems gelegene Orte und zur Erzeugung einer stark erhöhten Netzwerklast, durch die wiederum IT-Sicherheitsprobleme erzeugt oder Angriffe auf das Automatisierungssystem gestartet werden können.

Netzwerkkomponenten können solche Beschränkungen z. B. durch Blockieren einer bestimmten Kommunikation anhand der Port-Nummern und der Quell- und/oder Zieladresse sowie durch Tiefenprüfungen mittels Firewalls der Anwendungsschicht umsetzen.

15.13.3 Weitergehende Anforderungen

Keine.

15.13.4 Security-Level

Die Anforderungen für die vier Security-Level, die sich auf NDR 5.3 beziehen, sind:

- SL-C(SI,Komponente) 1: NDR 5.3;
- SL-C(SI,Komponente) 2: NDR 5.3;
- SL-C(SI,Komponente) 3: NDR 5.3;
- SL-C(SI,Komponente) 4: NDR 5.3.

Anhang A (informativ)

Gerätekategorien

A.1 Allgemeines

Die in diesen Kategorien beschriebenen Geräte sind als repräsentative Beispiele für jede Kategorie gedacht und stellen keine vollständige Liste dar.

A.2 Gerätekategorie: Eingebettetes Gerät

A.2.1 Speicherprogrammierbare Steuerung (SPS, en: Programmable logic controller)

Die Benennung „speicherprogrammierbare Steuerung“ ist aus IEC 60050-351:2013, 351-47-22 [11] abgeleitet und erweitert und wird häufig in der Prozess- und Fertigungsindustrie verwendet. Eine SPS ist ein Betriebsmittel, das gewöhnlich in den unteren Ebenen des Automatisierungssystems (wie Ebene 1 und Ebene 2 der Purdue Enterprise Reference Architecture in ANSI/ISA-95.00.01 [15]) zu finden ist. SPS sind in der Regel aus widerstandsfähiger Hardware aufgebaut, die für einen Betrieb in industriellen Umgebungen ausgelegt ist, und beruhen auf handelsüblichen ROTS. Zunehmend intelligente Sensoren und Stellglieder erhalten auch die Fähigkeit zur Prozesssteuerung. SPS und intelligente Sensoren/Stellglieder sind so programmiert, dass sie anhand der Eingabedaten aus dem Prozess (erhalten von der Messtechnik wie traditionellen Temperatursensoren, Drucksensoren, Schwingungssensoren) eine Steuerlogik ausführen. Mit den Ausgabedaten der Steuerlogik wird der industrielle Prozess (über Stellglieder wie z. B. Ventile, Pumpen) geregelt. Die Programmierung erfolgt gewöhnlich über eine Engineering-Software, die im Allgemeinen auf Host-Geräten (z. B. Laptops oder Arbeitsplatzrechner) läuft. Eine übliche Programmiersprache für die Steuerlogik ist IEC 61131-3 [13]. In größeren Systemen übermittelt die SPS oft auch die von Sensoren gemeldeten Prozessbedingungen an Server und/oder Arbeitsplatzrechner von Bedienern höherer Ebenen und empfangen Anweisungen von Steuerfunktionen und Arbeitsplatzrechnern von Bedienern höherer Ebenen, die dann in Befehle übersetzt und an Stellglieder weitergeleitet werden. Für die Kommunikation mit Funktionen höherer Ebenen wie Steuer-Servern oder Arbeitsplatzrechnern von Bedienern nutzen moderne SPS Ethernet- und TCP/IP-Protokolle, während für die Kommunikation mit der Messtechnik im Allgemeinen Feldbusse nach Industrienorm benutzt werden (von denen einige auch auf Ethernet-Trägern laufen, die aber im Allgemeinen keine TCP/IP-Stacks nutzen). Bei der Ausführung von Sicherheitsfunktion werden besondere SPS verwendet, die sicherstellen, dass der zu steuernde Prozess jederzeit innerhalb der sicheren Betriebsgrenzen bleibt. SPS, insbesondere ausführende Sicherheitsfunktionen, sollten strenge Echtzeitanforderungen sowie hohe Integritäts- und Verfügbarkeitsanforderungen erfüllen.

A.2.2 Intelligentes elektronisches Gerät (IED, en: intelligent electronic device)

Die Benennung „intelligentes elektronisches Gerät“ wird aus der IEC TR 61850-1:2013 [14] abgeleitet und erweitert. Ein intelligentes elektronisches Gerät (IED) ähnelt im Prinzip einer SPS, die Benennung wird aber im Allgemeinen in Stromversorgungssystemen (besonders in der Stationsleittechnik) angewendet. Ein IED empfängt Messwerte von der Stromversorgungs-ausrüstung (z. B. Transformatoren, Lastschalter und Leistungsschalter) und führt Funktionen der Steuerlogik oder Schutzfunktionen aus. Wie SPS werden IEDs gewöhnlich mit einer Engineering-Software, die im Allgemeinen auf Host-Geräten läuft (z. B. Laptops und Arbeitsplatzrechner), programmiert und parametrisiert. Eine moderne und genormte Art und Weise der Beschreibung der Konfiguration von IEDs und ihren Funktionen ist in der Norm IEC TR 61850-1 definiert. Die Ausgabedaten der von IEDs aufgeführten Logik werden an Stellglieder (Lastschalter, Leistungsschalter usw.) übertragen. Im Gegensatz zu SPS besitzen IEDs im Allgemeinen auch eine HMI, die es einem Nutzer ermöglicht, vor dem IED zu stehen und dessen Funktionen zu nutzen (oft ist eine Teilausrüstung notwendig, um wesentliche Funktionen zu unterstützen). Darüber hinaus müssen Stationen und damit auch die darin befindlichen IEDs vollkommen getrennt arbeiten können (z. B. ohne eine Kommunikation mit Systemen höherer Ebenen außerhalb der Station oder auch ohne eine Kommunikation mit anderen IEDs oder Arbeitsplatzrechnern oder Servern auf der Stationsebene). Moderne IEDs nutzen gewöhnlich Ethernet- und TCP/IP-Protokolle für die Kommunikation mit Komponenten höherer Ebenen, während die Kommunikation

mit anderen IEDs über Ethernet-Protokolle (in einigen Fällen auch TCP/IP-Protokolle, oft direkt über Ethernet) oder Feldbusse (von denen einige auch auf Ethernet-Trägern laufen, die aber im Allgemeinen keine TCP/IP-Stacks nutzen) erfolgen kann. Wie SPS sollten IEDs strenge Echtzeitanforderungen sowie hohe Integritäts- und Verfügbarkeitsanforderungen erfüllen.

A.3 Gerätekategorie: Netzwerkkomponente

A.3.1 Switch

Die Benennung „Switch“ ist aus IEC 60050-732:2010, 732-01-22 [12] abgeleitet und erweitert. Ein Switch ist ein Gerät in Rechnernetzwerken, das mehrere Netzwerksegmente oder Netzknoten miteinander verbindet. Ein Switch befindet sich gewöhnlich in Schicht 2 (Sicherheitsschicht) des OSI-Modells (siehe ISO/IEC 7498-1 [6]). Moderne Switches, insbesondere solche, die für größere Netzwerke vorgesehen sind, besitzen gewöhnlich Schnittstellen für das Konfigurations- und Netzwerkmanagement. Diese Schnittstellen dürfen die Konfiguration des Switches (z. B. Web-basiert über HTTP/HTTPS, Datei-basiert über FTP/SFTP, Befehlszeilen-basiert über SSH oder über einfache Netzwerkverwaltungsprotokolle (SNMP)) sowie ein Protokoll- und Ereignismanagement (z. B. via Syslog) unterstützen.

A.3.2 VPN-Terminator (en: Virtual private network (VPN) terminator)

Die Benennung „virtuelles privates Netzwerk“ ist aus IEC 60050-732:2010, 732-01-10 [12] abgeleitet und erweitert. Virtuelle private Netze sind logische Netzwerke, die die Erweiterung von privaten Netzen über Strecken möglich machen, die durch öffentliche Netze überbrückt werden. Die Nutzung des öffentlichen Netzes zur Abdeckung der Strecke ist für VPN-Nutzer transparent/unsichtbar. VPN werden durch Erzeugen eines logischen Tunnels an der Grenze der beiden Segmente des privaten Netzes errichtet. Der Tunnel wird durch VPN-Terminatoren errichtet, bei denen es sich um Geräte handelt, die sich an der Grenze des Netzes befinden. Die Datenpakete aus einem Segment werden am VPN-Terminator eingekapselt (gewöhnlich auch verschlüsselt) und dann über ein öffentliches Netz an den Partner-VPN-Terminator gesendet. Dort wird die Einkapselung entfernt (was gewöhnlich eine Entschlüsselung umfasst), und das ursprüngliche Paket wird wieder hergestellt und zum lokalen Netzsegment weiterbefördert. VPN werden auch häufig verwendet, um Roaming-Nutzern einen sicheren Zugriff auf Ressourcen in ihrem Heimnetz zu ermöglichen. In diesem Fall wirkt eine Client-Software im Roaming-Gerät als lokaler VPN-Terminator, der alle Datenpakete einkapselt (und gewöhnlich verschlüsselt) und sie zum VPN-Terminator an der Grenze des Heimnetzes befördert. Die Errichtung des Tunnels zwischen VPN-Terminatoren sollte authentifiziert werden, wobei es sich bei Roaming-Nutzern gewöhnlich um eine Nutzer-basierte Authentifikation handelt. Damit können VPN-Terminatoren benutzt werden, um Daten über Roaming-Nutzer zu erfassen, was einen Rückschluss auf deren Aufenthaltsort und weitere geschützte Daten ermöglicht.

A.4 Gerätekategorie: Host-Gerät/Anwendung

A.4.1 Arbeitsplatzrechner des Bedieners

Arbeitsplatzrechner von Bedienern werden in Automatisierungssystemen zur Anzeige von Prozessinformationen für menschliche Nutzer oder Bediener genutzt und um diesen eine Interaktion mit dem Automatisierungssystem zu ermöglichen (z. B. Bedienhandlungen für den Prozess wie z. B. das Öffnen eines Ventils, das Schließen eines Schalters, die Änderung von Sollwerten des Prozesses einleiten). In Abhängigkeit von den entsprechenden betrieblichen Anforderungen müssen Arbeitsplatzrechner von Bedienern häufig durchgehend verfügbar sein (wenigstens eine Mindestanzahl aller installierten Arbeitsplatzrechner), damit eine ununterbrochene Überwachung der Prozessbedingungen und gegebenenfalls eine sofortige Interaktion mit dem Prozess möglich sind. Für den Empfang der anzuzeigenden Daten und die Sendung der von menschlichen Nutzern ausgegebenen Befehle kommunizieren Arbeitsplatzrechner von Bedienern gewöhnlich mit Steuer-Servern und Verbindungs-Servern in den Automatisierungssystemen und mitunter auch unmittelbar mit SPS. Diese Kommunikation erfolgt im Allgemeinen über Ethernet- und TCP/IP-Protokolle. An Arbeitsplatzrechner von Bedienern werden gewöhnlich keine strengen Echtzeitanforderungen gestellt, aber hohe Integritätsanforderungen und (wenigstens als Satz von Arbeitsplatzrechnern von Bedienern) Verfügbarkeitsanforderungen. Sie bestehen in der Regel aus handelsüblicher PC-Hardware und laufen auf handelsüblichen Client-Betriebssystemen.

A.4.2 Datenhistorie

Datenhistorien dienen in Automatisierungssystemen zur Erfassung und Führung langzeitiger Verlaufsdaten des Prozesses. Diese Daten werden im Allgemeinen von Steuer-Servern oder direkt von SPS mittels Ethernet- und TCP/IP-Protokollen erfasst. Die Daten können in vielfältigen Analysen z. B. für die Prozessoptimierung oder Leitungsberichte genutzt werden, aber auch für Berichte für Regulierungsbehörden wie z. B. Emissionsberichte oder die Dokumentation der Integrität des Produktionsprozesses für das Produkt (wie sie z. B. von den Regulierungen des amerikanischen Ministeriums für Lebensmittel und Medikamente (FDA) für Pharmaprodukte gefordert werden). Datenhistorien werden in der Regel aus handelsüblicher PC/Server-Hardware aufgebaut und laufen auf handelsüblichen Client-Server-Betriebssystemen. Die Daten werden im Allgemeinen mit handelsüblichen Datenbankprodukten gespeichert. Die Kommunikation mit Datenzugriffs-Clients und Datenquellen erfolgt in der Regel mit TCP/IP-Protokollen. Abhängig von der Kritikalität des Prozessverlaufs aus der Geschäftsperspektive gelten für Datenhistorien mäßige Verfügbarkeits- und Integritätsanforderungen und gewöhnlich keine strengen Echtzeitanforderungen.

Anhang B (informativ)

Abbildung von Komponentenanforderungen (CR) und weitergehenden Anforderungen (RE) auf die SL 1 bis 4 der grundlegenden Anforderungen (FR)

B.1 Übersicht

Anhang B gibt dem Leser einen Leitfaden, wie die Security-Level 0 bis 4 anhand der grundlegenden Anforderungen (FR) über die festgelegten Komponentenanforderungen (CR) und deren zugehörige weitergehende Anforderungen (RE) abgegrenzt werden.

B.2 SL-Abbildungstabelle

Tabelle B.1 gibt an, welche Anforderungen der Komponentenebene für welche FR bei einem vorgegebenen erreichbaren Security-Level der Komponente – SL-C(xx,Komponente) – gelten. Für eine gegebene FR sind die geforderten Anforderungen der Komponentenebene, um das bestimmte SL-C zu erfüllen, mit einem Häkchen markiert.

Beispielsweise erfüllt eine Komponente, die in FR 7 SL-1 erreicht, die Grundanforderungen von CR 7.1 bis CR 7.7. Es ist zu beachten, dass das Erfüllen von CR 7.8 nicht erforderlich ist, um SL-1 zu erfüllen, da es erst bei SL-2 und höheren Sicherheitsstufen ausgewählt wird. Das Erfüllen von SL-1 auf diese Weise wird auch als SL-C(RA,Komponente) = 1 bezeichnet, um anzuzeigen, dass die Komponente eine Fähigkeits-Sicherheitsstufe von 1 in Bezug auf Ressourcenverfügbarkeit oder FR 7 aufweist.

Eine Komponente, die SL-2 in FR 7 oder SL-C(RA,Komponente) = 2 erfüllt, erfüllt alle Anforderungen von SL-1 und erfüllt zusätzlich CR 7.1 RE(1), CR 7.3 RE(1) und die Grundanforderung für CR 7.8.

Ähnliches gilt für eine Komponente, die SL-3 in FR 7 oder SL-C(RA,Komponente) = 3 erfüllt, sie erfüllt alle Anforderungen von SL-2 und zusätzlich die von CR 7.6 RE(1).

Eine Komponente, die SL-4 in FR7 oder SL-C(RA,Komponente) = 4 erfüllt, erfüllt alle Anforderungen von SL-3. In FR 7 gibt es keine Grundanforderungen oder Anforderungsverbesserungen, die nur für SL-4 gelten, und daher erfüllen alle Komponenten, die SL-3 erfüllen, auch SL-4.

In IEC 62443-3-3:2013, Anhang A wird beschrieben, wie ein vollständiger SL-Vektor, der alle grundlegenden Anforderungen enthält, bezeichnet wird.

Zur Verdeutlichung werden die in der Tabelle verwendeten Akronyme am Ende der Tabelle angezeigt.

Tabelle B.1 – Abbildung von Komponentenanforderungen (CR) und weitergehenden Anforderungen (RE) auf die SL 1 bis 4 der grundlegenden Anforderungen (FR) (1 von 6)

SR und RE	SL 1	SL 2	SL 3	SL 4
FR 1 – Identifizierung und Authentifikation (IAC)				
CR 1.1 – Identifizierung und Authentifikation von menschlichen Nutzern	✓	✓	✓	✓
RE (1) Eindeutige Identifizierung und Authentifikation:		✓	✓	✓
RE (2) Multifaktor-Authentifikation über alle Schnittstellen			✓	✓

Tabelle B.1 (2 von 6)

SR und RE	SL 1	SL 2	SL 3	SL 4
CR 1.2 – Identifizierung und Authentifikation von Softwareprozessen und Geräten		✓	✓	✓
RE (1) Eindeutige Identifizierung und Authentifikation			✓	✓
CR 1.3 – Nutzerkontenverwaltung	✓	✓	✓	✓
CR 1.4 – Verwaltung der Kennungen	✓	✓	✓	✓
CR 1.5 – Verwaltung der Authentifizierer	✓	✓	✓	✓
RE (1) Hardwaresicherheit für Authentifizierer			✓	✓
NDR 1.6 – Verwaltung drahtloser Zugriffsverfahren	✓	✓	✓	✓
RE (1) Eindeutige Identifizierung und Authentifikation		✓	✓	✓
CR 1.7 – Stärke der Authentifikation durch Passwörter	✓	✓	✓	✓
RE (1) Erzeugung und Lebensdauerbeschränkungen von Passwörtern für menschliche Nutzer			✓	✓
RE (2) Lebensdauerbeschränkungen von Passwörtern für alle Nutzer (menschliche Nutzer, Softwareprozess oder Gerät)				✓
CR 1.8 – PKI-Zertifikate		✓	✓	✓
CR 1.9 – Stärke der Authentifikation durch öffentliche Schlüssel		✓	✓	✓
RE (1) Hardwaresicherheit für eine Authentifikation durch öffentliche Schlüssel			✓	✓
CR 1.10 – Rückmeldung vom Authentifizierer	✓	✓	✓	✓
CR 1.11 – Erfolgreiche Anmeldeversuche	✓	✓	✓	✓
CR 1.12 – Nutzungshinweis des Systems	✓	✓	✓	✓
NDR 1.13 – Zugriff über nicht vertrauenswürdige Netzwerke	✓	✓	✓	✓
RE (1) Ausdrückliche Genehmigung von Zugriffsanforderungen			✓	✓
CR 1.14 – Stärke der Authentifikation durch symmetrische Schlüssel		✓	✓	✓
RE (1) Hardwaresicherheit für eine Authentifikation durch symmetrische Schlüssel			✓	✓
FR 2 – Nutzungskontrolle (UC)				
CR 2.1 – Durchsetzung der Autorisierung	✓	✓	✓	✓
RE (1) Durchsetzung der Autorisierung für alle Nutzer (menschliche Nutzer, Softwareprozesse und Geräte)		✓	✓	✓
RE (2) Abbildung der Berechtigung auf Rollen		✓	✓	✓
RE (3) Eingriff des Aufsichtspersonals			✓	✓
RE (4) Doppelte Zustimmung				✓

Tabelle B.1 (3 von 6)

SR und RE	SL 1	SL 2	SL 3	SL 4
CR 2.2 – Nutzungskontrolle von Funkverbindungen	✓	✓	✓	✓
CR 2.3 – Nutzungskontrolle von tragbaren und mobilen Geräten				
SAR 2.4 – Mobiler Code	✓	✓	✓	✓
RE (1) Authentizitätsprüfung von mobilen Codes		✓	✓	✓
EDR 2.4 – Mobiler Code	✓	✓	✓	✓
RE (1) Authentizitätsprüfung von mobilen Codes		✓	✓	✓
HDR 2.4 – Mobiler Code	✓	✓	✓	✓
RE (1) Authentizitätsprüfung von mobilen Codes		✓	✓	✓
NDR 2.4 – Mobiler Code	✓	✓	✓	✓
RE (1) Authentizitätsprüfung von mobilen Codes		✓	✓	✓
CR 2.5 – Sitzungssperrung	✓	✓	✓	✓
CR 2.6 – Beendigung einer Fernzugriffssitzung		✓	✓	✓
CR 2.7 – Kontrolle gleichzeitiger Sitzungen			✓	✓
CR 2.8 – Prüfbare Ereignisse	✓	✓	✓	✓
CR 2.9 – Speicherkapazität für Ereignisdatensätze	✓	✓	✓	✓
RE (1) Warnung, wenn die Speicherkapazität für Ereignisdatensätze erreicht ist			✓	✓
CR 2.10 – Verhalten bei Verarbeitungsfehlern von Ereignisdaten	✓	✓	✓	✓
CR 2.11 – Zeitstempel	✓	✓	✓	✓
RE (1) Zeitsynchronisierung		✓	✓	✓
RE (2) Schutz und Integrität der Zeitquelle				✓
CR 2.12 – Nichtabstreitbarkeit	✓	✓	✓	✓
RE (1) Nichtabstreitbarkeit für alle Nutzer				✓
EDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen		✓	✓	✓
RE (1) Aktive Überwachung			✓	✓
HDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen		✓	✓	✓
RE (1) Aktive Überwachung			✓	✓
NDR 2.13 – Nutzung von physikalischen Diagnose- und Prüfschnittstellen		✓	✓	✓
RE (1) Aktive Überwachung			✓	✓

Tabelle B.1 (4 von 6)

SR und RE	SL 1	SL 2	SL 3	SL 4
FR 3 – Systemintegrität (SI)				
CR 3.1 – Kommunikationsintegrität	✓	✓	✓	✓
RE (1) Authentifikation der Kommunikation		✓	✓	✓
SAR 3.2 – Schutz vor Schadcodes	✓	✓	✓	✓
EDR 3.2 – Schutz vor Schadcodes	✓	✓	✓	✓
HDR 3.2 – Schutz vor Schadcodes	✓	✓	✓	✓
RE (1) Angabe der Version des Codeschutzes		✓	✓	✓
NDR 3.2 – Schutz vor Schadcodes	✓	✓	✓	✓
CR 3.3 – Verifikation der IT-Sicherheitsfunktionalität	✓	✓	✓	✓
RE (1) Verifikation der IT-Sicherheitsfunktionalität im laufenden Betrieb				✓
CR 3.4 – Software- und Informationsintegrität	✓	✓	✓	✓
RE (1) Authentizität der Software und der Informationen		✓	✓	✓
RE (2) Automatisierte Meldung von IT-Sicherheitsverstößen			✓	✓
CR 3.5 – Eingabevalidierung	✓	✓	✓	✓
CR 3.6 – Vorbestimmte Zustände der Ausgänge	✓	✓	✓	✓
CR 3.7 – Fehlerbehandlung	✓	✓	✓	✓
CR 3.8 – Sitzungsintegrität		✓	✓	✓
CR 3.9 – Schutz von Prüfinformationen		✓	✓	✓
RE (1) Ereignisdatensätze auf nur einmal beschreibbaren Speichermedien				✓
EDR 3.10 – Unterstützung von Updates	✓	✓	✓	✓
RE (1) Authentizität und Integrität von Updates		✓	✓	✓
HDR 3.10 – Unterstützung von Updates	✓	✓	✓	✓
RE (1) Authentizität und Integrität von Updates		✓	✓	✓
NDR 3.10 – Unterstützung von Updates	✓	✓	✓	✓
RE (1) Authentizität und Integrität von Updates		✓	✓	✓
EDR 3.11 – Physikalische Manipulationssicherheit und -erkennung		✓	✓	✓
RE (1) Meldung eines Manipulationsversuchs			✓	✓
HDR 3.11 – Physikalische Manipulationssicherheit und -erkennung		✓	✓	✓

Tabelle B.1 (5 von 6)

SR und RE	SL 1	SL 2	SL 3	SL 4
RE (1) Meldung eines Manipulationsversuchs			✓	✓
NDR 3.11 – Physikalische Manipulationssicherheit und -erkennung		✓	✓	✓
RE (1) Meldung eines Manipulationsversuchs			✓	✓
EDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern		✓	✓	✓
HDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern		✓	✓	✓
NDR 3.12 – Bereitstellung von Hersteller-Vertrauensankern		✓	✓	✓
EDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern		✓	✓	✓
HDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern		✓	✓	✓
NDR 3.13 – Bereitstellung von Betreiber-Vertrauensankern		✓	✓	✓
EDR 3.14 – Integrität von Boot-Prozessen	✓	✓	✓	✓
RE (1) Authentizität des Boot-Prozesses		✓	✓	✓
HDR 3.14 – Integrität von Boot-Prozessen	✓	✓	✓	✓
RE (1) Authentizität des Boot-Prozesses		✓	✓	✓
NDR 3.14 – Integrität von Boot-Prozessen	✓	✓	✓	✓
RE (1) Authentizität des Boot-Prozesses		✓	✓	✓
FR 4 – Vertraulichkeit der Daten (DC)				
CR 4.1 – Vertraulichkeit von Informationen	✓	✓	✓	✓
CR 4.2 – Dauerhaftigkeit von Informationen		✓	✓	✓
RE (1) Löschen gemeinsam genutzter Speicherressourcen			✓	✓
RE (2) Verifikation der Löschung			✓	✓
CR 4.3 – Verwendung von Verschlüsselung	✓	✓	✓	✓
FR 5 – Eingeschränkter Datenfluss (RDF)				
CR 5.1 – Netzaufteilung	✓	✓	✓	✓
NDR 5.2 – Schutz der Zonengrenze	✓	✓	✓	✓
RE (1) Standardmäßig verweigern, als Ausnahme zulassen (en: Deny all, permit by exception)		✓	✓	✓
RE (2) Inselbetrieb			✓	✓
RE (3) Im Fehlerfall geschlossen			✓	✓
NDR 5.3 – Allgemeine Beschränkung der persönlichen Kommunikation	✓	✓	✓	✓

Tabelle B.1 (6 von 6)

SR und RE	SL 1	SL 2	SL 3	SL 4
FR 6 – Rechtzeitige Reaktion auf Ereignisse (TRE)				
CR 6.1 – Zugriffsmöglichkeit auf Ereignisprotokolle	✓	✓	✓	✓
RE (1) Programmgesteuerter Zugriff auf Ereignisprotokolle			✓	✓
CR 6.2 – Kontinuierliche Überwachung		✓	✓	✓
FR 7 – Verfügbarkeit der Ressourcen (RA)				
CR 7.1 – Schutz vor Denial-of-Service-Ereignissen	✓	✓	✓	✓
RE(1) Verwaltung der Kommunikationslast durch eine Komponente		✓	✓	✓
CR 7.2 – Ressourcenmanagement	✓	✓	✓	✓
CR 7.3 – Datensicherung im Automatisierungssystem (Backup)	✓	✓	✓	✓
RE (1) Verifikation der Integrität der Datensicherung		✓	✓	✓
CR 7.4 – Wiederherstellung des Automatisierungssystems	✓	✓	✓	✓
CR 7.5 – Notstromversorgung				
CR 7.6 – Netzwerk- und IT-Sicherheitseinstellungen	✓	✓	✓	✓
RE (1) Maschinenlesbare Berichte über die momentanen IT-Sicherheitseinstellungen			✓	✓
CR 7.7 – Geringste Funktionalität	✓	✓	✓	✓
CR 7.8 – Verzeichnis der Komponenten eines Automatisierungssystems		✓	✓	✓
Legende CR: Komponentenanforderung, die für alle Arten von Komponenten gemeinsam gilt (en: component requirement) SAR: Anforderungen an Softwareanwendungen (en: software application requirement) EDR: Anforderungen an eingebettete Geräte (en: embedded device requirement) HDR: Anforderungen an Host-Geräte (en: host device requirement) NDR: Anforderungen an Netzwerkkomponenten (en: network device requirement)				

Literaturhinweise

ANMERKUNG 1 Diese Literaturhinweise enthalten Verweisungen auf Quellen, die bei der Erstellung dieser Norm verwendet wurden, sowie Verweisungen auf Quellen, die dem Leser zu einem besseren Verständnis der IT-Sicherheit als Ganzes und des Entwicklungsprozesses eines IT-Sicherheit-Managementsystems verhelfen können. Nicht alle Verweisungen in diesen Literaturhinweisen werden im Text der Norm erwähnt. Die Verweisungen wurden je nach Art der Quelle in verschiedenen Kategorien zusammengefasst.

Verweisungen auf andere sowohl veröffentlichte als auch in Bearbeitung befindliche Teile der Normenreihe IEC 62443:

ANMERKUNG 2 Unter den Verweisungen sind veröffentlichte, in Bearbeitung befindliche oder zu erwartende Dokumente genannt. Diese Dokumente sind der Vollständigkeit halber zusätzlich zu den zur Zeit autorisierten Teilen der Normenreihe IEC 62443.

- [1] IEC 62443-2-1, *Industrial communication networks – Network and system security – Part 2-1: Establishing an industrial automation and control system security program*
- [2] IEC TR 62443-2-3, *Security for industrial automation and control systems – Part 2-3: Patch management in the IACS environment*
- [3] IEC 62443-2-4, *Security for industrial automation and control systems – Part 2-4: Security program requirements for IACS service providers*
- [4] IEC TR 62443-3-1, *Industrial communication networks – Network and system security – Part 3-1: Security technologies for industrial automation and control systems*
- [5] IEC 62443-3-2⁴, *Security for industrial automation and control systems – Part 3-2: Security risk assessment and system design*

ANMERKUNG Harmonisiert als EN 62443-3-2.^{Z1}

Andere Verweisungen auf Normen:

- [6] ISO/IEC 7498-1:1994, *Information technology – Open Systems Interconnection – Basic Reference Model: The Basic Model*
 - [7] ISO/IEC 8601:2004, *Data elements and interchange formats – Information interchange – Representation of dates and times*
 - [8] ISO/IEC 15408-1:2009, *Information technology – Security techniques – Evaluation criteria for IT security – Part 1: Introduction and general model*
 - [9] ISO/IEC 19790, *Information technology – Security techniques – Security requirements for cryptographic modules*
 - [10] ISO/IEC 27002:2013, *Information technology – Security techniques – Code of practice for information security management*
- ANMERKUNG Harmonisiert als EN ISO/IEC 27002:2017 (nicht modifiziert).
- [11] IEC 60050-351, *International Electrotechnical Vocabulary – Part 351: Control technology* (verfügbar unter <http://www.electropedia.org>)

⁴ In Vorbereitung. Stand zum Zeitpunkt der Veröffentlichung: IEC PRVC 62443-3-2:2018.

^{Z1} In Vorbereitung. Dokumentstufe zum Zeitpunkt der Veröffentlichung: prEN 62443-3-2:2018.

DIN EN IEC 62443-4-2 (VDE 0802-4-2):2019-12
EN IEC 62443-4-2:2019

- [12] IEC 60050-732, *International Electrotechnical Vocabulary – Part 732: Computer network technology* (verfügbar unter <http://www.electropedia.org>)
- [13] IEC 61131-3, *Programmable controllers – Part 3: Programming languages*
- [14] IEC TR 61850-1:2013, *Communication networks and systems for power utility automation – Part 1: Introduction and overview*
- [15] ANSI/ISA-95.00.01-2010 (IEC 62264-1 Mod), *Enterprise-Control System Integration – Part 1: Models and Terminology*
 ANMERKUNG Harmonisiert als EN 62264-1.
- [16] ISO/IEC 11889-1:2015, *Information technology – Trusted Platform Module Library – Part 1: Architecture*

Andere Dokumente und Veröffentlichungen:

- [17] FIPS 140-2, *Security Requirements for Cryptographic Modules*
- [18] NIST SP 800-57, *Recommendation for Key Management – Part 1: General*
- [19] NIST SP 800-92, *Guide to Computer Security Log Management*
- [20] NIST SP 800-63-2, *Electronic Authentication Guideline*

Webseiten:

- [21] OWASP Code Review Guide, verfügbar unter https://www.owasp.org/index.php/Code_Review_Guide
- [22] RFC 3647 – Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework
<https://www.ietf.org/rfc/rfc3647.txt>